Thomas Cambrai

Cybersécurité

La sécurité informatique pour protéger vos systèmes et vos réseaux



Cybersécurité

La sécurité informatique pour protéger vos systèmes et vos réseaux

Thomas Cambrai

SOMMAIRE

SOMMAIRE

AVANT-PROPOS

INTRODUCTION

CHAPITRE 1 : LE DOMAINE DE LA SÉCURITÉ

- A. Les enjeux
- B. La typologie des réseaux et des systèmes
- C. Le périmètre et la segmentation

CHAPITRE 2 : LES CONCEPTS ET LA DÉMARCHE DE LA SÉCURITÉ

- A. Les objectifs de la sécurité
- B. La politique de sécurité
- C. Les fonctions de sécurité
- D. La mise en vigueur de la sécurité

CHAPITRE 3 : LES MENACES ET LES VULNÉRABILITÉS

- A. Statistiques sur la sécurité et sur le coût de l'insécurité
- B. La typologie des attaquants
- C. Les attaques traditionnelles
- D. Les attaques modernes
- E. Le cyberterrorisme
- F. Les atteintes à la liberté individuelle : la filature électronique
- G. Les vulnérabilités des systèmes
- H. Les défaillances dans la conception et la fabrication des systèmes
- I. Le maillon faible : l'intervention humaine

CHAPITRE 4 : LES PRINCIPES DE LA SÉCURITÉ NUMÉRIQUE

- A. Les modèles opérationnels
- B. La dualité de l'intimité numérique et de la sécurité collective : la dignité numérique
- C. La confiance en la sécurité offerte : la souveraineté numérique
- D. Les méthodologies d'évaluation

CHAPITRE 5 : LES OUTILS CRYPTOGRAPHIQUES DE SÉCURITÉ

- A. Les deux familles d'algorithmes de chiffrement
- B. Les infrastructures de confiance
- C. Les protocoles cryptographiques

CHAPITRE 6 : LA SÉCURITÉ DES RÉSEAUX

- A. La sécurité des réseaux cellulaires
- B. La sécurité des accès sur Internet
- C. La sécurité des réseaux sans fil

CHAPITRE 7 : LES DISPOSITIFS DE SÉCURITÉ

- A. Les pare-feu

B. Les systèmes de détection et de prévention d'intrusion
C. Les pots de miel

CHAPITRE 8 : LES SOLUTIONS D'IDENTIFICATION ET D'AUTHENTIFICATION

A. La biométrie : une présence numérique liant l'homme au système
B. La carte à puce : un écrin de confiance pour amorcer la sécurité

CHAPITRE 9 : LA SÉCURITÉ DES SYSTÈMES CONFINÉS

A. La sécurité des systèmes embarqués
B. La sécurité des terminaux

CHAPITRE 10 : LA SÉCURITÉ DES SYSTÈMES ET DES LOGICIELS

A. La sécurité des systèmes d'exploitation : la faille essentielle
B. La sécurité des logiciels : les réponses providentielles, propriétaires ou publiques

CHAPITRE 11 : LA SÉCURITÉ SUR MOBILE

A. Quelles sont les quatre grandes menaces mobiles du moment et comment s'en prémunir ?
B. Collusion des applications : Nouvelle menace sur mobile

CHAPITRE 12 : LA SÉCURITÉ DES CONTENUS

A. La sécurité dans un monde en clair
B. Le tatouage : une marque pour attester sa propriété

CHAPITRE 13 : LE CAS DU RANSOMWARE

A. Comprendre ce qu'est le ransomware
B. Votre ordinateur est pris en otage
C. Les ransomwares sont-ils rentables pour les hackers ?
D. Comment se protéger face aux ransomwares ?

CHAPITRE 14 : COMMENT AMÉLIORER SON HYGIÈNE DE VIE NUMÉRIQUE ?

A. Comment protéger sa vie privée sur Internet ?
B. Introduction à Tor et visite du dark web
C. Les 6 conseils d'Edward Snowden pour protéger ses données personnelles en ligne

CHAPITRE 15 : LES PERSPECTIVES DE RECHERCHE

CONCLUSION

AVANT-PROPOS

« La sécurité est un enjeu majeur des technologies numériques modernes. »

Infrastructures de télécommunication (GSM, GPRS, UMTS), réseaux sans fils (Bluetooth, WiFi, WiMax), Internet, systèmes d'information, routeurs, ordinateurs, téléphones, décodeurs de télévision, assistants numériques, systèmes d'exploitation, applications informatiques, toutes ces entités présentent des vulnérabilités : faille de sécurité, défaut de conception ou de configuration.

Ces systèmes tombent en panne, subissent des erreurs d'utilisation et sont attaqués de l'extérieur ou de l'intérieur par des pirates ludiques, des cybercriminels, ou sont la proie d'espionnage industriel. Une approche globale de la sécurité des systèmes est essentielle pour protéger la vie privée, pour défendre le patrimoine d'une entreprise ou pour réduire les vulnérabilités des grands systèmes d'information. Nous présenterons d'abord les différents aspects de la sécurité : politique et fonctions de sécurité, menaces et vulnérabilités.

Nous introduisons ensuite les principes et les mécanismes de sécurité : cryptographie (chiffrement, signature, protocoles cryptographiques), infrastructure de confiance (IGC ou PKI, certificats). Nous exposons les solutions de sécurité : SSL, IPSec, VPN, sécurité des réseaux cellulaires, de l'Internet et sans fil, pare-feu, système de détection d'intrusion, pot de miel, biométrie, carte à puce, sécurité des systèmes embarqués, des systèmes d'exploitation, des logiciels et tatouage. Nous terminons par un panorama des défis de la recherche en sécurité.

INTRODUCTION

Virus informatiques, actes de malveillance interne ou externe, failles de sécurité, espionnage industriel, tous ces dangers constituent la préoccupation majeure des responsables informatiques des entreprises. Cette inquiétude se manifeste aussi chez les utilisateurs et parvient même à troubler la confiance des citoyens dans leur relation avec les technologies numériques.

Tout le monde a été confronté aux phénomènes suivants : fraude informatique, usurpation de numéro de carte bancaire, vol de carte de téléphonie mobile, irruption de sites sordides sur Internet, invasion de la messagerie non sollicitée, atteinte à la vie privée, filature électronique, vidéosurveillance, inquisition numérique. La sécurité des réseaux et des systèmes est une discipline en pleine évolution, au rythme du déploiement d'une urbanisation digitale autour de l'activité humaine, de l'appropriation concomitante des technologies numériques par un large public sous le joug fatal et incontournable de la société numérique, et même de l'addiction à Internet ou au téléphone mobile d'une partie de la population.

La naissance d'une ubiquité de la communication qui permet de se brancher sur les infrastructures de réseaux, en tout lieu et en tout temps, et l'émergence d'une ubiquité du calcul qui permet de traiter l'information sur ces infrastructures ont provoqué des phénomènes croissants de délinquance informatique.

La cybercriminalité, prolongement de la violence du monde réel qui se reflète dans le monde virtuel, emprunte la brèche essentielle des systèmes numériques : la volatilité de l'information. Une donnée numérique peut être divulguée, copiée, plagiée, falsifiée ou détruite.

Dans l'univers numérique, véritable village virtuel violent, il n'existe pas une œuvre originale avec des éventuelles copies, il n'existe que des clones identiques que l'on peut reproduire à l'infini. Ce miroir multiplicateur est une vulnérabilité engendrée par l'indépendance consubstantielle à la nature numérique entre le support physique et le contenu intangible de l'information.

Pour accompagner la croissance incoercible des patrimoines numériques des personnes et des entreprises, il est indispensable de contrecarrer les accidents dus à la fatalité aussi bien que les actions malveillantes des pirates par une politique

de sécurité qui doit être mise en vigueur, par chaque citoyen et dans chaque institution, grâce à un dispositif, à la fois technique et organisationnel. La gamme des méthodes actuelles et des outils existants permet de parer aux erreurs humaines et aux périls qui risquent de porter atteinte à la confidentialité, à l'intégrité ou à la disponibilité des réseaux et des systèmes. Par ailleurs, la recherche en sécurité est en plein essor. L'objectif est d'améliorer la maîtrise de la circulation des informations sur les réseaux, de favoriser la dissémination des applications informatiques et d'encourager l'appropriation des technologies numériques par un large public.

Dans cet ouvrage sur la sécurité, nous rappellerons les impératifs de sécurité, les menaces et les risques. Nous exposerons ensuite les techniques de sécurité, qui s'appuient essentiellement sur un catalogue de fonctions de sécurité qu'il faut exhiber pour contrer les menaces. Ces fonctions de sécurité mettent en œuvre des techniques cryptographiques pour protéger les informations ou pour sécuriser les interfaces entre les ordinateurs. De plus, des dispositifs particuliers de sécurité existent et sont déployés pour sécuriser des zones sensibles des réseaux, comme les points d'accès ou les frontières des systèmes.

La gestion de la sécurité est le sujet délicat de ces techniques car il faut notamment sécuriser ces fonctions de sécurité. Après un tour d'horizon des protocoles cryptographiques, des architectures de sécurité des différents réseaux, des dispositifs de sécurité, de la sécurité des divers systèmes et des contenus, nous esquisserons les verrous technologiques de la recherche en sécurité numérique.

Une urbanisation digitale fragile

Depuis la chute du mur de Berlin, on observe un mouvement général dans le monde, l'effondrement des frontières accordant une libre circulation des marchandises, des individus et des idées. Les systèmes numériques n'échappent pas à cette tendance. Une évolution des services, des infrastructures, des réseaux et des architectures informatiques, s'organise autour d'utilisateurs plus nomades, avec des éléments mobiles ou déplaçables, par du matériel informatique modulaire, du logiciel mobile et des données fluides De vastes infrastructures s'échafaudent depuis le succès d'Internet. Une urbanisation hétérogène s'installe au niveau des réseaux d'accès pour quadriller la Terre et créer une ubiquité de la communication.

Des initiatives de méta-calcul briguent la complexion d'une ubiquité des calculs pour entrer en compétition avec les réseaux d'information actuels. Tous ces mouvements se construisent autour des deux ressorts de la technologie moderne : Internet et les réseaux cellulaires.

- Internet s'est révélé un authentique laboratoire informatique en vraie grandeur, un pur accélérateur d'expérimentation et d'usage et a fédéré grâce à sa capacité d'interconnexion (réseau de réseaux, avec le protocole IP comme point focal) de nouveaux concepts sur des principes efficaces de simplicité et a balayé sur son passage des concepts désormais caducs. Malgré cette réussite, Internet a acquis au fil du temps une mauvaise réputation, en termes de sécurité et d'intimité numérique, forgée sur le caractère anonyme et virtuel de son fonctionnement et accentuée par les conséquences néfastes de l'éthique libertaire prônée par ses précurseurs.

- Les réseaux cellulaires ont réuni les utilisateurs autour du sentiment d'appartenir à une communauté délivrée du carcan des fils et des câbles, branchée sur le monde, et ont ressuscité au niveau du développement logiciel, l'informatique « janséniste » et confinée du temps réel embarqué. Les réseaux sans fil WiFi à la bordure de l'Internet ont connu des failles de sécurité, la nomadicité des usagers et la portabilité des terminaux (téléphone mobile avec carte SIM, agenda électronique) ont suscité des vols et déclenché des fraudes et des abus. Notre société de l'information est ainsi devenue complexe et fragile. Il s'établit de fréquentes interdépendances entre les différents systèmes d'information et de communication et les nombreux domaines d'activités : administration, banque, énergie, transport, santé et défense.

Deux tendances inquiétantes doivent faire l'objet d'un éclairage spécifique :

- Monochromie : la société de l'information converge vers un monde plus interconnecté et uniformisé, suite au nivellement de la technologie par les standards du marché. En informatique et communication, l'étanchéité et l'hétérogénéité des systèmes propriétaires jouent de moins en moins leur rôle protecteur. Ce monde décloisonné et monochrome favorise la vulnérabilité à toutes sortes d'agressions fortuites ou préméditées, parfois

propagées en cascade par les infrastructures qui fonctionnent de plus en plus en interdépendance.

- Flux tendus : l'évolution à venir imbriquera changements techniques, comportementaux et organisationnels et même psychologiques comme en témoigne notre addiction grandissante aux technologies des communications.

Les entreprises sont dites agiles, avec des cycles de décision à boucle de réaction courte et des cycles d'approvisionnement à flux tendus. Or la sécurité évolue elle-même vers le flux tendu (mise à jour de logiciels, d'antivirus) et son efficacité sera ainsi de plus en plus précaire et confrontée à des menaces croissantes. La sécurité de la reconfigurabilité et de la mise à jour du matériel et du logiciel accueillant les évolutions technologiques, est un défi majeur pour les techniques numériques.

Chapitre 1 : Le domaine de la sécurité

a. Les enjeux

La sécurité comporte des enjeux essentiels d'ordre stratégique puisque, dans le monde contemporain, les individus physiques (mais aussi les robots ou les entités logiques) doivent pouvoir communiquer, l'information doit être accessible sur les réseaux, que l'on soit au bureau, en voyage ou à domicile. Le premier enjeu est de maîtriser le cycle de vie, le transport, le traitement et le stockage des patrimoines numériques. Le patrimoine numérique peut être personnel, industriel, intellectuel ou culturel. Il s'agit d'un enjeu politique de souveraineté pour enrayer la régence des contenus intangibles dans le cadre de la mondialisation.

La technique maîtresse est ici la cryptographie, avec son cortège de protocoles cryptographiques utilisés à travers les réseaux. Le deuxième enjeu est de valoriser les contenus immatériels afin d'assurer la libre circulation des contenus en toute confiance et de disséminer les œuvres, de rétribuer les auteurs et d'essaimer le savoir-faire. Il s'agit d'un enjeu économique.

Les techniques font ici appel à la cryptographie mais aussi au tatouage électronique ou à la stéganographie, afin de dissimuler des détails secrets dans le corps même des œuvres, décelables exclusivement par leurs auteurs et les ayants-droit et de garantir ainsi leur propriété. Le troisième enjeu est d'instaurer ou de restaurer la confiance dans l'univers numérique pour intensifier le commerce électronique, les échanges immatériels, l'administration électronique, voire la république numérique. Il s'agit d'un enjeu social pour faciliter l'usage des nouvelles technologies et lutter contre la fracture numérique. Les techniques sont encore la cryptographie, mais aussi la sociologie de la confiance, car les usages, et notamment l'idée que l'on se fait de l'assurance de sécurité, ont ici un impact fort.

Les infrastructures de confiance vont consister à administrer le cycle de vie de certificats, véritables cartes d'identité électroniques des interlocuteurs afin d'authentifier leurs échanges.

Le quatrième enjeu est de sécuriser les infosphères, c'est-à-dire la sphère privée immatérielle, ou bien le nuage de données, de programmes et de connexions appartenant à un sujet, selon les trois granularités suivantes : l'infosphère de l'individu pour protéger sa liberté et préserver son intimité. Parmi la palette des

techniques utilisées, la biométrie va permettre d'identifier les individus physiques, responsables des actions informatiques. Les personnes physiques se déplacent désormais avec un attirail électronique qui les assujettit à une traçabilité à leur insu. Le téléphone portable ou la carte bancaire peuvent être utilisés comme des instruments de filature électronique. Les enregistrements de factures détaillées, les agendas électroniques livrent des indications qui peuvent porter atteinte à la vie privée.

L'infosphère des organisations pour prévenir les attaques contre les biens ou l'image de marque de la personne morale, et pour lutter contre l'espionnage, le renseignement informatique. L'ouverture des systèmes d'information vers l'extérieur constitue un défi stratégique pour les entreprises. La sécurité de leur système d'information est donc devenue un élément crucial de la protection des actifs de l'entreprise. C'est ici que toute l'ingénierie des réseaux intervient. Des architectures de sécurité vont être mises en place afin de protéger la confidentialité des informations sensibles, de sécuriser l'intégrité des systèmes d'information (SI) et d'assurer la disponibilité des réseaux.

On va installer des produits de sécurité aux endroits stratégiques du SI de l'entreprise : pare-feu à la frontière du SI pour filtrer les accès entrant et sortant, pots de miel dans une zone démilitarisée où est érigé le site Web, chiffreur IP à la lisière d'Internet, pour franchir, en toute confiance, le no man's land que sont les réseaux publics, système de détection d'intrusion au cœur du SI pour vérifier l'état du réseau et pour établir des lignes de défense en profondeur.

L'infosphère de l'État dans l'objectif de réduire les vulnérabilités des infrastructures critiques avec leurs interdépendances (catastrophes à effet domino) et de traquer la cybercriminalité lourde. Comme il n'existe pas de sécurité à 100% ou de construction à zéro défaut, le dernier enjeu est de gérer rapidement et efficacement les crises quand elles se déroulent, sans s'engouffrer inexorablement dans un engrenage vicieux de surenchères entre l'armure et la cuirasse, mais plutôt en tentant de surmonter le syndrome sécuritaire voire paranoïaque, qui guette souvent dès que l'on veut protéger le monde virtuel. Les techniques font appel aux modèles dynamiques de politique de sécurité, aux méthodologies de gestion de crises (par escalades et paliers), aux modèles de confiance, aux méthodes d'auto-cicatrisation et à la théorie des jeux.

b. La typologie des réseaux et des systèmes

Le monde numérique des réseaux et des systèmes comprend :

- les réseaux informatiques : les réseaux locaux d'entreprises, les réseaux de vidéosurveillance sur IP, Internet, les réseaux sans fil (WiMax, WiFi, Bluetooth), les réseaux passifs d'étiquettes intelligentes (RFId) ;

- les réseaux de télécoms : les réseaux satellites, les réseaux de localisation GPS ou Galiléo, les réseaux téléphoniques, les réseaux d'opérateurs de téléphonie mobile (GSM, GPRS, EDGE, UMTS) ;

- les réseaux de diffusion de télévision (TNT, câble) et de radio mais aussi les réseaux résultant de la numérisation de la totalité du processus de production audiovisuelle, et ceux qui émergeront du déploiement des salles de cinéma numérique ;

- les SI de l'État, des institutions, des entreprises, des banques, des organisations, des réseaux à domicile (réseau domestique), de gestion des infrastructures critiques et du patrimoine numérique naissant des familles et des individus.

c. Le périmètre et la segmentation

Sécuriser un système impose de maîtriser son cycle de vie et son utilisation à bon escient, de contrôler son fonctionnement, de pérenniser son évolution et consiste à s'assurer que les ressources matérielles et logicielles ainsi que les informations d'une personne ou d'une organisation sont strictement utilisées dans le cadre général qui est prévu. La sécurité est une propriété qui contribue à l'intégrité d'un système dans son acception la plus large.

Elle permet d'empêcher la conjoncture d'événements accidentels (perte de données, pannes de serveurs) ou intentionnels (messages parasites, saturations intempestives des ressources) qui le perturberaient. Ces périls d'occurrences aléatoires ou ces menaces issues d'une volonté malveillante, peuvent ou veulent porter atteinte à son domaine privé ou à ses secrets, altérer tout ou partie de ses organes, corrompre son environnement ou bien empêcher ou ralentir son fonctionnement habituel.

La sécurité englobe la sécurité des systèmes d'exploitation (OS), des logiciels, des communications interpersonnelles, de la messagerie, des données elles-mêmes, du partage des connaissances et de la propriété intellectuelle. La sécurité de l'informatique et des télécoms conjugue la liberté et la volonté de protéger les valeurs matérielles ou intangibles et leur image de marque, avec la correction des logiciels, la robustesse des architectures, l'immunité des applications, la résilience des systèmes, l'instillation et le maintien de la confiance dans les édifices numériques. L'importance croissante des liens hertziens, particulièrement sensibles, vient renforcer et compliquer cette priorité de sécurité.

Livre Uploader par www.bookys-gratuit.com

La sécurité se décompose en plusieurs volets :

- la sécurité physique (l'innocuité) des lieux, des personnes et des biens, des infrastructures et des ressources matérielles, relative à des accidents (dégâts des eaux, sinistres) ou des sabotages ;

la sécurité logique, la sûreté de fonctionnement, la fiabilité des systèmes embarqués, relative à la bonne marche, à la robustesse ou à la survie d'un système, suite à des dysfonctionnements internes ou externes ou des perturbations accidentelles ou intentionnelles de l'environnement.

La sécurité (qui inclut aussi la correction et la conformité des logiciels) des applications et des données rentrent dans ce contexte ;

la sécurité des infrastructures, des systèmes de télécommunication, des réseaux et des systèmes répartis, utilisant une informatique prépondérante en réseau, relative à la perturbation par des attaques ou des propagations d'erreurs via le réseau ;

la sécurité des SI de nature personnelle, technique, bureautique ou administrative, relative à la divulgation d'informations confidentielles ou à la corruption de base de données.

La sécurité moderne se concentre donc sur l'intimité numérique (privacy) des personnes, sur la protection du patrimoine et des idées (Intellectual Property Rights), sur la distribution des contenus en lignes tout en gérant les droits d'auteurs et de marques déposées (Digital Rights Management), sur la sécurité classique des réseaux et des SI et sur la protection des grandes infrastructures. Il s'agit techniquement de cryptographie, de stéganographie, de biométrie, mais aussi d'ingénierie de sécurité dans les architectures et les protocoles de réseau. En outre, le facteur humain est essentiel en sécurité.

La pédagogie vers une responsabilité proportionnée de tous les acteurs de la chaîne de confiance, la formation à l'administration vigilante des systèmes et des applications ainsi que la sensibilisation volontariste de tous les utilisateurs sont les critères primordiaux de la réussite d'une démarche de sécurité dans une structure. Enfin, la sociologie de la confiance, les aspects réglementaires, juridiques et éthiques ne doivent pas être sous-estimés.

Chapitre 2 : Les concepts et la démarche de la sécurité

La démarche traditionnelle de la sécurité consiste à cloisonner les ressources (réseaux et serveurs) et les informations (programmes et données) en fonction de leur sensibilité et de leur domaine d'application, dans le respect de la réglementation.

a. Les objectifs de la sécurité

La sécurité numérique brigue trois objectifs : la confidentialité, l'intégrité et la disponibilité des ressources et des informations des réseaux et des systèmes :

- La confidentialité, vise à assurer que seuls les sujets (les personnes, les machines ou les logiciels) autorisés aient accès aux ressources et aux informations auxquelles ils ont droit.

- La confidentialité a pour objectif d'empêcher que des informations secrètes soient divulguées à des sujets non autorisés. L'objectif des attaques sur la confidentialité est d'extorquer des informations ; l'intégrité vise à assurer que les ressources et les informations ne soient pas corrompues, altérées ou détruites par des sujets non autorisés. L'objectif des attaques sur l'intégrité est de changer, d'ajouter ou de supprimer des informations ou des ressources ;

- La disponibilité vise à assurer que le système soit bien prêt à l'emploi, que les ressources et les informations soient en quelque sorte consommables, que les ressources ne soient pas saturées, que les informations, les services soient accessibles et que l'accès au système par des sujets non autorisés soit prohibé. L'objectif des attaques sur la disponibilité est de rendre le système inexploitable ou inutilisable. La cryptologie permet de remplir largement les deux premiers objectifs en confidentialité et en intégrité. Malheureusement, il n'existe pas de modèles pour parvenir entièrement à la finalité de disponibilité.

b. La politique de sécurité

Pour atteindre ces objectifs de sécurité, il est nécessaire de mettre en œuvre une politique de sécurité, applicable à l'ensemble des entités à l'intérieur d'un domaine géographique ou fonctionnel. Cette politique désigne l'ensemble des lois et des consignes aux fins de protéger les ressources et les informations contre tout préjudice à leur confidentialité, leur intégrité et leur disponibilité, lequel serait dû à un usage inapproprié (incorrect, abusif ou frauduleux).

La politique exhibe, dans sa rédaction sous forme de règles, des sujets et des objets et précise les activités et opérations autorisées et interdites. Pour ce qui concerne la sécurité logique, il est essentiel de connaître la part de la politique de sécurité, traitée informatiquement et dévolue intrinsèquement au réseau et au système. Le reste de la politique sera pris en charge par des mesures non techniques, organisationnelles ou juridiques.

c. Les fonctions de sécurité

La politique de sécurité utilise un catalogue de fonctions de sécurité, parmi lesquelles on peut trouver :

- l'identification des sujets, des objets et des opérations effectuées par ces sujets sur ces objets. Il s'agit de donner un nom à une personne, à une carte graphique, à un document, à un paquet IP. Un sujet qui n'a pas de nom est anonyme. Dans ce cas, le sujet ne peut être tenu responsable d'une action fautive. Un sujet peut avoir un pseudonyme (un alias) : il cache alors son vrai nom, mais reste responsable des actions qu'il pourrait exécuter sous son faux nom ;

- l'authentification, c'est-à-dire la preuve de l'identité de ces entités ou de ces opérations. Il s'agit d'un processus incorruptible pour garantir que le sujet est bien celui qu'il prétend être, pour garantir que l'objet est bien celui que l'entité responsable nomme ou bien que l'opération est bien celle qu'elle doit être ;

- l'intimité numérique est une fonction qui consiste à abriter l'identité d'une entité et ses activités, en masquant son observation et en rendant impraticable le croisement d'informations (statut d'un sujet, état d'un objet) sporadiques et disparates.

Une manière de satisfaire cette intimité est de rester anonyme, mais un anonymat sévère peut à son tour devenir un danger pour autrui, se traduire par une irresponsabilité des actes et affaiblir la sécurité de l'ensemble du système ;

- La traçabilité, c'est-à-dire une fonction qui consiste à repérer l'histoire des entités (ou des fractions d'entités) et leur cinématique dans un monde mobile. La traçabilité peut localiser par intermittence la position d'un sujet ou d'un objet, peut dater des transactions, peut noter des renseignements sur des situations, le tout avec des attributs de sécurité. Cette fonction s'avère irremplaçable pour contrôler un objet, pour pister un suspect ou pour reconstituer un scénario lors d'une enquête ou d'une perquisition informatique ;

- l’audit du système, c’est-à-dire l’observation, l’enregistrement, l’analyse et la compréhension des événements importants ou anormaux qui vont concourir à reconstituer le fil de son histoire, après la constatation d’une panne ou d’une attaque. Dans la pratique, on enregistre, dans les différents dispositifs de sécurité, des journaux infalsifiables qui seront des témoins de confiance chargés d’interpréter la trame des opérations et d’imputer la responsabilité d’une erreur ou d’un acte malveillant à son initiateur. Cette fonction d’audit, témoin de la mémoire du système, est déterminante dans un système. Le cybercriminel s’efforce de dissimuler les traces de son passage en tentant de détériorer ces fichiers d’audit. L’auditabilité est une fonction qui consiste à pouvoir récupérer des preuves numériques incontestables, en cas de perquisition des données ou d’examen ultérieur des activités ;

- l’imputabilité des actions d’un sujet sur des objets, en relation avec sa responsabilité.

Par exemple, la non-répudiation est une fonction qui permet de garantir qu’une communication ou une transaction ne peut être niée, ni à l’émission, ni à la destination par ses responsables ;

- L’autorisation des actions par un sujet sur des objets. Les droits spécifiques et les privilèges des sujets sont définis par cette fonction ;

- Le contrôle d’accès, c’est-à-dire la restriction d’accès aux ressources et aux informations, aux seuls sujets qui sont autorisés. Il s’agit, par exemple, de filtrer les flux entrant et sortant dans un périmètre selon des règles définies ;

- La protection des contenus, c’est-à-dire ici la confidentialité et l’intégrité des informations des utilisateurs. Il s’agit de cacher la signification des informations aux sujets non autorisés, en utilisant des primitives cryptographiques. La protection des contenus, dans le domaine du multimédia, signifie plutôt la disponibilité et le contrôle d’usage des informations. Il s’agit alors de contrôler et de restreindre l’usage des contenus aux seuls sujets autorisés par

tatouage, sans nécessairement cacher ces informations pour des exécutions de logiciels, ou des lectures de documents audiovisuels ;

- La gestion de la sécurité, c’est-à-dire la gestion du cycle de vie de toutes les fonctions précédentes, essentiellement la configuration et la protection de ces fonctions de sécurité. L’objectif de la gestion de la sécurité est d’établir et de maintenir un état de sécurité conforme à la politique en vigueur.

d. La mise en vigueur de la sécurité

> Au commencement, il faut définir un état de sécurité pour les services de sécurité et leur gestion. Celui qui procure la sécurité doit être de confiance. La sécurité exige une permanence des prescriptions : celles-ci ne doivent pas changer sans cesse et les états de confiance doivent se maintenir beaucoup plus longtemps que leurs transitions. Dans les règles de cette politique, il est capital d'octroyer une priorité aux opérations de configuration de la sécurité.

Pour mettre en place la politique de sécurité, il faut déployer toute la panoplie des fonctions de sécurité qui permettront de résister aux menaces potentielles. Les personnes, les entreprises et les États implémentent de nos jours des solutions compétitives relatives à ces fonctions :

- l'identité d'une personne, d'une application, d'un document, d'un réseau, d'une entité informatique ; depuis les événements du 11 septembre 2001, une compétition rude est en cours pour gagner les standards de l'identification physique, biométrique de chaque individu

- la preuve de l'identité (l'authentification) par l'authenticité d'un titre, d'une étiquette, d'un tatouage par signature numérique ;

- l'audit des faits, l'imputabilité, l'enregistrement de l'histoire du système à partir de capteurs et de sondes, la traçabilité des mouvements des divers sujets et des objets ;

- la preuve d'une communication (non-répudiation), d'un consentement avec des signatures numériques de toutes sortes ;

- la protection du transport, du traitement, du stockage et de l'archivage de documents ou de bases de données, et la sécurité de transactions et d'actes, le tout par chiffrement cryptographique ;

- la gestion des droits et des devoirs des propriétaires, des auteurs, des distributeurs, des abonnés : protection contre le piratage, la modification, le plagiat, la rediffusion ;

- la restriction d’accès, les autorisations en accord avec des politiques de sécurité, variables avec le temps, l’espace et le contexte ;

- l’intégrité d’un document, preuve de sa non-manipulation, par signature numérique ;

- la gestion de la sécurité : administration des outils et dispositifs de sécurité, évaluation globale du niveau d’assurance de sécurité. Afin de simplifier cette administration de la sécurité, les entreprises ont tendance à regrouper au sein d’un centre de gestion centralisée de la sécurité, les fonctions critiques (cellule de crise, système de secours). Cet organe vital devra à son tour être protégé.

Chapitre 3 : Les menaces et les vulnérabilités

Les risques potentiels sur le fonctionnement conforme des réseaux, des systèmes et des infrastructures sont de types variés qui vont de la panne ordinaire à la malveillance technique en passant par la maladresse humaine. La construction effrénée du cyberespace ne s'élabore pas sans essais et erreurs, sans conséquences néfastes qu'il faut affronter et, pour le moins, restreindre. L'origine des menaces émane avant tout de l'idéologie ambiante « il est interdit d'interdire » de la Toile, qui suscite l'apparition d'effets nuisibles ou pervers, amplifiés par la résonance de la taille du réseau.

Les menaces sont incarnées pêle-mêle par l'irruption de sites qui hébergent des serveurs suspects, par l'encombrement des réseaux sous forme de contenus illicites ou de messages non sollicités, par la pollution des messageries, la propagation de virus, le téléchargement illégal de fichiers audio et vidéo, la circulation de fausses informations et par l'intrusion d'informations cachées ou de logiciels malveillants. Enfin le réseau favorise la création de nids pour des implantations de sectes, de mafias ou bien de refuges pour les réseaux de cybercriminels, voire de cyber-terroristes. L'impact de ces agressions peut être fatal en termes économiques, sociaux ou juridiques.

Les entreprises du secteur de l'audiovisuel et du multimédia cumulent la plupart des problématiques de sécurité précitées, dans le contexte spécifique de ce métier et de ses usages : l'inéluctable dématérialisation des contenus impose non seulement de trouver des parades acceptables aux phénomènes de piratage, mais de garantir leur traçabilité et leur intégration sans couture dans les processus de production, ainsi que leur transparence pour les utilisateurs finaux légitimes.

a. Statistiques sur la sécurité et sur le coût de l'insécurité

Il existe de nos jours 450 000 attaques réussies par mois dans le monde. Cependant la cartographie et le volume de la délinquance dans le cyberespace sont mal connus car la plupart des infractions commises ne sont pas portées à la connaissance des autorités.

De plus, la métrologie des attaques est un domaine de recherche pour mesurer, en toute intelligibilité, avec une toise irrécusable la dangerosité d'un site, d'un système ou d'un réseau et pour jauger ou annoncer une « météorologie des attaques » sur un réseau. On compte environ 250.000 virus en 2016. L'augmentation est d'environ 1000 par mois, mais il n'existe environ que 10 000 virus actifs en permanence. Pendant le pic d'une infection, 10 % des mails de l'Internet sont infectés. En 2016, le spam comprend quelque 40 milliards de messages par jour à l'échelle mondiale. Les fraudes sur les cartes bancaires et sur les téléphones sont finalement plus importantes, car elles se caractérisent par des pertes financières directes, alors que les virus et les spams n'engendrent en général qu'indirectement des coûts financiers qui se comptent toutefois par milliards d'euros par an, à l'échelle mondiale.

On peut estimer le coût des dommages directs de la cybercriminalité dans les entreprises à 1 milliard d'euros par an, mais le coût global de l'insécurité numérique culmine plutôt vers 50 milliards d'euros par an. Le marché mondial de la sécurité des systèmes d'information est de l'ordre de 20 milliards d'euros, mais le marché mondial de la sécurité numérique dans le cadre de la convergence avoisine 80 milliards d'euros.
Les dépenses en sécurité ne doivent pas être calculées sur des critères classiques de modèles financiers avec un retour sur investissement, car la sécurité ne contribue pas directement au chiffre d'affaires. La cyber-assurance a d'ailleurs du mal à trouver son bien-fondé. En règle générale, les dépenses de sécurité sont de l'ordre de 5 % à 10 % du budget correspondant aux technologies numériques.

b. La typologie des attaquants

Les pirates du numérique appartiennent à des catégories très hétéroclites.
Ce sont :

- des cyberterroristes qui exploiteront bientôt le côté virtuel du réseau pour harceler et atteindre des cibles stratégiques, dans l'intention de déstabiliser les États et terroriser les populations ;

- des cybercriminels qui cultivent la dimension de communication du réseau pour gagner de l'argent (vol, extorsion) de manière frauduleuse et pour fertiliser leur propre réseau de diffusion : délinquance, mafia, casinos, blanchiment d'argent, narcotique, contrefaçon, proxénétisme, pédophilie, racisme, sectes en tout genre ;

- des hackers, des cyberpunks : sur un mode ludique, ces amateurs (souvent informaticiens adolescents) se lancent des défis, publient les découvertes de failles de sécurité sur les OS et les protocoles, jouent sur le réseau à déverrouiller des accès, transgressant la législation à leurs risques et périls ;

- des organisations privées ou gouvernementales qui commanditent des interventions peu recommandables ou délictueuses : intelligence économique sur Internet, surveillance, écoutes, interceptions, infractions envers des concurrents ;

- des utilisateurs standard qui ont des pratiques illégales comme le téléchargement de fichiers musicaux ou l'utilisation illégale de logiciels.

Sur le plan juridique, la délinquance et la cybercriminalité englobent les infractions liées aux technologies numériques et celles dont la commission est facilitée ou liée à l'utilisation de ces technologies.

c. Les attaques traditionnelles

Toute stratégie d'intrusion est construite autour de l'exploitation des vulnérabilités de l'application concrète de la politique de sécurité d'un système par ses utilisateurs. La méthode pour organiser des attaques informatiques est donc d'exploiter systématiquement la mise en échec de la politique de sécurité en vigueur (expression prise ici au sens très large du terme), c'est-à-dire d'exploiter les failles dans l'état de confiance et dans la gestion de la sécurité. En matière d'attaque, il existe deux phases capitales :

- l'accès au système ou au réseau de communication (par le renseignement, par des essais et erreurs) qui peut demander beaucoup de temps et de ressources, l'apparition des réseaux radio facilitant cette phase ;

- une fois la pénétration réalisée, il convient de naviguer discrètement (ou pas) dans le système pour toucher les zones sensibles du système.

Les moyens mis en œuvre vont dépendre :

- de la connaissance a priori de la cible attaquée, allant d'une connaissance nulle exigeant des attaques aveugles jusqu'à une connaissance idéale soulageant les prospections, suite à une compromission de l'ingénieur responsable du système, en passant par une connaissance moyenne, suite à une phase de renseignement informatique ;

- de la volonté de la détectabilité de l'attaque : volonté d'être indécelable dans le cas de l'espionnage ou, au contraire, intention de médiatisation de l'agression comme faisant partie de sa réussite dans le cas d'attaques symboliques ;

- du degré de compromission que l'attaquant souhaite avoir avec cette cible : attaque directe par pénétration physique ou compromission avec le personnel de l'entreprise attaquée ou, au contraire, attaque indirecte via la mise à contribution de serveurs informatiques externes, compromis au préalable. Internet, devenu

> un refuge et un support d’attaques, a acquis cette mauvaise réputation de sécurité en éloignant les attaquants de leur cible, hors des frontières nationales.

Un système possède un cycle de vie : conception et développement avant la mise en service, installation, déploiement, exploitation et maintenance pendant son utilisation, puis obsolescence et destruction. L’attaque d’un système peut se préparer pendant la phase de conception et développement, lorsqu’on est fournisseur d’éléments du système, par l’insertion de chevaux de Troie dans l’architecture, de portes dérobées dans les applications.

On peut aussi profiter des défaillances dans la chaîne de distribution des matériels et logiciels en interceptant et en corrompant ces produits. Dans la phase exploitation, c’est au cours des phases de maintenance (matérielle, logicielle, mise à niveau d’un logiciel en flux tendus) que les politiques de sécurité sont mises en péril. En phase de maintenance, des personnes étrangères au système sont amenées à fréquenter des zones sensibles du système. C’est cette vulnérabilité qui peut être exploitée à fond pour avoir accès à un système ou pénétrer un réseau, en provoquant ultérieurement des pannes ou en obligeant le système à être exploité en mode dégradé.

d. Les attaques modernes

Les attaques ont évolué, ces dernières années, tant en volume qu'en nature. Autrefois, les attaques ciblaient toujours un gain tangible. Il faut de nos jours considérer l'éventail des motivations hétéroclites des attaquants : récupérer la connaissance d'une donnée, modifier ou détruire un fichier, ternir l'image de marque d'une entreprise, offenser la notoriété d'une personne, déstabiliser une institution ou un pays. Les attaques devraient encore s'intensifier dans l'avenir.

- Les systèmes numériques peuvent être exploités pour perpétrer à distance des attentats à l'aide de télécommande informatique. Ces agressions vont se sophistiquer ;

- le cœur des réseaux est encore épargné par les attaques.

- Avec la fragmentation du marché et le partage des infrastructures de communication, les modules racines des réseaux seront bientôt vulnérables à des assauts redoutables ;

- Les communications cellulaires sont protégées par leur structure centralisée sous forme d'une gestion par un opérateur de télécoms et par la notion de circuit virtuel encore présente dans le GSM. L'évolution vers des télécoms « informatiques » (voix sur IP, GPRS, UMTS) devrait briser la confiance dans ce secteur : écoutes et dérivations téléphoniques, dénis de services, virus dans les téléphones. Comme Internet, le GSM est victime de son succès qui le rend vulnérable par l'ampleur de son déploiement et de son utilisation, par la multiplication des opérateurs de télécoms qui interviennent dans le trafic international, lesquels se doivent une confiance réciproque, et par l'addiction des usagers pour qui le téléphone mobile est devenu un compagnon inséparable de la vie quotidienne ;

- L'évolution vers la diffusion interactive et numérique d'émissions de télévision devrait aussi venir à bout de la confiance en une télévision passive, en direct du producteur (les grandes chaînes de télévision) au consommateur passif. Les émissions incontrôlées de télévision sont apparues avec la diffusion par satellite et pourraient

se généraliser avec la convergence audiovisuelle. De plus, la vidéosurveillance risque de se banaliser pour enregistrer et contrôler l’activité urbaine. Elle peut, à son tour, devenir la proie d’attaques insidieuses.

e. Le cyberterrorisme

La mondialisation a modifié les enjeux et de nouvelles formes d'offensives apparaissent. Avec les attentats du 11 septembre 2001, le monde a pris conscience qu’une nouvelle ère dans les formes d’agression pouvait survenir. Les causes profondes des conflits ne prendraient plus racine dans des enjeux territoriaux, ni même dans la convoitise économique, mais l’origine des conflits futurs serait plutôt dans la contestation des systèmes de valeurs. Les guerres « symboliques » utilisant les technologies numériques, conduites par des petits groupes motivés, dotés de peu de ressources, prendraient une dimension inédite.

f. Les atteintes à la liberté individuelle : la filature électronique

Dans le monde numérique, il existe des menaces réelles contre la sphère privée de la personne, physique et morale, créées par les traces numériques laissées par chacun d'entre nous, suite à une navigation dans le monde virtuel. Des filatures électroniques sont fatalement réalisables, suite au repérage continu par GPS, suite à la localisation permanente enregistrée par un téléphone portable chez l'opérateur de télécoms, suite aux dépenses inscrites sur la carte bancaire dans les divers magasins, suite aux multiples photographies mémorisées par les caméras citadines. Les recoupements avec les sites Web visités, les numéros de téléphones joints, les citations détectées sur les moteurs de recherche, tout concourt à confectionner une glu qui emprisonne chaque individu dans sa vie quotidienne.

De nos jours, tout citoyen est enregistré sur environ cinq cents fichiers, tout individu circulant dans les grandes villes est filmé une dizaine, voire une centaine de fois par jour par des entités publiques ou privées et tous les utilisateurs d'un téléphone portable sont pistés dans d'immenses fichiers. Ces enregistrements d'itinéraires électroniques ont des utilisations indirectes justifiées pour repérer efficacement des terroristes ou des criminels, mais pourraient être détournées pour connaître les activités intimes des personnes : dates et heures du téléphone portable allumé et éteint, position dans les cellules des réseaux, circulation à travers les cellules. Les menaces d'inquisition numérique doivent être réduites par un encadrement strict de l'utilisation des fichiers nominaux ainsi que des registres de traçabilité des personnes ou des biens (objets communicants, voitures) qui les accompagnent.

g. Les vulnérabilités des systèmes

Les vulnérabilités d'un système dépendent de nombreux facteurs. Les critères primordiaux sont la complexité du système, sa répartition, sa sensibilité et sa mobilité. La complexité dépend elle-même de multiples éléments :

- les ontologies (c'est-à-dire les entités informatiques en tant que telles) qui composent le système et leur structuration ;
- l'hétérogénéité du système.
- Le pluralisme des technologies présentes, la diversité des acteurs, des entités et des actions sur le système sont des facteurs de complication qui créent des erreurs de conformité, mais aussi des facteurs de cloisonnement qui jouent un rôle d'étanchéité dans la propagation des attaques ;
- la taille du système, c'est-à-dire le cardinal des diverses ontologies qui composent ce système ;
- les architectures, c'est-à-dire les composants et les liens entre ces composants, avec leurs articulations aux différentes échelles de temps, d'espace et de géométrie de ce système ;
- la virtualité des abstractions qui sont mises en jeu. La complexité des systèmes augmente avec le degré d'abstraction des paradigmes qui sont utilisés pour concevoir le système.

D'une manière schématique, les attaques sur les réseaux filaires vont se situer plutôt dans les couches hautes du modèle OSI de référence, alors que les attaques sur les réseaux sans fil vont se situer plutôt dans les couches basses. En effet, les vulnérabilités des réseaux filaires (Internet sur fibre optique ou sur cuivre, réseaux locaux sur fibre ou sur câble) sont plus dans les protocoles de couches hautes, les intergiciels, les applications et les contenus.

Au contraire, les vulnérabilités des réseaux sans fil vont plutôt résider dans la couche physique et provoquer des attaques par des brouillages possibles de la transmission et dans la couche de liaison de données, par des tentatives intempestives à l'accès de la communication.

h. Les défaillances dans la conception et la fabrication des systèmes

La fragilité du monde numérique provient intrinsèquement de l'insuffisante maîtrise des infrastructures informatiques par les concepteurs (fabricants, distributeurs, équipementiers et systémiers) et par leur absence de transparence pour les usagers (utilisateurs des entreprises et utilisateurs personnels, managers et ingénieurs).

Les raisons sont théoriques, pratiques, économiques et sociologiques. Une surenchère dans l'accélération des techniques ne favorise pas un déploiement mature des solutions. L'ingénieur concepteur de système et de service est devenu un architecte qui ne maîtrise plus ses composants ; dès lors la sécurité des infrastructures est édifiée sur des sables mouvants.

L'intégration des composants s'opère plus avec des obligations de délai et des objectifs de coût, que des enjeux de sécurité pour l'exploitant et l'utilisateur. Les préoccupations sont plus dans le respect de l'interopérabilité et l'interfonctionnement que dans la sécurité et la sûreté de fonctionnement. L'informatique est une industrie où la latitude envers les écarts de conformité aux spécifications et aux services attendus a toujours été surprenante :

- Tolérance aux bugs : les utilisateurs acceptent d'acheter des logiciels avec des erreurs sans protester. Ils admettent d'acheter plusieurs fois les nouvelles versions des programmes. La notion de « copyright » vient d'ailleurs de cette incapacité à produire des logiciels sans erreurs. Pour éviter les poursuites judiciaires, on a décrété que le logiciel était une œuvre d'art plutôt qu'une marchandise qui rendait un service spécifié ;

- Tolérance aux spams (courriers électroniques non sollicités), aux virus : les Internautes consentent à équiper leurs ordinateurs de logiciels antivirus, lesquels vampirisent les ressources de calcul. Les logiciels d'antivirus sont en tête des ventes de logiciels. On peut s'en réjouir car ce palmarès montre la sensibilisation des utilisateurs. On peut aussi s'en désoler quand on considère le problème dans sa globalité. La gouvernance numérique de la communauté internationale devra tôt ou tard prendre en compte sérieusement cette question de l'économie de la sécurité numérique

au niveau de la planète.

i. Le maillon faible : l’intervention humaine

Les réseaux et les SI sont sous la responsabilité d’entités physiques ou morales. Ils sont toujours actionnés par un individu. Cet individu est pleinement responsable de ses actes et de ses conséquences. Il constitue toujours le maillon faible dans les systèmes numériques. Il va se tromper de manière involontaire, provoquer des effacements de fichiers, des dérèglements dans le fonctionnement normal d’un système. Il peut agir de manière intentionnelle et tenter de pénétrer dans un réseau, dans un ordinateur, dans un SI, pour percer les secrets d’une institution, d’une organisation, pour modifier la configuration du parc de machines, de logiciels ou des données, pour utiliser les ressources illégalement, ou pour empêcher les personnes autorisées à les utiliser.

Chapitre 4 : Les principes de la sécurité numérique

La sécurité numérique, c'est l'art de partager un secret. Ce secret est dissimulé dans un coffre-fort (mémoire d'un individu ou de carte à puce, tiers de confiance). Quand ces secrets sont numériques (clés transitant sur un réseau), ils sont chiffrés, ce qui nécessite encore un autre secret, et ainsi de suite. Si tout était numérique, il ne subsisterait que des secrets de polichinelle.

Les entités de confiance sur un réseau sont là pour amorcer la pompe de la confiance, en se prolongeant par capillarité dans les méandres des réseaux et des systèmes, via des protocoles cryptographiques implantant ces secrets, spatialement et temporellement.

a. Les modèles opérationnels

Livre Uploader par www.bookys-gratuit.com

Un système en état de sécurité est un système « tranquille » qui peut fonctionner et vaquer à son occupation réelle, sans se soucier de sa mise en danger dans son propre cycle de vie. Pour sécuriser un système :

- On peut le plonger dans un bain de totale confiance, auquel cas des dispositifs de protection sont superflus. C'est l'organisation qui prend alors en charge les effractions potentielles et les fautes des utilisateurs légitimes ;

- on peut le protéger, avec des dispositifs de défense, mais ce n'est pas le seul modèle de sécurité ;

- on peut, ne pas le protéger, mais dissuader les assaillants potentiels ;

- on peut désinformer ou leurrer les adversaires.

Pour éviter le piratage des œuvres sur Internet, le propriétaire des œuvres peut mettre en place un serveur de distribution pirate pour repérer les gens qui viennent s'abreuver à sa source. Pour ralentir les éventuelles écoutes indiscrètes sur un réseau, on engendre de faux messages correspondant à de nombreux leurres, ce qui a pour effet de camoufler dans la pluralité le vrai message. Les pots de miel, décrits ci-dessous, sont aussi des exemples de leurres.

Quand on sécurise un système, il faut apprécier la situation dans laquelle on se place : contexte hostile où les attaques sont régulières, contexte défavorable où il faut être vigilant, contexte neutre où il convient d'être prudent, contexte clément où la confiance est de mise, où il est inutile de se protéger des attaques et où il faut simplement se prémunir d'erreurs humaines toujours possibles. Quand on sécurise un système, il est rentable de se servir de son architecture informatique. Mais il est aussi intéressant de s'appuyer sur sa composition.

Les solutions techniques de sécurité doivent se répartir de manière harmonieuse et efficace dans le contenu des données, dans le cœur des réseaux, dans les serveurs des opérateurs, des fournisseurs d’accès et de services, et dans les entités54 informatiques des utilisateurs.

b. La dualité de l'intimité numérique et de la sécurité collective : la dignité numérique

En sécurité, il existe toujours deux angles de vue : le point de vue de l'utilisateur qui veut se protéger du réseau (c'est la perspective de l'intimité numérique avec une exigence de préservation de la liberté individuelle) et le point de vue du réseau ou de la société qui veut se prémunir de l'utilisateur malveillant ou imprudent (c'est la perspective de la sécurité ambiante avec une exigence de défense de la collectivité).

Pour protéger ses objets intangibles, un propriétaire va les dupliquer et stocker une copie dans un endroit sûr. Pour les transporter et protéger leur contenu sémantique et esthétique, il va brouiller, selon un code secret, le contenu de l'information et/ou son formatage. Pour protéger l'intégrité de son infosphère :

- il va encapsuler le contenu dans une enveloppe intangible sécurisée ;
- il va souder et coupler le message formaté avec une signature électronique, laquelle dépend secrètement du texte intégral formaté, signature que pourra vérifier un partenaire ;
- il va tagguer le message ou estampiller ses transactions avec horodatage pour en authentifier l'heure et la date ;
- il va incruster de façon secrète et répartir de manière continue dans tout le message, une marque invisible, indélébile et éventuellement indécelable pour marquer de sa griffe, qu'il est bien l'auteur ou le propriétaire de ce message.

Pour se protéger en tant que sujet, un être informatique (un programme informatique ou un dispositif) doit être discret, surveiller son territoire (les ressources qu'il utilise) ; il doit filtrer les accès aux frontières, guetter ses voisins, en les discernant ou au moins en les traçant. Pour se protéger des objets des autres, le propriétaire va filtrer les objets (suivant leur nom, leur contenu, leur syntaxe) et inspecter les actions des sujets qui les commandent. Il va contrôler les mouvements à la frontière et dans son environnement pour repérer les événements anormaux.

On conçoit ainsi la compétition subtile et assidue qui se joue entre, d'une part les méthodes qui préservent l'intimité d'un sujet et les procédures légales pour observer ce sujet, et d'autre part les pratiques qui immunisent le reste du monde des exactions et bévues potentielles de ce sujet, et les recours indispensables du sujet afin d'accéder à la connaissance des moyens mis en œuvre pour le contrôler. L'instauration d'un climat de respect et de confiance n'entrave pas la mise en place de procédures croisées de défenses réciproques. Une dialectique transparente doit permettre de négocier les règles et de souscrire à des politiques de sécurité, claires et harmonieuses. La valeur démocratique de notre civilisation est au prix de cette dignité numérique.

c. La confiance en la sécurité offerte : la souveraineté numérique

Il est essentiel que l'utilisateur final, conservant son libre arbitre, ne puisse être l'otage de solutions obligatoires secrètes de sécurité dont il n'aurait ni l'information sur la présence, ni le contrôle sur la marche et l'arrêt. Il faut offrir à l'utilisateur une sécurité concrète, vérifiable ou vérifiée et certifiée par une entité garante, digne de confiance (comme l'État) de façon qu'il garde confiance dans l'arsenal des outils de sécurité proposés. Il faut donc insister sur la garantie, la certification ou la qualification effectuée par une entité de confiance disposant d'experts. Il ne faut pas confondre la véritable sécurité informatique et l'illusion de sécurité.

Pour éviter cette méprise, il suffit de donner, à l'utilisateur final, la possibilité de connaître les défenses et les protections mises en place. Si la sécurité, dite dans l'obscurité, s'abrite sous l'égide d'une boîte noire, il est non seulement impossible d'analyser les faiblesses et les vulnérabilités résiduelles, et donc de faire confiance au dispositif, mais il est impossible d'intervenir en cas d'attaques. Les spécifications de sécurité mises en place ne peuvent être donc un secret absolu de fabrication. Le fournisseur de solutions de sécurité, à l'ambition parfois hégémonique, ne doit pas établir un rapport de force intolérable entre lui et l'utilisateur en sorte que ce dernier devienne esclave, lui abandonnant ainsi toute sa confiance.

Au bas mot, un tiers de confiance, habilité par les deux protagonistes, devrait être capable d'apprécier les mesures techniques et de valider la réelle sécurité mise en vigueur. Mais les techniques, opérationnelles pour la sécurité des biens et des personnes dans les secteurs du transport ou de la santé ne sont pas du tout ébauchées ni transposées pour la sécurité logique dans le secteur de l'informatique.

d. Les méthodologies d’évaluation

Les critères communs (CC) sont une méthodologie pour l’évaluation des propriétés de sécurité des produits et systèmes numériques. Les CC permettent un étalonnage des résultats d’évaluations de sécurité menées indépendamment les unes des autres. Cette comparaison est rendue possible grâce à un ensemble d’exigences pour les fonctions de sécurité des produits et systèmes et pour les mesures d’assurance qui leur sont appliquées.

Le processus d’évaluation établit un niveau de confiance, s’échelonnant de 1 à 7, par le fait que les fonctions de sécurité de tels produits et systèmes et les mesures d’assurance qui leur sont appliquées satisfont à ces exigences. La norme ISO 17799 constitue un guide de bonnes pratiques pour la gestion de la sécurité, avec une centaine de recommandations d’ordre organisationnel et technique.

Chapitre 5 : Les outils cryptographiques de sécurité

La cryptographie demeure la technique indispensable pour, d'une part, protéger la confidentialité des informations transmises sur les réseaux ou stockées dans les serveurs de données et pour, d'autre part, assurer l'intégrité d'un document ou pour prouver l'authenticité d'une opération ou d'une transaction. Elle applique des concepts mathématiques et met en place des paradigmes informatiques afin de résister aux attaques potentielles d'assaillants ou de prouver, de manière quasi sûre, qu'une procédure est incorruptible. La fonction première de la cryptographie est de proposer des algorithmes de chiffrement et de signature électronique. En principe, l'algorithme est normalisé et connu de tous. Le secret ne réside que dans la clé secrète. Ces algorithmes sont installés dans les entités de confiance personnelles (cartes à puces), ou dans des coffres-forts logiciels des serveurs informatiques.

a. Les deux familles d'algorithmes de chiffrement

Il existe deux familles d'algorithmes :

- La cryptographie symétrique, avec les algorithmes DES, 3DES, AES, n'emploie qu'une unique clé pour chiffrer et déchiffrer un message. Il est donc nécessaire de distribuer cette même clé aux deux protagonistes de la communication. Si une personne s'adresse séparément à plusieurs personnes distinctes, elle aura besoin d'autant de clés distinctes. Cette famille d'algorithmes sert à chiffrer en temps réel ou en différé, des documents, des flots d'information, car ces algorithmes sont puissants et nécessitent assez peu de ressources. La taille des clés est faible, par exemple 128 bits.

- La cryptographie asymétrique emploie deux clés différentes : si l'on chiffre avec une clé, il faut déchiffrer avec l'autre. Il existe ainsi deux possibilités d'applications qui servent des objectifs distincts. Dans le cas du système RSA, le système asymétrique le plus utilisé, la taille des clés les plus courantes est 2048 bits.

Notons que les clés sont beaucoup plus longues que dans le cas du chiffrement symétrique. Ceci est dû à la nature arithmétique du système RSA dont la sécurité repose sur la difficulté de factoriser des grands entiers. Or les progrès mathématiques et informatiques dans le domaine de la factorisation imposent maintenant cette taille de clé. Ces algorithmes sont beaucoup plus lents (dans un ordre de 10 à 100) que les algorithmes symétriques. On les réserve donc au chiffrement et déchiffrement des messages courts. Un message court peut justement être une clé d'un algorithme symétrique.

Cryptographie asymétrique et cryptographie symétrique sont donc exploitées de manière complémentaire et successive dans les protocoles cryptographiques pour authentifier l'émetteur, le récepteur, énoncer la non-répudiation des interlocuteurs, et déployer les systèmes de secrets qui vont permettre de communiquer de manière sécurisée.

Les fonctions de hachage

Une fonction de hachage permet de calculer un résumé (une empreinte, un condensé) de taille réduite et fixe (160 bits, par exemple) d'un document

volumineux, écrit au niveau atomique à l'aide de 0 et de 1. Ces fonctions ne sont absolument pas continues, si bien que si le document est un tant soit peu modifié, le résumé sera radicalement transformé. C'est en particulier cette propriété que l'on utilise pour valider l'intégrité d'un transfert de documents ou pour vérifier qu'un fichier n'a pas été corrompu sur un disque d'ordinateur.

L'application classique des outils cryptographiques

Le chiffrement des communications et des fichiers

Pour que deux personnes échangent des documents de manière sécurisée, il suffit que ces deux personnes partagent au préalable un secret (une clé de longueur 128 bits, par exemple) qui va permettre à l'émetteur de broyer le message intelligible en une farine numérique indistincte grâce à un algorithme de cryptographie symétrique. Le récepteur va ensuite déchiffrer le message avec ce même algorithme réversible et cette même clé.

Pour stocker de l'information sur un support physique, la personne qui archive procède de la même façon. Elle chiffre l'information avec une clé et stocke cette information chiffrée. Pour la relire, elle utilise la même clé secrète afin de déchiffrer l'information. Si ces algorithmes sont performants, leur défaut majeur est la gestion lourde des clés dont le nombre croît avec le carré du nombre de partenaires dans le réseau, et ce d'autant plus qu'il convient de changer fréquemment les clés pour empêcher leur compromission.

La double utilisation de la cryptographie asymétrique

La cryptographie asymétrique résout le problème de la distribution initiale des clés secrètes qui doivent être partagées par les interlocuteurs d'une communication, dans le cas de la cryptographie symétrique. Elle attribue à chaque personne un couple d'éléments associés, une clé privée qui doit rester connue de son seul propriétaire, et une autre clé associée, publique qui, au contraire, doit être connue de tous. Munie de ce couple de clés qui sont reliées entre elles par une solidarité mathématique difficile à briser, chaque personne peut ainsi communiquer de manière sécurisée de deux façons.

L'ensemble des partenaires connaissant la clé publique de cette personne ne peut pas découvrir la clé privée car il faudrait, pour percer ce secret, des ressources incommensurables de calcul. Les messages peuvent être chiffrés avec une clé et

déchiffrés avec l’autre qui est différente. On peut ainsi grâce à ce stratagème, communiquer de manière sécurisée, sans partager de secret initial. En chiffrant un message avec sa clé privée, l’émetteur assure aux récepteurs, sa propre authentification.

En chiffrant un message avec la clé publique d’un destinataire, l’émetteur permet, à ce seul récepteur, d’être capable de déchiffrer ce message avec sa clé privée (celle du destinataire), et donc d’assurer la confidentialité du message. Dans la pratique, un émetteur peut ainsi choisir une clé symétrique qui va servir de clé de session pour une communication avec un destinataire, la chiffrer avec sa clé privée asymétrique, rechiffrer le résultat avec la clé publique du récepteur. En envoyant ce message doublement codé, au récepteur, ce dernier pourra seul le déchiffrer avec sa clé privée, puis redéchiffrer avec la clé publique de l’émetteur et recevra ainsi la clé symétrique pour communiquer avec cet émetteur. Des travaux récents portent sur des algorithmes associant une seule clé de chiffrement à plusieurs clés de déchiffrement distinctes, notamment dans le cas de la télévision cryptée.

La clé de chiffrement du diffuseur de la télévision peut être une fonction mathématique de l'ensemble des clés de déchiffrement conservées dans les décodeurs des abonnés de la télévision cryptée. Ainsi, pour désactiver un récepteur, il suffit d’éliminer son secret de la fonction calculant la clé de chiffrement de l’abonné sans pour autant affecter les autres récepteurs. Pour admettre un nouvel élément dans le groupe, il suffit d'ajouter sa clé de chiffrement dans la fonction précitée.

La signature numérique

Une signature numérique est une empreinte (d’un document) chiffrée par la clé privée de l’auteur, cette empreinte chiffrée étant jointe au document originel. La signature permet ainsi de vérifier l’intégrité du document et l’identité de l’expéditeur. On signe un document via des fonctions de hachage.

b. Les infrastructures de confiance

La difficulté de la cryptographie asymétrique provient de l'authenticité non établie de la clé publique d'un interlocuteur. N'importe qui peut, à présent, engendrer un couple de clés privée-publique en récupérant un algorithme sur Internet. Aussi, lorsqu'une personne publie son nom et sa clé publique associée, un pirate peut se glisser sous cet affichage et usurper la clé, en proposant sa propre clé publique. De cette façon, le pirate pourra décoder avec sa propre clé privée les messages à destination de l'interlocuteur véridique, quitte à restituer les messages chiffrés à l'interlocuteur de départ avec la clé publique originelle. C'est ce qu'on appelle une attaque par l'homme au milieu.

Les autorités de confiance

Pour éviter cette méprise, la solution consiste à s'en remettre à un tiers, en faisant signer la clé publique par une autorité digne de confiance, qui va ainsi garantir que la clé publique appartient bien au bon interlocuteur. On va donc signer numériquement le couple composé du nom du propriétaire de la clé publique et de la clé publique. La clé privée de l'autorité va donc signer ce couple de manière que la clé publique de cette autorité puisse permettre de vérifier cette signature.

Les certificats numériques

Un certificat numérique est un message signé par la clé privée d'une autorité de confiance. Cette autorité de confiance est un tiers qui est reconnu digne de confiance par les deux parties d'une transaction. Un certificat X.509 version 3 est un standard qui contient notamment les renseignements suivants :

l'identité du porteur du certificat ;
l'identité de l'autorité de certification ;
les coordonnées de l'émetteur du certificat ;
la clé publique, objet du certificat ;
les paramètres de sécurité utilisés ;
la période de validité du certificat ;
la signature numérique de l'autorité émettrice pour valider le certificat.

Avant tout échange, il convient donc de se procurer un certificat auprès d'une

autorité de certification. Le partenaire doit fournir son identité.

on y adjoint sa clé publique ;
l'autorité ajoute ses propres informations dont sa propre clé publique ;
l'autorité calcule l'empreinte du tout et chiffre avec sa clé privée ;
l'autorité signe un certificat pour le partenaire à l'aide de cette empreinte.

Le récepteur peut récupérer ce certificat, recalculer l'empreinte correspondante pour vérifier l'intégrité du certificat, déchiffrer la signature du certificat avec la clé publique de l'autorité et vérifier que les deux empreintes sont identiques.

On peut donc faire la preuve de son identité, produire sa clé publique avec le certificat associé qui est une assurance de sécurité entre un nom de personne et sa clé publique associée. Quiconque peut ainsi vérifier la validité de la relation entre la clé publique et le nom associé.

Les infrastructures de gestion de clés (IGC)

Le mécanisme de gestion de ces certificats est mis en place dans les infrastructures de gestion de clés qui sont des infrastructures de confiance sur les réseaux pour vérifier l'identité des partenaires dans une communication ou une transaction. Les IGC (Public Key Infrastructure, PKI) sont des infrastructures matérielles et logicielles dont le déploiement et les procédures sont en définitive assez lourdes.

Une IGC comprend donc :

- une autorité d'enregistrement : cette autorité recueille en différé les demandes de certificats et prépare les certificats à valider ;
- une autorité de certification : cette autorité signe les certificats à l'aide de sa clé privée ;
- une autorité de dépôt et de séquestre : cette autorité permet de conserver et éventuellement de régénérer un certificat délivré à un utilisateur pour déchiffrer des messages quand le certificat n'est plus valable ou s'il a été perdu.

c. Les protocoles cryptographiques

PGP, S/MIME

PGP, acronyme de Pretty Good Privacy, été créé en 1991 par un militant, Philip Zimmermann, objecteur de la vision cryptologique autocratique des organisations gouvernementales américaines. PGP a été conçu pour offrir aux citoyens une solution de sécurité, librement téléchargeable sur le Web, pour se protéger de l'État en particulier. Au départ, il s'agissait de protéger un fichier informatique. PGP est à présent utilisé pour protéger la messagerie personnelle ou l'échange d'information entre deux partenaires. Il garantit l'origine des messages et leur confidentialité.

S/MIME (Secure/Multipurpose Internet Mail Extension) est une extension de sécurité du protocole de messagerie MIME, définie dans les RFC 3850 et RFC 3851 de l'IETF. C'est un format de message qui inclut les paramètres de sécurité comme, par exemple, la signature du message, le certificat du signataire et le corps du message éventuellement chiffré. Il faut souligner que les formats PGP et S/MIME sont distincts et qu'il n'existe pas d'interopérabilité entre les deux protocoles.

SSL

Le protocole SSL (Secure Socket Layer) est un protocole cryptographique, défini en 1994 par Netscape, appliqué à la communication sécurisée point à point entre deux entités d'un réseau. C'est un protocole de sécurisation des échanges électroniques, qui est intégré dans tous les butineurs (les navigateurs) des terminaux connectables à Internet. C'est le protocole de sécurité, le plus déployé, pour sécuriser le canal de transmission d'informations entre deux ordinateurs.

Son application la plus répandue est la connexion sécurisée sur un serveur pour éviter les abus et les fraudes, pendant une transaction de commerce électronique. SSL, au niveau 5 de la couche session du modèle de référence, sécurise toutes les applications qui fonctionnent nativement sur le protocole TCP. Il utilise les fonctionnalités du protocole TCP/IP pour permettre aux applications d'accéder à un mode sécurisé pour la transmission sécurisée de documents ou l'exécution de transactions sécurisées.

SSL n’implique aucune modification au niveau des applications pourvu qu’il soit incorporé dans le navigateur, ce qui a concouru à faciliter son déploiement. SSL permet donc d’assurer la confidentialité et l’intégrité des données échangées comme un numéro de carte bancaire au cours de la communication. Toutes les données sont chiffrées afin d’empêcher leur lecture par des tiers, si bien que rien ne transite en clair.
Le chiffrement de ces données mobilise d’importantes ressources de processeurs, ce qui ralentit les échanges et réduit les performances globales des systèmes. SSL permet d’assurer l’authentification du serveur et, optionnellement, l’ordinateur du client. En d’autres termes, le client peut être sûr de s’adresser au bon serveur sur Internet lors d’une transaction sécurisée pour acheter sur Internet ou pour déclarer ses impôts.

SSL nécessite pour cette authentification l’entremise d’un certificat X509 valide afin de garantir l’identité du serveur (en fait l’organisme qui exploite ce serveur) et le cas échéant l’ordinateur du client (en fait l’identité de l’utilisateur) pendant la session.

SSL offre enfin le service de sécurité de non-rejeu. SSL, qui fonctionne sous un mode client/serveur, est en fait composé de quatre protocoles : Handshake, Record, Alert et Change Cipher Spec. Il fonctionne en deux étapes : la première phase est assurée par le protocole Handshake, durant laquelle les deux protagonistes négocient les algorithmes de chiffrement, la création et le partage des secrets, ainsi que l’authentification des parties.

Dans la deuxième phase, le protocole Change Cipher Spec active les paramètres négociés entre les parties, le protocole Record assure les services de sécurité du protocole SSL, décrits plus haut. Enfin, le protocole Alert gère les erreurs et les dysfonctionnements.

IPSec

IPSec (Internet Protocol Security) est une collection de protocoles cryptographiques de sécurisation des réseaux IP. C’est un protocole de niveau 3 du modèle de référence. IPSec est indépendant des applications et du transport fiable TCP ou du transport UDP. Il peut se déployer sur les réseaux, indépendamment des utilisateurs, car il est transparent aux applications. Il est défini dans le RFC 2401 de l’IETF. Son élaboration fut laborieuse de 1992 à 1998 dans le cadre de la nouvelle version v6 du protocole IP, qui tarde toujours à

être déployée à grande échelle.

IPSec est désormais un module indépendant qui fonctionne sur IPv6, mais aussi sur la version la plus courante IPv4. Il est disponible sur tous les OS des stations de travail et des serveurs. IPSec peut être installé en natif dans la pile protocolaire de l'OS de l'ordinateur, du serveur, du routeur ou de la passerelle. Mais il est plus simple de l'insérer comme un module autonome entre la couche 3 et la couche 2, au-dessus de la couche de liaison des entités du réseau. IPSec peut être aussi déporté dans un boîtier dédié, indépendant des machines, module géré par le responsable réseau, de manière analogue à la gestion d'un routeur ou d'un pare-feu.

IPSec est composé de deux protocoles, AH (Authentication Header) défini dans le RFC 2406 et ESP (Encapsulating Security Payload) défini dans le RFC 2402. ESP offre les services d'authentification, d'intégrité et de confidentialité des données utiles associées au paquet IP.

AH, moins utilisé qu'ESP, offre les services d'authentification et d'intégrité de la totalité du paquet IP. IPSec fonctionne sous deux modes. Dans le mode tunnel, le paquet IP initial est totalement encapsulé dans un nouveau paquet IP. C'est avec ce mode que le service VPN est mis en œuvre. Dans le mode transport, on conserve le paquet initial.

Dans les deux modes, les champs spécifiques des protocoles AH et ESP sont ajoutés à la suite des rubriques classiques du format IP et les données du paquet sont signées ou chiffrées selon la politique en vigueur. Comme pour SSL, une phase initiale est nécessaire pour la négociation des algorithmes de chiffrement, la génération des clés et de l'authentification des parties. Cette phase est assurée par le protocole IKE (Internet Key Exchange) défini dans le RFC 2409.

PPTP

PPTP (Point-to-Point Tunneling Protocol) est une extension du protocole PPP (Point-to-Point Protocol), soumise à l'IETF en 1996. PPTP est un protocole de tunnel de la couche 2, qui permet aux données passant d'une extrémité à l'autre du tunnel d'être sécurisées par des algorithmes de cryptographie. PPTP encapsule des trames PPP dans des datagrammes IP pour une transmission sur un réseau IP, tel qu'Internet. C'est un protocole utilisé dans la mise en place des VPN.

Les réseaux virtuels privés (VPN)

Les entreprises et les organisations possèdent en général plusieurs sites géographiques qui travaillent conjointement en permanence. Dans chaque site géographique, les utilisateurs sont connectés ensemble grâce à un réseau local. Ces réseaux locaux sont souvent connectés via Internet.

En outre, certains utilisateurs peuvent vouloir se connecter aux réseaux de l'entreprise en étant à l'extérieur chez un client ou en déplacement. Il existait autrefois des liaisons physiques spécialisées, qui sont maintenant abandonnées au profit de liaisons logiques. Un réseau virtuel privé (Virtual Private Network, VPN) consiste en la fabrication d'un tunnel logique qui sera contracté par les communications de l'entreprise, lesquelles seront véhiculées dans cette tranchée numérique construite sur un réseau fréquenté par d'autres usagers. Dans la pratique, il s'agit d'un artifice, car les données vont utiliser un chemin ordinaire, emprunté par tout le monde, mais ces données chiffrées et tagguées seront sécurisées, à l'image du transport de containers plombés sur une route.

Le caractère privé du réseau est donc complètement virtuel puisqu'il ne s'agit pas de liaison physique spécialisée. Le caractère privé est créé par un protocole cryptographique (IPSec ou PPTP). Un VPN est donc une communication sécurisée entre deux points d'un réseau public, d'où l'expression de tunnel.

Chapitre 6 : La sécurité des réseaux

En sécurité, on distingue deux styles d'architecture de réseaux : les réseaux gérés par une autorité, comme les réseaux d'entreprise ou les réseaux d'opérateurs de télécoms et les réseaux comme Internet qui ne sont pas administrés pour les fonctions de sécurité de manière centralisée par une tutelle. Pour les réseaux gérés par une autorité, l'architecture est centralisée et les utilisateurs du réseau sont comme des abonnés appartenant à un club fermé. Chaque membre de ce club possède un secret (une carte à puce, un jeton, un mot de passe) et doit d'abord s'identifier, puis s'authentifier auprès de l'autorité de sécurité.

Il peut alors, selon son profil dans l'institution ou selon les privilèges de son contrat d'abonné, solliciter les services du réseau auxquels il a droit. Pour les réseaux non protégés par un office administrateur, les utilisateurs doivent se débrouiller seuls en installant des outils de sécurité sur leur propre machine ou se procurer des solutions de sécurité en faisant appel à des fournisseurs qui sont en intermédiation sur le réseau.
Dans ces réseaux, la sécurité globale ne règne donc pas et l'anarchie prévaut puisqu'il existe toujours une machine non protégée qu'une personne imprudente ou malveillante va utiliser à l'origine d'une attaque.

a. La sécurité des réseaux cellulaires

La sécurité des réseaux cellulaires nécessite de prendre en compte d'une part, les spécificités du fragment radio du circuit emprunté par les communications et d'autre part, la mobilité de l'utilisateur qui est repéré dans ses déplacements par une segmentation radio de l'espace géographique en cellules disjointes.

Une cellule est un domaine radio au centre duquel se situe une station relais qui raccorde le téléphone portable à une infrastructure filaire. La sécurité des réseaux cellulaires doit donc protéger notamment le canal de l'interface air des transmissions pour inhiber des interceptions et restreindre les brouillages. On doit donc spécifier le protocole d'identification et d'authentification du téléphone mobile de l'abonné. On doit aussi définir la protection du canal radio, en général, par le chiffrement des trames qui transitent entre le terminal et la station de base.

Les brouillages sont plutôt traités par des algorithmes de traitement de signal de diversité, des sauts de fréquence ou un étalement du spectre. La disponibilité du réseau est critique pour les réseaux cellulaires comme pour tout type de réseaux sans fil, à cause de la rareté des ressources radio. Les réseaux cellulaires sont donc vulnérables à différentes attaques de type déni de service. De plus, il faut aussi protéger le terminal miniature nomade devenu la proie des pickpockets et le profil de l'utilisateur stocké dans la carte à puce susceptible d'être déplombée puis triturée par des fraudeurs. Du point de vue de l'abonné, la sécurité du GSM est une sécurité centralisée, fondée sur un secret partagé entre l'opérateur de télécoms et l'utilisateur. Ce secret est stocké dans une carte à puce SIM (Subscriber Identification Module) encastrée dans le téléphone portable.

Il s'agit en fait d'une clé connue de l'opérateur et exploitée par les protocoles, et d'un identifiant unique IMSI (International Mobile Subscriber Identity) permettant notamment l'itinérance, c'est-à-dire d'être reconnu des autres opérateurs de télécoms et de pouvoir ainsi téléphoner à partir d'un autre pays ou d'un autre réseau d'opérateur que le sien. Cet identifiant est remplacé par un numéro temporaire, renégocié régulièrement, pour assurer un certain anonymat. Le protocole vérifie également le numéro du téléphone, un code unique composé de quinze chiffres, identifiant le terminal, le code IMEI (International Mobile Equipment Identity) pour limiter les vols.

Du point de vue de l'infrastructure mondiale, la sécurité du GSM repose sur la confiance mutuelle entre tous les opérateurs de télécoms. Ceux-ci sont garants du trafic international, administré sous la tutelle de cette sécurité fédérée. La sécurité des réseaux GSM se manifeste donc par les éléments suivants :

- l'authentification de l'utilisateur repose sur le principe défi-réponse, en utilisant l'algorithme d'authentification A3 ;

- la confidentialité des données de l'utilisateur est assurée sur le segment radio par un chiffrement symétrique ; l'algorithme A8 est utilisé pour la génération de clés de chiffrement, l'algorithme A5 pour le chiffrement des données. Cet algorithme A5, relativement faible, fut cassé plusieurs fois par des cryptanalystes et dut supporter des améliorations ;

- la confidentialité de l'identité de l'utilisateur est assurée par la génération d'une identité temporaire pour l'utilisateur, appelée TMSI (Temporary Mobile Subscriber Identity).

Les vulnérabilités du GSM proviennent surtout de la dissymétrie de traitement entre le terminal et la station relais. Des attaques de type homme au milieu sont possibles en se plaçant en coupure entre une station relais et un téléphone portable, dans le but d'intercepter les numéros ou les champs des protocoles et de capter finalement les communications.

Les réseaux GSM sont vulnérables à plusieurs attaques de type déni de service. Divers scénarios existent, analogues aux attaques par inondation sur Internet. La sécurité du GPRS ou de l'UMTS est similaire à celle du GSM dans son esprit et son architecture. L'UMTS protège les nouveaux services et apporte des améliorations significatives pour prendre en compte le retour sur expérience du GSM. En particulier, on a rééquilibré la symétrie de sécurité entre le téléphone et la station relais qui s'authentifient mutuellement.

b. La sécurité des accès sur Internet

La structure Internet est telle que les menaces ne sont jamais interceptées par le réseau, pour le moment. On peut les bloquer à une extrémité du réseau, mais le réseau lui-même est incapable de reconnaître ce qui devrait ou non circuler librement. Les fournisseurs d'accès relient les utilisateurs à Internet et ont par conséquent une situation clef pour contrôler les menaces entrantes et sortantes envers les ordinateurs de leurs clients. Ils pourraient éliminer un certain nombre de ces menaces avant même leur apparition sur les ordinateurs personnels et commencent à proposer des dispositifs de sécurité tels que des filtrages dans la messagerie, mais cette démarche n'est pas facile, surtout si on demande une obligation de résultats.

Pour concevoir une sécurité des accès sur Internet, il faut mettre en œuvre des mécanismes très généraux pour intégrer tous les nouveaux services. La première préoccupation est la gestion sécurisée des accès à ces services. Aussi, les mécanismes ont été regroupés par l'IETF, autour de trois fonctions principales, sous le sigle AAA, l'authentification, l'autorisation et l'imputation (accounting). L'objectif originel d'AAA était d'offrir aux abonnés en déplacement la possibilité de se connecter à Internet depuis un modem téléphonique. Le protocole AAA utilise une architecture client-serveur classique. Il identifie et authentifie l'utilisateur par l'intermédiaire d'un secret partagé par l'utilisateur et le serveur d'authentification, détermine les droits de cet utilisateur et impute l'utilisation des ressources à des fins de facturation.

Les serveurs AAA sont sur des serveurs d'accès au réseau, gérés par des opérateurs offrant des services de télécommunication. RADIUS (Remote Access Dial-In User Service) est un standard de l'IETF (RFC 2138-2139) pour les utilisateurs qui se connectent à Internet par modem. C'est le protocole AAA le plus répandu chez les fournisseurs d'accès à Internet, mais il comporte des limitations. DIAMETER (RFC 3588) améliore les fonctionnalités de RADIUS, pour notamment la gestion des inter-domaines et le passage à l'échelle. TACACS+ (Terminal Access Controller Access Control System) est une solution propriétaire reprise par Cisco, qui utilise TCP et gère séparément les trois fonctions AAA.

c. La sécurité des réseaux sans fil

L'utilisation accrue de réseaux radio pour accéder à d'autres réseaux adjacents et aux réseaux d'entreprise aggrave les préoccupations d'ensemble de sécurité. Les réseaux de faible portée comme Bluetooth se banalisent pour des connexions en point à point, par exemple, entre le clavier ou la souris et son ordinateur, ou bien entre le téléphone portable et un assistant numérique. Les vulnérabilités sont des interceptions (capture du mot de passe) ou des intrusions (diffusion de virus).

Le protocole de sécurité de Bluetooth met en œuvre des mécanismes particuliers mais performants qui ne sont hélas pas souvent activés. Les réseaux WiFi se déploient à la périphérie des réseaux filaires, dans les sites privés comme les entreprises, les institutions ou à la maison pour partager une connexion Internet et dans les sites publics ouverts (aéroport, campus) avec des portées radio de l'ordre de la centaine de mètres.

Les vulnérabilités sont nombreuses : connexions pirates, usurpations, écoutes intempestives… La mauvaise conception initiale de la sécurité des réseaux sans fil IEEE 802.11 paralysa son déploiement. La première génération de réseau sans fil IEEE 802.11, normalisée en 1997, comporte un protocole de sécurité, WEP (Wired Equivalent Privacy), qui délivre les services d'authentification par une méthode de défi, de confidentialité en chiffrant les trames et d'intégrité en signant les trames par le chiffrement de leur empreinte.

Le protocole WEP comporte d'importantes faiblesses : l'authentification n'est pas fiable car elle peut être corrompue par rejeu, la signature n'est pas efficace, enfin la saisie d'environ un million de trames chiffrées permet de déduire la valeur du secret partagé.

Face à ces insuffisances, diverses méthodes, en particulier le protocole TKIP (Temporal Key Integrity Protocol), sont venues se greffer pour résoudre ces lacunes. La norme IEEE 802.1X, dédiée initialement au contrôle d'accès des réseaux utilisant des commutateurs de paquets, réalise l'authentification des utilisateurs et le filtrage des trames qu'ils échangent.

Toutefois, la norme ne définit pas expressément le procédé de distribution des clés entre le point d'accès et le client. En outre, l'application de l'architecture IEEE 802.1X aux réseaux sans fil 802.11 peut introduire des problèmes de

sécurité comme les attaques de l’homme au milieu ou l’usurpation de session, notamment quand il n’y a pas d’authentification mutuelle. Consciente des failles de sécurité, l’IEEE a proposé en juillet 2004, comme extension du protocole de base, la norme IEEE 802.11i qui introduit des protocoles de sécurité renforcés au niveau de la couche MAC de liaison de données ; elle décrit également le protocole d’échange de clés entre le point d’accès et le terminal sans fil.

Elle supporte le protocole WEP, ainsi que les protocoles TKIP et CCMP (Counter Mode/CBC-MAC) qui améliorent les mécanismes de chiffrement des standards précédents. Le WPA (WiFi Protected Access) est une norme destinée à accélérer la diffusion des réseaux sans fil. C’est un sous-ensemble de la norme IEEE 802.11i, basé sur le protocole TKIP. WPA définit des éléments d’informations spécifiques et des machines d’états de gestion de clés partiellement compatibles avec 802.11i.

Le déploiement de cette norme implique donc la disponibilité de points d’accès, de cartes réseaux et de logiciels clients spécifiques. Le WPA2 est conforme au standard IEEE 802.11i et inclut le chiffrement AES (Advanced Encryption Standard) plus robuste. Le WPA2 est compatible avec les produits supportant le WPA, mais la compatibilité avec les produits utilisant le protocole WEP n'est pas assurée.

Chapitre 7 : Les dispositifs de sécurité

a. Les pare-feu

Un pare-feu (firewall) est un dispositif matériel et/ou logiciel qui implémente la fonction de sécurité de contrôle d'accès. Un pare-feu est donc un dispositif pour filtrer les accès, les paquets IP, les flux entrant et sortant d'un système.

Un pare-feu est installé en coupure sur un réseau lorsqu'il sert de passerelle filtrante pour un domaine à la frontière d'un périmètre fermé. Dans le cas d'un pare-feu personnel, sur une machine cliente, il est installé en son cœur pour y contrôler et filtrer les accès au réseau. Un pare-feu met en vigueur une politique de sécurité qui laisse passer, ou arrête les trames ou les paquets d'information selon cette politique. Il peut donc autoriser ou empêcher des communications selon leur origine, leur destination ou leur contenu.

Dans la pratique, un pare-feu lit et analyse chacun des paquets qui arrivent. Après analyse, il décide du passage ou de l'arrêt selon l'adresse IP de l'émetteur, du récepteur, selon le type de transport (TCP ou UDP) et le numéro de port, en relation avec le type d'application réseau. Quand la politique de sécurité ne concerne que les couches basses, la seule analyse du paquet permet d'autoriser, de rejeter ou d'ignorer le paquet.

Quand la politique décrit des règles de sécurité qui mettent en jeu le transport fiable (TCP), les sessions ou les applications, le pare-feu doit connaître l'état momentané de la connexion et doit garder en mémoire de nombreux paquets pendant un certain temps de façon qu'il puisse décider de l'autorisation ou du rejet des paquets. Les pare-feu ont des limitations : ils doivent être très puissants en termes de ressources pour ne pas ralentir le trafic dans un sens ou dans un autre, puisqu'ils sont en coupure sur le réseau. Ils ne doivent pas être court-circuités par d'autres passerelles ou des modems connectés directement à l'extérieur.

Ils sont des « bastions », c'est-à-dire des cibles pour les attaquants qui peuvent les assaillir pour saturer leur ressource. Un pare-feu doit posséder un système de journalisation (.log) sophistiqué de manière à analyser a posteriori tous les faits importants qui jalonnent la vie de cette passerelle filtrante : tentatives d'intrusion, événements anormaux, attaques par saturation, par balayage. Un pare-feu est en général architecturé de telle manière que l'on puisse distinguer physiquement les communications avec l'extérieur, celles avec le réseau à

protéger et enfin celles qui sont déviées vers une zone tampon de parking, souvent appelée zone démilitarisée (demilitarized zone, DMZ). C’est dans cette zone qu’on place le site Web, ouvert sur Internet, à l’abri d’un pare-feu, mais nettement séparé du réseau interne à protéger.

b. Les systèmes de détection et de prévention d'intrusion

Un système de détection d'intrusion (Intrusion Detection System, IDS) est un dispositif matériel et/ou logiciel de surveillance qui permet de détecter en temps réel et de façon continue des tentatives d'intrusion dans un réseau, dans un SI ou dans un ordinateur seul, de présenter des alertes à l'administrateur, voire pour certains IDS plus sophistiqué, de neutraliser ces pénétrations éventuelles et de prendre en compte ces intrusions afin de sécuriser davantage le système agressé.

Un IDS réagit en cas d'anomalies, à condition que le système puisse bien identifier les intrus externes ou internes qui ont un comportement anormal, en déclenchant un avertissement, une alerte, en analysant éventuellement cette intrusion pour empêcher qu'elle ne se reproduise, ou en paralysant même l'intrusion. Un IDS est donc un capteur informatique qui écoute de manière furtive le trafic sur un système, vérifie, filtre et repère les activités anormales ou suspectes, ce qui permet ultérieurement de décider d'actions de prévention. Sur un réseau, l'IDS est souvent réparti dans tous les emplacements stratégiques du réseau.

Les techniques sont différentes selon que l'IDS inspecte un réseau ou que l'IDS contrôle l'activité d'une machine (hôte, serveur) :

- sur un réseau, il existe en général plusieurs sondes qui analysent de concert, les attaques en amont d'un pare-feu ou d'un serveur ;
- sur un système hôte, les IDS sont incarnés par des démons ou des applications standards furtives qui analysent des fichiers de journalisation et examinent certains paquets issus du réseau.

La détection d'intrusion est un problème difficile que des chercheurs ont appréhendé, il y a maintenant plus de trente ans. Le problème était assez simple à exprimer lorsque ces systèmes étaient des systèmes fermés, à l'intérieur d'un périmètre défini, avec des utilisateurs connus. Le problème s'est compliqué notablement depuis que les systèmes sont sans fil et ouverts (le périmètre est presque impossible à cerner), que les utilisateurs sont nomades (avec des entrants, des sortants et parfois des anonymes), que les services sont mobiles et que ces systèmes s'étendent par interconnexion sur de grands espaces géographiques (infrastructure de télécommunications).

Pour vaincre les tentatives d’intrusion, il faut définir un schéma d’identification, d’authentification et d’autorisation destiné à des utilisateurs légitimes et aux matériels et logiciels qui se situent à l’intérieur du système. On soulage fortement l’IDS en filtrant au préalable le trafic forcément régulier et légitime. On définit alors une sonde intelligente qui observe, enregistre et analyse le comportement des sujets, des objets et des événements.

À partir d’un modèle de normalité et conformément à certains seuils, on décrète que le comportement du système et des personnes est normal ou suspect. On en déduit des actions à mettre en œuvre, immédiatement ou non. Ces dispositifs ont des défauts majeurs (fausse alerte et carence de détection), bien décrits dans la littérature.

c. Les pots de miel

Les pots de miel (honey pots) sont des dispositifs de leurre, à la frontière des SI, destinés à piéger les attaques des pirates. Les attaques par balayage, en particulier, ont tendance à tomber dans le panneau de ces attrape-nigauds. Un pot de miel est un mécanisme qui permet d'augmenter la sécurité d'un réseau ou d'un système, pourvu qu'on soit capable d'analyser les profils des attaques tombées dans l'embuscade. Un pot de miel peut venir en complément d'un pare-feu. Mais les mises en œuvre concrètes sont plutôt rares. Les pots de miel sont répertoriés selon deux catégories, à faible ou à forte interaction. L'interaction représente l'intensité de l'activité que peut avoir un attaquant avec le pot de miel.

Les pots de miel à faible interaction consistent à émuler des OS et des services. L'émulation présente l'avantage de circonscrire les possibilités de l'attaquant incapable de prendre le contrôle du véritable OS pour endommager d'autres systèmes. L'activité est réduite au degré d'émulation offerte. Ainsi, ces pots de miel offrent peu de prérogatives à l'intrus qui aura un champ d'action limité, car ils ne font que proposer des services factices et ne renvoient jamais de réponse. L'avantage des pots de miel à faible interaction est leur simplicité. Ils sont faciles à implémenter, à gérer et présentent peu de danger avec des attaquants très cantonnés. En pratique, on installe un logiciel, on sélectionne les OS et les services qu'on veut émuler et on surveille l'activité en laissant le pot de miel fonctionner.

Les inconvénients sont que ces pots de miel examinent une information limitée et ne peuvent épier que des activités connues. Enfin ces pots de miel à faible interaction sont aisément détectables par un attaquant. Les pots de miel à forte interaction n'émulent rien mais engagent des OS véritables et des applications réelles. L'avantage de cette solution est qu'il est possible de recueillir des informations nombreuses. Comme les attaquants ont accès à de vrais systèmes, on peut observer l'intégralité de leur comportement et on peut analyser ainsi les méthodes et les outils qu'ils utilisent.

Ce type de pots de miel ne fait pas de suppositions sur le comportement probable de l'attaquant et capture tout ce qu'il peut. Ces pots de miels permettent donc de révéler des modes d'attaques encore insoupçonnées. Néanmoins, leur utilisation comprend des risques élevés puisque la machine, désignée comme pot de miel, est destinée à être compromise. Il existe donc un risque que l'attaquant puisse

utiliser les vrais services du pot de miel comme rebond pour affronter d'autres systèmes voisins. Enfin, ces pots de miel sont plus compliqués à mettre en place et à gérer.

Chapitre 8 : Les solutions d’identification et d’authentification

a. La biométrie : une présence numérique liant l'homme au système

La biométrie est une technique ancienne qui connaît un engouement récent dans son application électronique. Elle a pour but d'identifier les personnes physiques par des caractéristiques physiologiques ou comportementales. La mesure d'une grandeur de l'apparence du vivant et le calcul du représentant biométrique pour assurer l'identification doivent être discriminants, fidèles, automatiques et rapides. La biométrie identifie donc un individu par ce qu'il est et qui est unique et caractéristique de la personne. On peut ensuite l'authentifier par le respect d'un procédé sûr de validation biométrique ou bien par la vérification de ce qu'il sait, comme un mot de passe dont il se souvient.

Pour déployer un système biométrique, il est nécessaire de recueillir tout d'abord un échantillon de référence et d'extraire ensuite une représentation numérique réduite, opérations qui doivent être réalisées par une institution de confiance. Les échantillons sont alors stockés globalement dans une base de données sous la responsabilité d'une organisation de confiance ou localement, dans une carte à puce par exemple, sous la responsabilité du propriétaire. Lorsque cette infrastructure biométrique est déployée, une personne physique peut alors être identifiée, après capture en temps réel d'un nouvel échantillon, calcul de la représentation numérique caractéristique de la personne, et comparaison avec le gabarit.

Les inconvénients des méthodes biométriques sont connus : l'enregistrement et le déploiement sont lourds, le coût d'exploitation est élevé, l'interopérabilité des infrastructures biométriques est faible, la durée de vie des informations de référence est limitée, mais surtout le contrôle, c'est-à-dire la comparaison entre un étalon et un échantillon prélevé en temps réel est statistique, sans garantie totale de succès. Les procédés possèdent donc des performances qui varient avec la source biométrique. Pour chaque mode d'identification, il faut estimer statistiquement le taux de mauvais rejets (on a refusé des personnes légitimes) et le taux d'acceptations incorrectes (on a admis des personnes illégitimes).

La conjonction de plusieurs modes biométriques est indispensable pour atténuer le risque d'erreur. Ensuite, plutôt que d'attaquer en amont la chaîne de traitement de biométrie, les attaquants préfèrent mettre en défaut l'algorithme final de comparaison des deux échantillons et faire en sorte que sa réponse soit constamment positive, ce qui annihile alors tout le dispositif de biométrie. Par

ailleurs, l’introduction de la biométrie soulève des questions délicates de protection de la vie privée et des difficultés culturelles et sociologiques qui ne manqueront pas de tempérer l’enthousiasme envers cette technique.

b. La carte à puce : un écrin de confiance pour amorcer la sécurité

Une carte à puce (smart card) est une enceinte hermétique portable de sécurité, une entité de confiance attachée à un individu par l'intermédiaire d'un code secret. C'est un authentique micro-ordinateur doté d'un coffre fort qui renferme des secrets, assisté par un processeur spécifique étanche capable d'exécuter des primitives cryptographiques.

La carte à puce offre principalement une authentification robuste, mais fournit également des fonctions d'identification comme une carte d'identité électronique.
Elle est en outre un moteur miniature de sécurité, une machine de chiffrement de messages courts et de calcul de signatures. La carte à puce déployée en Europe, a connu son essor depuis trente ans grâce à la carte bancaire, aux télécartes de téléphonie, puis grâce à la carte SIM du GSM. La carte à puce peut stocker des certificats X.50978 pour l'identification et des caractéristiques biométriques.

Elle connaît une puissance croissante de calcul, améliorant ainsi les performances de résistance aux attaques par essais et erreurs, et une ouverture plus grande grâce à l'émergence d'applications en langage Java, au sein même de la carte. Le crypto-processeur permet de calculer en toute confidentialité les opérations de sécurité : la clé privée reste secrète à l'intérieur de la carte à puce.

Avec la commercialisation massive des cartes à puces et leur rôle dans les transactions de paiement, les pirates redoublent d'imagination pour élaborer de nouvelles attaques physiques ou par canaux cachés sur le matériel afin de contourner la sécurité toujours plus ferme de ces micro-ordinateurs de confiance. La carte à puce demeure un dispositif de sécurité très fiable grâce aux contre-mesures des fabricants. Elle évite la multiplication des mots de passe souvent peu protégés par les utilisateurs négligents. Elle obéit à des normes de sécurité (FIPS I40) et se généralise dans les applications des réseaux et des SI pour la sécurité de bout en bout entre deux protagonistes, le client, l'abonné ou l'utilisateur d'une part et le vendeur, l'opérateur ou le serveur informatique, d'autre part.

Chapitre 9 : La sécurité des systèmes confinés

a. La sécurité des systèmes embarqués

Les systèmes embarqués ou les logiciels enfouis (embedded systems or software), sont des entités autonomes qui remplissent une mission indépendante, parfois critique, sans intervention humaine, en général en interaction directe avec l'environnement extérieur que celui-ci soit physique ou informatique. Ces systèmes autonomes miniaturisés peuvent être isolés mais ils sont la plupart du temps reliés et communiquent à travers un réseau.

Ces systèmes sont soumis à des contraintes fonctionnelles qui mettent en jeu leur définition, leur robustesse, leur conception, leur capacité à accomplir une tâche avec des ressources déterminées, souvent liées aux astreintes temporelles ou à la consommation énergétique. Le comportement de ces systèmes doit être blindé, voire garanti avec un haut niveau de sécurité et de sûreté, pendant tout leur cycle de vie.

Ces systèmes doivent être protégés, mais ils doivent avant tout fonctionner correctement tant dans leurs fonctions purement intestines que dans leurs interactions avec le monde extérieur, d'autant plus que ces systèmes embarqués sont plongés de nos jours dans une « intelligence ambiante », de sorte que les interlocuteurs et les voisins du système peuvent être eux-mêmes des ordinateurs. Avec la diffusion massive des capteurs et des actuateurs électroniques, les systèmes complexes bénéficient d'une instrumentation importante.

Les échanges d'information avec l'extérieur et la faculté d'adaptation de ces systèmes à l'environnement nécessitent des contrôles sévères sur la bonne marche de ces systèmes avec des modules flexibles, autochargeables, autoconfigurables. Les systèmes embarqués ou les logiciels enfouis doivent donc posséder des propriétés de sécurité et de sûreté de fonctionnement, localement, puisque ces systèmes autonomes doivent résister seuls à des sollicitations imprévisibles de leur entourage.

Ils doivent donc être pourvus algorithmiquement d'une sorte de conscience de sécurité et d'une espèce d'instinct de survie, le tout étant conçu et calculé à partir des données et des traitements in situ, disponibles. Sur la base des informations fournies par l'instrumentation en place et des connaissances disponibles par des modèles mathématiques, physiques et de sécurité, il s'agit d'implanter localement une carapace de sécurité et de sûreté, voire de résilience pour d'abord

percevoir (observer, détecter, localiser, diagnostiquer), analyser (selon la politique en vigueur) la situation hic et nunc en fonction des événements imprévus, des occurrences aléatoires, des dangers et réagir (corriger, se cicatriser, tolérer, se maintenir, s'adapter, se dégrader, survivre en autarcie, voire s'anéantir) en fonction des évolutions et des déviations par rapport à un état ou un comportement de référence normal, souhaitable ou nominal. La sécurité et la sûreté des systèmes et logiciels embarqués se construisent donc en plusieurs phases :

- pendant la spécification du système : maîtrise de sa complexité, de son architecture et claire séparation entre le module autonome et son infrastructure en considérant l'énergie consommée et les flux de communication : application traditionnelle des méthodologies pour la spécification de sécurité et de sûreté;

- pendant la conception du système : utilisation de techniques de modélisation, d'abstraction et de techniques du comportement dynamique des systèmes, temps réel strict ou adaptatif, méthodes mathématiques et ingénierie système ;

- pendant l'implantation : épargne rigoureuse des ressources spatiotemporelles, parcimonie dans les communications avec les périphériques, économie temporelle intransigeante dans les réseaux, calcul d'horloge, ordonnancement des messages, compilation optimisée des algorithmes en travaillant à l'aide d'ateliers de développements informatiques spécifiques ;

- pendant la validation : vérification formelle, simulation et test, évaluation de l'assurance de sécurité et de sûreté.

La conception du système doit prendre en compte les aspects mathématiques, informatiques, électroniques et architecturaux, les aspects de normalisation et de standardisations (interopérabilité) et les impératifs économiques. La difficulté porte en général sur l'assemblage hétérogène de composants et de modules.

La correction de la spécification ainsi que la conformité de l'implantation réelle par rapport à la spécification sont des étapes importantes qui ne doivent pas être confondues. Dans sa spécification, il faut scrupuleusement définir les menaces et l'intelligence locale de sécurité et de sûreté du système. Il faut le rendre tolérant

aux fautes, aux incertitudes de l’environnement et des situations. Il faut l’immuniser contre des agressions potentielles. La sécurité d’un système, c'est-à-dire d’une part la non-agressivité du monde extérieur face aux vulnérabilités résiduelles du système embarqué et d’autre part son caractère inoffensif vis-à-vis de l’entourage reste en définitive une question complexe à cause de l’incomplétude de sa caractérisation.

b. La sécurité des terminaux

Alors que SSL résout la sécurité des communications de point à point sur un réseau et que la carte à puce est le lien sécurisé entre l'utilisateur final et le SI, il convient aussi de préserver le terminal lui-même d'une utilisation dangereuse ou frauduleuse, soit que son utilisateur laisse ouvertes des brèches ou bien outrepasse ses droits (utilisation irrégulière de licence logicielle), soit que les éditeurs de logiciels abusent de leur position dominante, en interdisant l'installation de logiciels concurrents. Pour sécuriser un terminal, il est nécessaire de cacher un bouquet de secrets dans ce terminal.

Ces éléments secrets peuvent être partagés et exploités par le fournisseur de matériel, les éditeurs de logiciels, les applications et l'utilisateur. Définir une politique de sécurité fédérative pour l'exploitation du poste de travail, est une question qui relève de la quadrature du cercle, puisque le terminal devient un espace où maintes politiques aux intérêts paradoxaux s'affrontent. Pour son implémentation, l'articulation sécurisée entre le matériel et le logiciel demeure toujours un point dur à résoudre.

Les secrets peuvent être insérés en dur dans le cœur du matériel ou bien être enfouis en périphérie dans une carte modulaire de chiffrement. L'architecture de sécurité d'un poste de travail se décompose en trois parties :

- une ressource matérielle avec un processeur sécurisé qui offre des fonctions cryptographiques, qui exécute les tâches sensibles et une mémoire qui stocke les éléments secrets et les informations sensibles ;

- un noyau minimum digne de confiance, qui assure les fonctions de base de l'OS ;

- une interface logicielle sécurisée avec les applications.

La sécurité des applications prend alors racine dans cette infrastructure native de base.
Les applications peuvent puiser dans cette plate-forme, les ressources de sécurité dont elles ont besoin. Les outils de sécurité d'un poste de travail permettent :

- de vérifier l’intégrité du poste : à l’amorce, la ressource matérielle vérifie l’identification et la configuration des composants matériels et la certification des composants logiciels ;

- de développer la sécurité des applications grâce à une bibliothèque sécurisée de primitives de sécurité : chiffrement, signature, authentification, gestion de confiance des clés.

TPM (Trusted Platform Module) est le résultat des recommandations précisées par TCPA. C’est un composant informatique installé sur la carte mère ou intégré au processeur. TPM est capable de chiffrer les données et de les stocker dans des espaces sécurisés. Indépendamment de ces tentatives de normalisation, il existe sur le marché maintes solutions propriétaires, sous forme de cartes modulaires, utilisées dans les grandes entreprises et gérées par le responsable de sécurité.

Chapitre 10 : La sécurité des systèmes et des logiciels

a. La sécurité des systèmes d'exploitation : la faille essentielle

Les systèmes d'exploitation (Operating System, OS) sont le talon d'Achille des SI. Les attaquants externes d'un système doivent toujours, à un moment donné, emprunter leur chemin et utiliser leurs services. Les OS (UNIX, Linux, Windows) et les moniteurs en temps réel (Symbian, Linux embarqué) proposent un ensemble de fonctions mises à la disposition des processus d'applications. Ils possèdent des interfaces qui contiennent habituellement des appels pour ouvrir, fermer, lire, écrire des fichiers et des appels pour communiquer (transferts de messages, appels de procédures). Mais ces OS ne sont, en général, pas sécurisés. Sous UNIX, la politique de sécurité est discrétionnaire, c'est-à-dire que les propriétaires des fichiers décident eux-mêmes des attributs de sécurité de leurs fichiers.

Avec la structure actuelle des SI, l'OS est un élément prépondérant. S'il est acheté sur étagère avec la machine, c'est un progiciel hermétique avec toutes les répercussions fâcheuses que cette méconnaissance implique. La gravité des conséquences d'une intrusion dans un SI par la prise de contrôle de l'OS est très élevée. La faiblesse des SI provient souvent de la non-maîtrise de l'élément primordial de ces systèmes : l'OS des serveurs ou des stations terminales.

La faiblesse des réseaux découle aussi de l'opacité des OS des routeurs ou des passerelles. Le risque encouru est similaire à la remise d'une clé secrète à un utilisateur non autorisé. La sécurité minimum d'un OS comprend deux types de fonctions de sécurité : les fonctions intrinsèques et les services supplémentaires offerts aux applications. Avec cet arsenal de fonctions, on peut ainsi sécuriser les principales fonctionnalités vulnérables d'un OS.

b. La sécurité des logiciels : les réponses providentielles, propriétaires ou publiques

La sécurité des applications ou des logiciels est un thème difficile car un logiciel seul n'a pas de propriété réflexive pour déclarer la confiance qu'on peut lui accorder ou décréter la confiance qu'il peut avoir envers telle autre entité. Il est donc nécessaire d'ancrer la sécurité des applications à l'infrastructure générale de sécurité. En pratique, on arrime l'application à un crochet sécurisé qui est relié aux parties sécurisées du terminal ou aux protocoles d'authentification et d'autorisation du réseau ou du système. La sécurité des logiciels se scinde de nos jours en deux volets contradictoires :

- d'une part, les éditeurs désirent enrayer le vol de logiciels et l'usage abusif de licences, distribuer leurs contenus intangibles en les valorisant (DRM) et conserver la confidentialité du texte (IPR) de leur logiciel. S'ils ne sont pas eux-mêmes dignes de confiance, ils peuvent à leur tour abuser les utilisateurs en adjoignant des sondes secrètes pour espionner à leur insu les utilisateurs, ce qui constitue une sécurité dans l'obscurité ;

- d'autre part, la communauté des utilisateurs redoute les positions économiques dominantes des éditeurs qui fort de leur avantage veulent en profiter de manière déloyale. Cette tendance de pensée informatique de type altermondialiste préconise de dépouiller l'informatique de son caractère opaque et libéral, en distribuant des logiciels nus, c'est-à-dire transparents, lisibles par quiconque souhaite inspecter les textes de l'application informatique.

Face à la montée de la menace du piratage de logiciels et de l'hégémonie des logiciels propriétaires, certaines réponses sont inappropriées :

- des éditeurs de logiciels et les industriels de l'électronique se regroupent avec des initiatives propriétaires et conservatrices qui sont plus d'ordre géostratégique, avec des intérêts plus égoïstes que sécuritaires ; Et d'autres ne sont pas encore arrivées à maturité

- la montée en puissance des standards ouverts et des logiciels libres, notamment sur les serveurs, prouve l'existence d'un modèle

économique original. Néanmoins et malgré le soutien d'acteurs majeurs, les logiciels libres ne constituent pas aujourd'hui une alternative complète, mature et sûre aux éditeurs de logiciels habituels. Les logiciels libres sont encore des produits d'informaticiens pour des clients informaticiens, et ne sont pas manipulables et configurables par des utilisateurs non spécialistes. Par ailleurs, ces logiciels ne sont exempts ni de bugs, ni de portes dérobées, ni de virus. Si la communauté du logiciel libre arbore un côté Robin des bois sympathique, elle masque, voire ignore elle-même, son versant négatif d'auberge espagnole, en ayant laissé les pirates l'infiltrer largement.

Afin de protéger les applications sur les postes de travail connectés à des réseaux, deux approches très différentes sont apparues dans la dernière décennie :

- en 1995, la sécurité par le langage Java et sa machine virtuelle sécurisée a connu un succès éclatant et a même contribué à la réussite d'Internet. C'est une sécurité partielle qui a permis la diffusion des logiciels Java sur le Web

- en 1999, la sécurité par le matériel et son prolongement logiciel, sous le sigle de TCPA est réapparue. C'est une approche classique dans l'informatique de défense, qui suscite depuis son introduction une polémique qui concerne les arrière arrière-pensées protectionnistes supposées des concepteurs, pour juguler la progression du logiciel libre et entraver la concurrence apportée par les cartes à puce.

La sécurité des logiciels Java fut conçue au départ pour protéger le poste de travail récepteur des logiciels téléchargés à partir d'Internet. La machine virtuelle Java fait office de réceptacle de sécurité. Le modèle de sécurité de Java est un modèle appelé sandbox en anglais, c'est-à-dire bac à sable, à l'image du terrain de jeu pour les enfants où ils peuvent s'amuser sans crainte. Les applications Java s'exécutent alors sûrement dans cette machine virtuelle puisqu'à l'intérieur de cette zone tous les appels à des fonctions abrogatives du système sont proscrits.

TCPA (Trusted Computing Platform Alliance), Alliance pour une informatique

de confiance, fut un projet lancé par Intel en 1999, très controversé dans le monde de la sécurité. TCPA a évolué, suite à ce tollé, s'est étendu, a modifié certaines ambitions mais la motivation géostratégique monopolistique est restée. L'objectif affiché de TCPA est de protéger les droits des éditeurs de logiciels. TCPA propose les spécifications d'un module de sécurité, de surveillance et d'alerte grâce à une puce ou à un périphérique soudé à la carte mère. C'est l'équivalent d'une carte à puce associée non pas à l'utilisateur mais au poste de travail.

Chapitre 11 : La sécurité sur mobile

Quel rapport entre une banque centrale, une pompe à insuline, la technologie Blockchain, une Tesla, un grand parti politique, un drone militaire, une poupée… Ils ont tous été piratés en 2016 ! Avec des conséquences plus ou moins graves voire désastreuses. Au Bangladesh, la banque centrale du pays a perdu plus de 80 millions de dollars (et son PDG avec) après que son système de détection des fraudes a été neutralisé ; le parti des démocrates américains cherche toujours à comprendre dans quelle mesure le piratage de leur système de messagerie a pu leur coûter l'élection présidentielle et favoriser l'élection de Donald Trump; quant à certains géants du Net (Amazon, Netflix…) ont vu leurs services inaccessibles durant des heures après une attaque sur les serveurs d'adressage du réseau Internet…

En clair, plus rien ni personne, dès lors qu'il est connecté à un réseau ouvert comme Internet, n'est plus à l'abri d'une cyberattaque. C'est l'une des conclusions majeures que l'on peut retirer du panorama de la cybercriminalité présenté par le club de la sécurité de l'information français (Clusif). Réunissant plus de 250 entreprises autour du thème de la sécurité informatique, il est revenu sur les grandes tendances de la cybersécurité et les événements marquants de 2016. Trois formes de cybercriminalité se dégagent.

Les rançongiciels

Citroni, Petya, Keranger.. S'ils n'ont pas accédé à votre PC, tant mieux pour vous. Derrière ces noms se cachent des logiciels de rançons qui frappent aussi bien les particuliers que les entreprises. Leur principe : chiffrer le contenu des disques durs de leurs victimes pour les rendre totalement inexploitables. Et leur vendre ensuite la clé de déchiffrement moyennant une forte somme d'argent. Un business lucratif.

Aujourd'hui, plus d'une victime sur deux paie pour retrouver ces données. Ce business aurait rapporté un milliard de dollars aux États-Unis. Les PC ne sont les seules machines ciblées. Le logiciel Keranger s'est attaqué au Mac en début d'année 2016

"On a assisté en 2016 à un changement d'échelle du phénomène des

ransomwares. Ces attaques sont réalisées à plus de 60% à partir de mails qui contiennent une pièce jointe infectée ou un lien qui mène vers un site frauduleux", explique le colonel Eric Freyssinet, expert en cybersécurité pour le Ministère de l'Intérieur. L'expert déconseille de payer la rançon. "Ce n'est pas une garantie de retrouver ses données. Si le malware n'a pas été traité, il peut encore frapper. Nous conseillons de mettre en place des systèmes de duplication des données" précise-t-il.

Le piratage des objets connectés

Nouvelle cible des cybercriminels: les objets connectés. L'attaque qui a touché la société DYN qui opère des serveurs d'adressage du réseau Internet, a été un événement marquant de l'année 2016. Rappel des faits : en octobre dernier, des pirates ont pris le contrôle de milliers d'objets notamment des caméras de vidéosurveillance et des routeurs domestiques. De quoi bombarder de requêtes des serveurs en charge d'adresser les flux Internet jusqu'à les faire tomber. Résultat : les sites Amazon, Netflix, Twitter n'étaient plus inaccessibles durant plusieurs heures.

Les pirates (et des experts à des fins de sensibilisation au danger) ont découvert durant l'année 2016 des failles de sécurité dans toute sorte de produits : ampoules des bâtiments intelligents, poupées, un interphone, pompe à insuline … "Dans la plupart des cas rencontrés, le problème est la même : la conception du produit n'a pas pris en compte la sécurité dès le départ", explique Hervé Schauer du cabinet HSC by Deloitte. Résultats : n'importe quel objet anodin peut devenir le vecteur d'une cyberattaque... La voiture connectée est une cible privilégiée. Des voitures Tesla ont été piégées par de faux point d'accès Wifi sur lesquels elles venaient télécharger des données ; une Jeep Cherokee dont l'ordinateur de bord a été piraté jusqu'à en prendre le contrôle des fonctions mécaniques comme le freinage…

Les terminaux mobiles

Les téléphones portables sont également des cibles faciles. Les modèles Android sont les plus ciblés. Leur propriétaire croit télécharger un jeu ou une application à partir de son magasin d'applications favori mais il télécharge à son insu un logiciel malveillant. Ce malware prend ensuite le contrôle de tout ou partie du terminal : verrouillage de l'écran, exfiltration de vos données personnelles, désactivation de l'antivirus, envoi de SMS vers des numéros surtaxés... "Ces

malwares sont suffisamment sophistiqués et s’adaptent aux mises à jour des téléphones. Souvent, ils ne sont pas détectés par les antivirus", décrypte Adrien Petit, spécialiste des nouvelles pratiques de cybercriminalité dites « underground » pour le cabinet CEIS. Des développeurs pirates font un véritable business de cette activité de piratage des téléphones portables : certains de ces malwares sont vendus sur des sites Internet à partir de 250 dollars !

Le pire est peut-être à venir. Comment ? En combinant ces attaques ! Le couplage des ransomwares avec les vulnérabilités objets connectés risquent de faire mal. C'est même déjà à l'oeuvre. Ainsi certaines TV connectées ont été piratées par les virus Flocker ou PopCorn Time. En guise de programme TV, elles affichent un message exigeant le paiement d'une rançon pour fonctionner à nouveau. C'est clair: la cybersécurité peut tourner au film catastrophe.

a. Quelles sont les quatre grandes menaces mobiles du moment et comment s'en prémunir ?

Longtemps, on a cru être plus en sécurité sur son téléphone mobile que sur un ordinateur, mais depuis que l'utilisation de terminaux mobiles a explosé à travers le monde, les menaces n'ont jamais été aussi nombreuses sur ces appareils. Actuellement, quatre logiciels malveillants menacent particulièrement les systèmes d'Apple et Google grâce à des techniques très astucieuses. Si bien que lorsque leurs victimes se rendent compte qu'ils ont été piratés, il est souvent déjà trop tard.

Même si les plateformes mobiles restent plus sûres que les PC, les systèmes d'exploitation iOS et Android ne sont pas exempts de failles susceptibles d'être exploitées pour voler des données parfois très précieuses.

Les entreprises qui utilisent uniquement ActiveSync pour déployer leur messagerie sont particulièrement vulnérables à ces menaces, car ActiveSync ne propose que très peu de fonctionnalités MDM. La plupart s'appliquent seulement aux anciens systèmes d'exploitation Windows et certaines ne fonctionnent pas du tout sous iOS ou Android. Seul un fournisseur de gestion de la mobilité en entreprise (EMM) peut protéger les terminaux mobiles des logiciels malveillants tels que Stagefright, Keyraider, XcodeGhost et YiSpecter.

99 % des appareils Android vulnérables face à StageFright

Stagefright tire parti de la vulnérabilité de la bibliothèque multimédia Android. Le pirate envoie un message multimédia malveillant par MMS. Lorsque le terminal Android vulnérable reçoit le message, ce dernier est automatiquement téléchargé et infecte l'appareil par le biais de la fonction d'aperçu multimédia. Il est important de noter qu'aucune action n'est requise de l'utilisateur (clic sur un lien ou téléchargement d'une application) pour que le code malveillant pénètre dans le téléphone. Ce dernier est infecté dès la réception du MMS.

Les entreprises doivent être extrêmement vigilantes, car Stagefright peut voler des données, détourner le microphone, utiliser la caméra et essentiellement se comporter comme un logiciel espion sur le terminal infecté.

En contaminant plusieurs milliers d'applications, XcodeGhost cible tous les

terminaux iOS

XcodeGhost attaque les terminaux, jailbreakés ou non, par le biais d'applications infectées qui ont réussi à se retrouver dans l'Apple Store. Les applications peuvent être accidentellement infectées par XcodeGhost si les développeurs iOS (et OS X) téléchargent l'environnement de développement logiciel Xcode d'Apple depuis des sites malveillants plutôt que sur le site de téléchargement officiel d'Apple. Lorsque les développeurs utilisent l'une de ces versions piratées de Xcode, sans le savoir, ils dissimulent dans leurs applications un logiciel malveillant. À ce jour, plus de 4 000 applications infectées par XcodeGhost ont été identifiées par notre partenaire FireEye et supprimées de l'App Store par Apple.

Si des collaborateurs téléchargent des applications infectées par XcodeGhost sur leurs terminaux mobiles personnels ou détenus par l'entreprise, les données de l’entreprise peuvent être en danger. Grâce à ce logiciel malveillant, des pirates peuvent exécuter des commandes et des contrôles (C&C) à distance, ouvrir des pages Web sur le terminal, afficher des invites de saisie de mot de passe factices et voler des identifiants de connexion.

Keyraider : les données de plus de 225 000 comptes Apple subtilisés

KeyRaider cible les terminaux jailbreakés, car le jailbreak élimine la plupart des fonctionnalités de sécurité intégrées du système d'exploitation. Il peut voler les noms d'utilisateur, les mots de passe, les certificats et même les clés privées.

Les entreprises doivent être particulièrement vigilantes et bloquer l'accès aux informations professionnelles sur les terminaux mobiles jailbreakés. Les logiciels malveillants tels que KeyRaider peuvent prendre le contrôle d'un iPhone ou d'un iPad, et ainsi accéder rapidement aux e-mails, documents et données d'entreprise.

YiSpecter prend le contrôle des données utilisateur en toute discrétion

YiSpecter infecte les terminaux, jailbreakés ou non, grâce à des API privées, non publiées ou non prises en charge par l’iOS d’Apple. Bien que les applications utilisant ces API soient généralement bloquées lors des processus de contrôle des applications d'Apple, YiSpecter peut se répandre de trois autres manières : par le fournisseur d'accès à Internet, par un ver sous Windows qui infecte le terminal

lors d'une association, et par l'installation d'une application hors ligne.

Une fois le terminal infecté, YiSpecter peut modifier, installer et lancer des applications iOS sans l'autorisation de l'utilisateur. Il peut également remplacer les applications existantes par celles qu'il télécharge, afficher des annonces en plein écran lorsque l'utilisateur lance une application normale, changer le moteur de recherche par défaut de Safari, ouvrir des pages Web et les ajouter aux favoris, ou encore transférer des informations du terminal vers le serveur C&C. Ce logiciel malveillant peut aussi réapparaître automatiquement après sa suppression.

Face aux menaces mobiles, des solutions EMM pour une protection adaptée

Bien qu'ActiveSync soit efficace lors de l'utilisation de la messagerie sur les terminaux mobiles, il fait courir à votre entreprise un risque important d'attaque par des logiciels malveillants mobiles sur iOS et Android. Une solution EMM adaptée dispose des fonctionnalités nécessaires pour bloquer ces menaces sur l'ensemble des terminaux gérés de l’entreprise et assurer la protection des données.

Pour éliminer une grande partie de ces menaces il faut commencer par déterminer le statut ou le niveau de sécurité du terminal. Les contrôles de statut servent à vérifier qu’il n'a pas été jailbreaké, que le terminal et l'utilisateur sont autorisés à accéder au réseau, et qu’il contient des versions approuvées des systèmes d'exploitation et des applications. Seuls les terminaux ayant un niveau de sécurité conforme sont autorisés à accéder aux informations de l'entreprise présentes sur le terminal ou le réseau. Si la solution EMM détecte un logiciel malveillant sur un terminal, il prend automatiquement des actions de conformité pour le mettre quarantaine, y supprimer les données professionnelles et empêcher tout accès à ces données depuis ce terminal.

b. Collusion des applications : Nouvelle menace sur mobile

Le retard des mises à jour logicielles des applications mobiles offre de nouvelles opportunités pour les cybercriminels.

Le dernier rapport d'Intel Security, intitulé 'McAfee Labs Threats Report : June 2016', détaille la tendance de la collusion des applications mobiles, en expliquant comment les cybercriminels manipulent les applications mobiles pour orchestrer des attaques contre les propriétaires de smartphones.

Ce type de comportement a été observé par le McAfee Labs d'Intel Security dans plus de 5 000 versions des 21 applications étudiées, destinées au grand public, tels que le streaming vidéo, la surveillance santé, la planification de voyage, etc. Le constat est alarmant : l'échec des utilisateurs à faire régulièrement des mises à jour essentielles de leurs applications augmente le risque de détournement des smartphones par les cybercriminels à travers les anciennes versions des applis.

Considérée depuis plusieurs années comme une menace théorique, la collusion des applications mobiles tire parti des capacités de communication inter-applicatives inhérentes aux systèmes d'exploitation mobiles. Ces systèmes d'exploitation intègrent de nombreuses méthodes permettant d'isoler des applications au sein de sandbox, de limiter leurs capacités et de contrôler les autorisations à un niveau granulaire. Malheureusement, les plateformes mobiles comprennent également des protocoles documentés permettant aux applications de communiquer entre elles à travers les frontières des sandbox. Dans ce cadre, la collusion des applications peut se servir des capacités de communication inter-applicatives à des fins malveillantes.

Trois types de menaces qui peuvent résulter de la collusion des applications mobiles

Le vol d'informations : une application avec un accès à des informations sensibles ou confidentielles collabore volontairement ou involontairement avec une ou plusieurs autres applications pour envoyer des informations en dehors des limites du dispositif/matériel. Le vol d'argent : une application envoie des informations à une autre qui peut exécuter des transactions financières ou faire un appel API pour parvenir à des objectifs malveillants similaires. L'abus de

services : une application contrôle un service système et reçoit des informations ou des commandes à partir d'une ou plusieurs autres applications pour orchestrer une variété d'activités malveillantes.

La collusion applicative mobile requière au moins deux applications pouvant communiquer entre elles. D'un côté, une application qui dispose de la permission d'accéder à une information ou à un service restreint et de l'autre côté, une application sans cette autorisation, mais qui elle bénéficie d'un accès extérieur au dispositif. Les deux applications peuvent potentiellement exposer le smartphone au risque d'une collusion, que ce soit volontairement ou involontairement suite à une fuite de données accidentelle ou à une inclusion d'un kit de développement de logiciels malveillants ou d'une bibliothèque de malwares. Ces applications peuvent utiliser un espace partagé (fichiers lisibles par tous) pour échanger des informations sur les privilèges accordés et déterminer lequel est positionné de manière optimale pour servir de point d'entrée aux commandes à distance.

« L'amélioration des méthodes de détection entraîne les cybercriminels à redoubler d'efforts en matière de fraude », déclare Vincent Weafer, Vice-Président du McAfee Labs d'Intel Security. « Il n'est pas surprenant de voir qu'ils ont développés de nouvelles ruses pour déjouer la sécurité mobile avec de nouvelles menaces qui tentent de se cacher à la vue des utilisateurs. Notre objectif est de rendre l'ancrage des applications malveillantes au sein des appareils personnels plus difficile. Cela passe notamment par le développement d'outils et de techniques plus intelligents en mesure de détecter la collusion des applications mobiles. »

Le rapport 'McAfee Labs Threats Report : June 2016' s'inscrit dans une démarche proactive visant à développer de nouveaux outils et à automatiser les outils existants pour détecter toute collusion inhérente aux applications mobiles. Une fois identifiée, cette nouvelle typologie de menace peut être bloquée en s'appuyant sur des technologies de sécurité mobile. Afin de minimiser le risque et l'impact de la collusion, l'étude encourage les utilisateurs à adopter une approche plus consciencieuse. Cela implique notamment que l'usager se soucie de télécharger des applications uniquement depuis des sources fiables, en évitant celles intégrant de la publicité, et surtout de maintenir le système d'exploitation et le logiciel applicatif à jour.

Les principales tendances recensées au 1er trimestre en matière de menaces

Le nombre de nouveaux échantillons de ransomwares a augmenté de 24 % ce trimestre en raison de l'arrivée continue de nouveaux cybercriminels peu qualifiés dans ce domaine. Cette tendance est le résultat de l'adoption généralisée des kits d'exploitation pour le déploiement de logiciels malveillants.

Mobile. Les nouveaux échantillons de logiciels malveillants sur mobile ont augmenté de 17 % sur le trimestre par rapport au trimestre précédent. En un an, le nombre d'échantillons de logiciels malveillants sur mobiles a augmenté de 113 %, à raison d'une hausse de 23 % d'un trimestre à l'autre.

Mac OS malware. Les logiciels malveillants ciblant l'OS de Mac ont augmenté rapidement au premier trimestre, principalement en raison d'une augmentation de l'adware VSearch. Bien que le nombre absolu d'échantillons à destination de Mac OS demeure encore faible, son volume a augmenté de 68 % par rapport au trimestre précédent et de 559 % en un an.

Macro malware. Cette menace poursuit la croissance amorcée en 2015, avec une augmentation de 42 % par rapport au trimestre passé. Une nouvelle version de macro malware continue d'attaquer les réseaux d'entreprise principalement via des campagnes de spams sophistiquées qui tirent profit de l'information recueillie grâce à l'ingénierie sociale pour paraître légitime.

Gamut botnet. Le botnet Gamut s'est avéré être le botnet de spam le plus productif au premier trimestre, augmentant son volume de près de 50 %. Les campagnes de spam les plus courantes font l'éloge de solutions miracles pour devenir riche ou pour perdre du poids rapidement. Kelihos, le botnet le plus prolifique au cours du dernier trimestre 2015 est relayé à la quatrième place au premier trimestre 2016.

Le cheval de Troie : Pinkslipbot. Également connu sous le nom Qakbot, Akbot ou QBOT, ce cheval de Troie, lancé en 2007, fait partie des logiciels malveillants les plus nuisibles en mesure de subtiliser des informations d'identification bancaire, des mots de passe, des mails et des certificats numériques. Il a fait son retour en 2015 renforcé de fonctionnalités de contre-analyse et de capacités de chiffrement multicouches lui permettant de contrecarrer les efforts des chercheurs pour le disséquer et l'annihiler. Le rapport précise également son mécanisme d'exfiltration des données ainsi que sa capacité de mise à jour automatique.

Chapitre 12 : La sécurité des contenus

a. La sécurité dans un monde en clair

Pour protéger les objets nomades intangibles, les techniques cryptographiques permettent d'assurer leur sécurité, de leur faire franchir les régions hostiles sans dommage tout au long de leur pérégrination par le chiffrement des objets et par des protocoles cryptographiques pour leurs déplacements. Mais tôt ou tard, ces objets doivent être vus, entendus, lus ou exécutés en clair. Ils sont alors à la merci de leur utilisateur (copie pirate, falsification, détournement). Une solution pour réduire les vulnérabilités des objets mobiles est de leur laisser transporter eux-mêmes leur sécurité, par exemple en les marquant. Si cette marque est perceptible (étiquette, code barre, logo), il est relativement aisé d'ôter cette étiquette et de la substituer pour usurper l'identification de cet objet, même si cette étiquette est signée électroniquement. Si cette marque est indécelable et intimement fondue dans le corps de l'objet, il est plus difficile de l'arracher ou de l'effacer.

C'est le but des techniques de tatouage qui consistent à incruster un message clandestin dans le contenu (syntaxique ou sémantique) même de l'objet numérique. Cette greffe doit posséder de bonnes propriétés de robustesse et résister à différentes menaces de lessivage. Une infrastructure minimale est indispensable pour instiller la confiance dans ces univers numériques mobiles. Des entités (notaire numérique, tierce partie de confiance) vont établir une cartographie de la confiance qui permettra de faire appliquer une politique de sécurité. En effet, le code mobile ou les peuples d'agents mobiles intelligents circulant dans Internet pour le compte d'un usager ne sont pas protégés s'ils ne rendent pas compte à des entités de confiance, situées à des endroits stratégiques.

b. Le tatouage : une marque pour attester sa propriété

Le mot stéganographie signifie « écriture cachée ». La stéganographie est l'art de dissimuler intimement un message clandestin dans le corps d'un autre message, en général de caractère anodin, de sorte que la présence même du message secret en soit cachée. Le mot tatouage (watermarking), désigne une technique stéganographique, qui incruste électroniquement dans une œuvre, un message clandestin.

Ce court message subliminal est inséré de manière robuste (souvent par redondance), indécelable par les organes des sens humains ou par une machine automatique et indélébile, dans toute l'étendue du document. Il sert à étiqueter la propriété de l'auteur ou il peut être exploité à des fins de lecture sous-jacente parallèle par une machine annexe de façon que cette empreinte invisible ne gêne pas une lecture standard. Les mécanismes de tatouage reposent sur des approches multiples selon le type de support et selon les contraintes imposées pour remplir l'objectif de sécurité souhaité.

Une méthode de tatouage englobe des composantes de communication numérique, de traitement du signal, de cryptographie et de capacités physiologiques. Le tatouage est une technique de dissuasion : si la politique de sécurité consiste à prévenir les attaquants potentiels que les images sont tatouées, le pirate peut être découragé de tenter de dérober les œuvres.

Encore faut-il, quand on dissuade, que la riposte soit crédible, c'est-à-dire que l'on puisse effectivement détecter et tracer les œuvres tatouées. Les applications du marquage et du traçage sont nombreuses : contrôle de l'origine (IPR), du contenu, de la destination (DRM) pour la propriété intellectuelle, pour le filtrage, pour l'indexation de contenu, pour la mesure objective (facturation, surveillance).

La supervision d'objets répartis mobiles peut être aussi envisagée à travers ces marques, dans un contexte de hétérogènes. Le tatouage n'est pas encore parvenu à un stade de déploiement industriel. L'absence de standards et la multiplicité des procédés ne facilitent pas sa dissémination. La stéganographie ne protège pas a priori les objets numériques, elle assure seulement leur sécurité dans l'obscurité. Néanmoins, la stéganographie risque de prendre de l'importance dans l'avenir, car les objets qui navigueront, seront de plus en plus exploités par

de multiples utilisateurs qui manipuleront ces objets en clair.

Chapitre 13 : Le cas du ransomware

a. Comprendre ce qu'est le ransomware

Véritable fléau de ce début de 21e siècle, le ransomware a tendance à se développer d'une manière exponentielle, notamment ces dernières années. Il est vrai que les cybercriminels qui utilisent cette méthode arrivent à gagner beaucoup d'argent. En effet, rien que pour le premier trimestre 2016, le FBI a estimé à 209 millions $ la rançon payée par la police aux hackers qui ont mis au point ces logiciels. Pour ceux qui ne savent pas ce qu'est le ransomware, il s'agit de logiciels informatiques malveillants conçus dans le but de bloquer et de crypter les données contenues dans l'ordinateur de la personne ou de l'entreprise cible. De cette façon, cette dernière ne peut y accéder et par conséquent n'est pas en mesure d'utiliser sa machine.

Afin de pouvoir se servir de nouveau de son ordinateur, elle devra payer une rançon qui s'élève en moyenne entre 200 et 500 € s'il s'agit d'un particulier. Mais ces dernières années, les hackers s'en prennent de plus en plus aux entreprises et institutions qui, par définition, peuvent verser une rançon beaucoup plus importante. Ce qui, au final, encourage les pirates informatiques à développer d'autres ransomwares qui sont également appelés « rançongiciel » en français. C'est le cas notamment de ces logiciels de rançon qui s'infiltrent sournoisement dans les systèmes des ordinateurs par l'intermédiaire des comptes des médias sociaux. Il s'agit en particulier de LinkedIn, de Skype, de Facebook ou encore de Twitter.

Des nombreux sites où trouver des ransomwares

Jusqu'à présent, la sécurité de messagerie représente un des moyens de se défendre filtrage logiciel anti-phishing et anti-hameçonnage. Ce qui constitue une source de profit plus qu'intéressante pour de nombreux hackers dans le monde. Et d'ailleurs, il existe un certain nombre de sites qui proposent à leurs visiteurs de créer des logiciels de rançon. C'est le cas par exemple de Tox qui offre des rançongiciels gratuits et qui permet même aux pirates informatiques de suivre sur un tableau récapitulatif le nombre d'infections et de rançons versées par le biais de ce logiciel. La victime est, de plus, autorisée à payer la rançon en Bitcoin directement sur la plateforme qui prélève tout de même au passage une commission de 30 %.

Aujourd'hui, les spécialistes ont pu mettre un nom sur un certain nombre de ces

ransomwares. Les plus connus sont CryptoWall, CryptoLocker, Reveton, Ransoc, ou encore Petya. Mais jusqu'à aujourd'hui, les systèmes de défense traditionnels en matière de cybersécurité affichent un faible taux d'efficacité contre ces logiciels de rançon. Il existe cependant diverses solutions des terminaux de dernière génération qui arrivent à détecter, atténuer, voire arrêter ces rançongiciels. En effet, elles délaissent les signatures statiques pour se tourner vers la surveillance basée sur des algorithmes sophistiqués et le comportement. D'autre part, les entreprises sont également de plus en plus.

b. Votre ordinateur est pris en otage

Sur le marché mondial des virus informatiques, les ransomwares prospèrent depuis deux ans. Ils permettent à un pirate de crypter toutes les données d'une entreprise et d'exiger une rançon en échange de la clé de déchiffrage. Hackers, policiers et experts en sécurité se sont lancés dans une passionnante course poursuite.

Nicolas Guyamier n'est pas près d'oublier le 27 avril 2016. Aux environs de midi, alors qu'il est tranquillement installé à son bureau, ce patron d'une PME familiale de transport voit soudain son ordinateur s'éteindre puis se rallumer. Et se lancer ensuite dans un étrange ballet digital. «Tous les fichiers du serveur défilaient sous mes yeux en modifiant, les uns après les autres, leur extension. De .doc ou .xls, ils passaient en.locky." Le jeune chef d'entreprise ne met pas longtemps à comprendre qu'il est victime d'un ransomware: «J'avais déjà entendu parler de ces logiciels malveillants cryptant les données contenues sur un disque dur ou un serveur et proposant ensuite à la victime de les déverrouiller contre rançon, mais je n'aurais jamais imaginé que ça tomberait un jour sur moi.»

Décontenancé, Nicolas Guyamier cherche à joindre son conseil en informatique. Lorsqu'il l'a finalement en ligne, celui-ci lui intime d'éteindre tous les postes de travail, seul moyen d'arrêter la propagation du malware (logiciel malveillant). Mais le virus a déjà compromis une partie de la mémoire de l'entreprise. Pour récupérer ses données, le patron est sommé de payer 5000 euros. En bitcoins, la monnaie virtuelle. Tant la police que les spécialistes en informatique consultés lui déconseillent de céder au chantage. Même s'il s'exécute, il n'est pas certain de récupérer la clef de décryptage, lui assure-t-on. Nicolas Guyamier se range à l'avis des experts et refuse de payer. Au final, l'attaque lui aura coûté deux jours de perte d'exploitation, le temps que le système informatique soit restauré. Et, surtout, plus d'un tiers de ses fichiers: «Aujourd'hui, je ne peux plus, par exemple, me reporter aux documents de mes bilans passés car... je ne les possède plus.»

Depuis sa mésaventure, Nicolas Guyamier a découvert que beaucoup d'autres chefs d'entreprise ont été victimes d'une attaque similaire. Les crypto-ransomwares, ou «rançongiciels de cryptage» en français, ont proliféré ces deux dernières années, devenant l'une des familles de malware les plus en vogue.

Selon l'éditeur japonais de logiciels antivirus Trend Micro, plus de 40% des entreprises européennes auraient été infectées par l'un de ces programmes au cours des vingt-quatre derniers mois. Il faut dire que son confrère russe Kaspersky a recensé en 2016 une attaque toutes les... 40 secondes. La grande majorité est bloquée par les barrières de protection antivirus. Mais les pirates excellent à repérer les failles des systèmes.

Le plus souvent, le malware se propage par l'intermédiaire d'un e-mail contenant une pièce jointe infectée sur laquelle clique le destinataire. Celui-ci se méfie d'autant moins que l'expéditeur, dont on a piraté le compte ou copié le logo, est souvent très plausible: prestataire de services, banque, cabinet d'avocats... En général, la pièce jointe ne contient pas de virus, elle met en contact avec un serveur extérieur qui pilote l'attaque. Du particulier au grand groupe, en passant par les PME et TPE, aucun poste informatique relié à Internet n'est à l'abri. Le procédé du rançongiciel n'est pas nouveau. Mais auparavant, les pirates n'avaient pas recours au cryptage de données. Le plus souvent, la victime voyait la page d'accueil de son ordinateur bloquée avec un message estampillé «gendarmerie nationale» l'accusant d'avoir surfé sur des sites illicites et lui intimant de payer une amende pour déverrouiller sa machine. Le cryptage des fichiers est apparu vers 2014, quand le rendement des virus dits «gendarmerie" a commencé à baisser.

Rançonneurs malins

Ce nouveau mode opératoire permet de toucher beaucoup plus massivement les entreprises. Comme l'accès à leurs données est évidemment primordial, les pirates réalisent des «scores" très élevés. D'après Trend Micro, les plus promptes à payer sont les anglaises (65%) et les allemandes (60%), contre «seulement» 17% pour les françaises. «Les entreprises sont d'autant plus tentées de céder que les cybercriminels ont «l'intelligence» de n'exiger que de petits montants», explique Loïc Guézo, responsable de la cybersécurité chez Trend Micro. L'éditeur estime à 638 euros la rançon moyenne pour la France: les pirates capitalisent sur l'effet de masse. Ils profitent du développement du système de paiement par bitcoin pour assurer leur anonymat. D'après le groupe de cybersécurité canadien Herjavec, le montant total des rançons aurait dépassé le milliard de dollars dans le monde en 2016.

Très rentable, le système ne cesse d'attirer de nouveaux pirates. D'autant qu'il n'y a plus vraiment besoin d'être un geek pour se lancer dans le «métier»: on peut se

procurer assez facilement un kit d'attaque sur le Dark Web, Internet parallèle où prospèrent toutes sortes de commerces illicites (voir encadré ci-dessous). Connus sous les patronymes de Locky, Odin, Cerber, Mischa... les crypto-ransomwares y sont de vrais hits commerciaux. Kaspersky en a recensé l'an dernier 62 nouvelles versions.

«Aujourd'hui sur ce secteur, on fait face à trois grandes typologies de cybercriminels, détaille Tanguy de Coatpont, directeur général de Kaspersky. Ceux qui ont les compétences pour créer de toutes pièces leur propre logiciel et lancer leurs attaques eux-mêmes. Ceux qui achètent des bouts de code en vente sur le Dark Web pour fabriquer des déclinaisons de logiciels existants et passer à l'action. Et ceux, sans compétences très pointues, qui préfèrent payer des droits d'utilisation sur des plates-formes capables de leur fournir une prestation clefs en main, contre un pourcentage sur les rançons versées.»

Baptisé «ransomware as a service» ce dernier modèle permet au gestionnaire de la plate-forme de démultiplier les attaques tout en prenant moins de risques. Par sa relative simplicité, il a aussi ouvert le marché à une population de malfrats beaucoup plus vaste. Entre ces groupes de cybercriminels, la compétition est féroce. «Il n'est pas rare que les plates-formes s'attaquent les unes les autres pour s'empêcher de fonctionner ou se voler des données et casser ainsi leur réputation», précise Loïc Guézo.

Leur «réputation»? Oui. «Les promoteurs de ces plates-formes savent qu'ils doivent établir un degré relatif de confiance avec la victime pour qu'elle effectue son paiement. Certains vont jusqu'à proposer un «chat» d'assistance et même des essais gratuits pour le déchiffrement", pointe Sean Sullivan, security advisor chez F-Secure, autre éditeur de solutions antivirus. Pour mieux comprendre la psychologie des criminels, cet éditeur n'a pas hésité à infecter volontairement des ordinateurs isolés afin d'entrer en contact avec des extorqueurs. Surprise: les trois quarts ont accepté de revoir la rançon à la baisse, de près de 30% en moyenne. Récemment, on a même appris que les opérateurs du ransomware Popcorn Time proposent à la victime, en lieu et place de la rançon de 1 bitcoin (plus de 1000 euros au cours actuel), d'envoyer un lien infecté à tous les destinataires de son carnet d'adresses. Il suffit que deux de ses contacts cèdent au chantage pour qu'on lui livre la clef de décryptage – gratuitement.

Les malwares s'adaptent sans arrêt

Pourquoi les logiciels antivirus n'arrivent-ils pas à bloquer ces intrusions? «De plus en plus sophistiqués, les malwares apprennent à s'adapter aux systèmes de défense qui leur sont opposés", analyse Olivier Ligneul, responsable de la sécurité des systèmes d'information d'EDF et vice-président du Cesin (Club des experts de la sécurité de l'information et du numérique). Ainsi, lorsqu'ils ont compris que leurs virus étaient détectés via leur «signature informatique», les hackers en ont mis au point de nouveaux, capables d'en changer à la volée. Leurs adversaires ont riposté avec un dispositif «d'analyse comportementale»: le système informatique exécute au préalable la pièce jointe dans un environnement virtuel pour voir si elle agit de manière suspecte, auquel cas l'utilisateur est prévenu du danger. Mais ces outils dits «bac à sable» sont déjà dépassés car les malwares les plus récents ont appris à retarder l'exécution de leurs méfaits s'ils détectent un test virtuel.

Bref, l'attaquant réussit toujours à garder un petit temps d'avance. Même pour les entreprises les mieux préparées, la protection à 100% n'existe pas. Rares sont celles qui reconnaissent publiquement être tombées dans les filets des pirates. Mais les exemples connus font froid dans le dos, comme ces hôpitaux qui ont été attaqués en 2016. La série a commencé en début d'année au Hollywood Medical Presbyterian Center, qui a choisi de régler 17000 dollars pour récupérer ses données. Le Kansas Heart Hospital de Whichita a eu moins de chance. Son rançonneur, après le versement de la somme demandée, n'a pas livré la clé de déchiffrement mais a réclamé une rallonge que la direction a, dès lors, refusé de payer, et préféré assumer des perturbations dans son fonctionnement. Une attitude choisie d'emblée par la Northern Lincolnshire and Goole NHS Foundation Trust, fiducie qui gère trois hôpitaux en Angleterre. Mais les conséquences furent lourdes: des centaines d'opérations annulées, le temps de restaurer le système.

Même résolution, il y a quelques mois, à la compagnie de transports municipaux de San Francisco. Le samedi 26 novembre, les usagers ont eu la surprise de voir s'afficher sur un tiers des distributeurs de tickets un message peu orthodoxe: «Vous avez été piratés, toutes les données ont été cryptées. Pour obtenir la clef de déchiffrement contacter cryptom27@ yandex.com.» L'entreprise a tenu bon mais a dû se résoudre à faire voyager gratuitement tous ses passagers pendant une journée entière. Ironie du sort, le cybercriminel s'est lui-même fait pirater par un «hacker éthique» - un pirate rangé du bon côté de la force (voir encadré ci-contre). On a pu ainsi découvrir qu'il était de nationalité iranienne et qu'il n'en était pas, loin s'en faut, à son premier méfait.

Les entreprises les plus vulnérables sont sans doute les PME et TPE. Pas toujours pressées d'installer les mises à jour de leurs applications, moins réactives, elles sont devenues une cible privilégiée des cybercriminels. D'après Kaspersky, elles auraient subi huit fois plus d'attaques au troisième trimestre 2016 qu'au cours de la même période de 2015. Les polices nationales ont de faibles marges d'intervention, car ces attaques sont orchestrées la plupart du temps via des serveurs logés dans des pays peu portés sur la coopération, comme la Chine ou la Russie. «Il arrive parfois que des complices ou des «mules» soient identifiés dans l'Hexagone mais la tête du réseau n'est jamais chez nous», assure la commissaire de police Adeline Champagnat, conseillère à la Délégation ministérielle aux industries de sécurité et en charge de la lutte contre le cybercrime.

La bataille se joue plutôt au niveau d'Europol ou d'Interpol. Ces agences internationales viennent tout juste de démanteler, en collaboration avec le FBI, un gigantesque réseau de cybercriminalité baptisé Avalanche, qui a sévi dans 180 pays et infecté plus d'un demi-million d'ordinateurs, pour un montant d'extorsion évalué à plusieurs centaines de millions d'euros. Ce groupe de cybercriminels fonctionnait comme une vraie entreprise et jonglait avec une panoplie très diversifiée de malwares, dont les crypto-ransomwares Cerber et Teslacrypt. Lorsqu'ils arrivent à mettre la main sur les serveurs des hackers, les policiers collaborent avec des experts en sécurité informatique pour décrypter les malwares.

Depuis l'été 2016 un site baptisé «No more ransom», lancé par Europol, la police néerlandaise et Kaspersky, met à disposition gratuitement les clefs de décryptage d'une dizaine de rançongiciels. Il reste que le meilleur moyen de résister au chantage, c'est de faire des sauvegardes. Pour les entreprises prévoyantes, ce type d'attaque peut se solder à moindres frais, comme l'illustre l'exemple du ministère des Affaires étrangères, qui a dû récemment gérer une alerte sérieuse. «Le poste de travail d'un consulat a été touché avec un mail infecté qui a réussi à passer à travers nos systèmes de détection, raconte son responsable de la sécurité informatique, Michel Cazenave. Mais nous avons réussi à isoler rapidement la machine avant que le malware ne s'attaque au serveur. Au final, nous n'avons perdu que les fichiers relatifs aux quelques heures de travail effectuées depuis la précédente sauvegarde.» Si la pratique des sauvegardes se généralise, les pirates perdront un grand levier…

Pour Tanguy de Coatpont, un autre facteur pourrait ralentir l'essor de ces ransomwares: «La démocratisation de ce type d'attaques a attiré une nouvelle population de pirates à la recherche d'argent facile et peu soucieux de livrer la clef de décryptage. Ce qui devrait détourner à terme les victimes du paiement de la rançon.» Et donc tuer le business! Mais on n'en est pas encore là. D'autant plus qu'un nouveau «marché» est apparu: les smartphones. Et bientôt, sans doute, les objets connectés. Un nouveau et très vaste territoire de jeu pour les hackers. Les chaînes de production industrielle entièrement connectées pourraient être particulièrement visées. De même que les objets de notre vie courante. «Une récente expérience réalisée par deux journalistes américains a démontré qu'on pouvait tout à fait introduire un virus dans une voiture connectée pour prendre le contrôle des freins", indique Loïc Guézo. Qui ne serait pas prêt à payer une rançon pour recouvrer l'usage de son véhicule?

Gentils hackers

Les pirates informatiques peuvent se faire «éthiques". Baptisés «White Hats» pour les distinguer des méchants «Black Hats», ils forcent eux aussi les défenses des systèmes informatiques des entreprises, mais sur invitation et contre rémunération. Leurs tentatives d'intrusion se font dans un cadre légal. Les donneurs d'ordre cherchent par ce biais à tester la vulnérabilité de leurs nouveaux programmes. Aux États-Unis, la pratique est très répandue: de grands groupes comme Apple, Twitter, Facebook, Netflix, Airbnb ou Amazon y ont souvent recours. En Europe, le système commence à se développer. En France, des start-up comme Yogosha ou Bounty Factory proposent aux entreprises de leur constituer un «commando» de White Hats de confiance, pour évaluer leurs défenses. Ces gentils hackers sont payés «au résultat", c'est-à-dire seulement s'ils identifient des failles.

Des virus en vente libre sur le Dark Web

Ce n'est pas très connu, mais le réseau sur lequel on surfe tous les jours n'indexe qu'une petite partie du Web. Son protocole de fonctionnement «http» ne donne notamment pas accès aux données des intranets d'entreprises, du cloud ou des boîtes mails. Au sein du Deep Web, où l'on ne peut évoluer avec Chrome ou Internet Explorer, on trouve des réseaux cryptés, qui forment ce que l'on nomme le Dark Web. Pour s'y brancher, il faut télécharger un navigateur ou un programme ad hoc. Le plus connu d'entre eux s'appelle Tor. Ces outils ont été créés pour garantir un total anonymat aux internautes. Avec eux, impossible de

remonter jusqu'à l'utilisateur. Les manifestants des Printemps arabes les ont beaucoup utilisés pour se protéger de la répression policière. Sur le Dark Web, on peut aussi acheter des armes, de la drogue et des virus informatiques. Les polices s'efforcent d'infiltrer ces réseaux, mais l'anonymat des échanges complique beaucoup les opérations.

c. Les ransomwares sont-ils rentables pour les hackers ?

Malgré l'ampleur sans précédent de leurs dégâts, WannaCrypt et NotPetya engendrent des revenus limités. Qu'ont à gagner leurs concepteurs ?

L'attaque

Une Mercedes grise quitte l'avenue Solomienska pour filer vers le centre de Kiev par la rue Mekhaniztoriv. À 8 h 14, ce mardi 27 juin 2017, la circulation est dense dans la capitale ukrainienne. Alors que le véhicule termine son virage, il est soudain pulvérisé à plusieurs dizaines de mètres à la ronde par une violente explosion. Des débris retombent comme des météorites sur la chaussée. « La scène du crime laisse à penser qu'il s'agit d'un acte de terrorisme planifié », déclare le porte-parole du ministère de l'Intérieur, Artem Shevchenko, quelques heures plus tard. Une thèse confortée par le profil de la victime.

Tué dans l'explosion, Maksim Shapoval travaillait pour les services de renseignement ukrainien. À ce titre, il a pris part aux combats contre les séparatistes du Donbass et leurs parrains russes, dans l'est du pays. Ajouté à l'annexion de la Crimée, au printemps 2014, ce conflit donne à l'ancienne république soviétique une raison de suspecter Moscou. En fait de relations diplomatiques, les deux États n'échangent plus que des accusations.

Quand, quelques heures après l'attentat, une série de sociétés ukrainiennes a été « frappée par un virus », d'après le gouvernement, les regards se sont à nouveau tournés vers l'est. Par l'intermédiaire d'un logiciel de comptabilité national, MEDoc, l'attaque informatique s'est répandue dans les systèmes de l'administration, de compagnies productrices d'énergie, d'aéroports et même de supermarchés. Elle a aussi affecté, entre autres, le transporteur maritime danois Maersk, le réseau britannique d'agences publicitaires WPP, les bureaux allemands de Nivea, l'entreprise pharmaceutique américaine Merck et le Français Saint-Gobain. Sur chaque ordinateur est apparu un même message annonçant que le chiffrement de données les rendaient inaccessibles, sauf à payer une rançon d'environ 300 dollars.

Baptisé ransomware (ou rançongiciel), ce type de programme malveillant est une arme financière redoutable. « Du point de vue de l'internaute, un nouveau disque dur coûterait environ 400 dollars alors que les hackers demandent entre 100 et

300 », explique Hemanshu Nigam. « Il vaut donc mieux les payer et récupérer ses informations que de devoir tout recommencer. » Fondateur de SSP Blue, la plus importante société de conseil en sécurité numérique au monde, Hemanshu Nigam souffle à l'oreille des grandes entreprises comme des gouvernements. Il a déjà œuvré auprès de Disney Interactive Studios, des Nations Unies et de l'administration Obama.

Mais cette fois, régler la note aurait été vain, prévient le hacker Matt Suiche, fondateur de la société de cybersécurité Comae Technologies. D'abord présenté comme une nouvelle version de Petya, un logiciel diffusé en 2016, l'infection « est un wiper et non un ransomware », recadre-t-il. « Son but est de nuire, pas de gagner de l'argent. » Au lieu d'être chiffrées et donc récupérables, les données sont simplement supprimées, analyse-t-il. S'il est encore souvent appelé Petya, le virus a été renommé « NotPetya ».

L'argent ne serait donc pas la cause du sinistre. « C'est arrivé au moment où une série d'incidents a eu lieu, dont l'assassinat d'un agent de renseignement ukrainien et plusieurs mois après l'attaque informatique contre le système d'alimentation électrique du pays », insiste Matt Suiche. En décembre 2015, trois sociétés de distribution d'énergie ont été la cible de la première cyberattaque réussie contre un réseau de cette importance. La société de cyberespionnage américaine iSight Partners a accusé le groupe de hackers russe Sandworm.

Dans le cas de NotPetya, le centre de cyberdéfense de l'OTAN est persuadé de la responsabilité d'un acteur étatique. « Des cybercriminels ne sont pas derrière cela étant donné que la méthode de collecte de la rançon est rudimentaire. Le montant de la rançon ne couvrirait même pas le coût de l'opération », écrit-il dans un communiqué de presse.

D'après la société de sécurité informatique Kaspersky, la clé délivrée à un internaute pour récupérer ses données n'est d'aucune utilité. Elle est générée de manière aléatoire, ce qui laisse supposer que les hackers sont incapables d'opérer le déchiffrage. L'adresse e-mail à laquelle elle doit être envoyée pour ce faire a de toute manière été supprimée. « Un groupe très organisé avait inventé Petya pour gagner de l'argent », considère Hemanshu Nigam. « Mais je pense qu'un autre groupe s'en est saisi et l'a transformé en une attaque malveillante pour d'autres raisons. Quelqu'un l'a modifié de sorte que vous ne puissiez pas déchiffrer les données même si vous payez. »

En plus de NotPetya, l’Ukraine a aussi été atteinte par un clone de WannaCrypt, un rançongiciel ayant intoxiqué plus de 300 000 ordinateurs en mai 2017. Mais dans un cas comme dans l’autre, « ce n’était pas une attaque directe de la Russie contre l’Ukraine », tempère Nigam. « Si c’était le cas, le gouvernement russe aurait frappé beaucoup plus fort et aurait fait davantage de dégâts. Au vu du profil des victimes, il y avait un désir d’endommager des multinationales. » D’ailleurs, le pétrolier d’État russe Rosneft n’a-t-il pas lui-même été attaqué ?

Comme WannaCryt, NotPetya exploite EternalBlue, un programme développé par la NSA qui lui a échappé. Il permet d’exploiter une faille de sécurité de Windows pour propager une attaque à grande échelle, augmentant la capacité de nuisance des ransomwares. Ce qui explique pourquoi on commence enfin à s’intéresser à un programme vieux de près de trente ans.

PC Cyborg

« Le docteur Popp a été empoisonné. » Ce jour d’avril 1989, le message résonne dans l’aéroport Schipol d’Amsterdam. En transit entre le Kenya et les États-Unis, un passager ne cesse de crier son angoisse aux agents de contrôle. Il l’a même griffonnée sur la valise d’un autre voyageur. Personne n’a empoisonné le biologiste américain Joseph Popp, mais il n’est pas en parfaite santé pour autant. Décrit comme en « état de folie aiguë », l’homme qui parle de lui-même à la troisième personne s’en tire avec une simple fouille. Pour l’instant. Sur la base de l’autocollant « PC Cyborg » trouvé parmi ses affaires, il est arrêté le 2 février 1990 par la police américaine.

Pour tout domicile, PC Cyborg possède une boîte aux lettres au Panama. C’est là qu’avant la création du world wide web, les victimes du premier ransomware de l’histoire devaient envoyer leur argent. Entre le 7 et le 11 décembre 1989, 20 000 personnes ont reçu une enveloppe contenant une disquette de « renseignements introductifs sur le Sida ». Envoyée depuis une société fantôme basée à Londres, la Ketema & Associates, celle-ci donne accès à « un logiciel interactif pour l’éducation à la prévention du Sida ». Ces conseils sont censés pouvoir « sauver la vie » aux patients et associations de patients qui les reçoivent. En réalité, elle contient une autre infection : un programme qui chiffre les données et propose de les restaurer contre une redevance annuelle de 189 dollars.

Pour une part, les destinataires sont des abonnés du magazine anglais PC

Business World. Les autres figurent sur la liste des participants à la quatrième Conférence internationale sur le sida, organisée l'année précédente à Stockholm par l'Organisation mondiale de la santé (OMS). À cause de la disquette envoyée par Joseph Popp, une organisation italienne travaillant sur le sujet perd 20 années de recherches sur une épidémie qui connaît alors un pic inquiétant, le nombre de cas rapporté dépassant 100 000 pour la première fois en 1989. Auteur d'une thèse sur l'évolution à Harvard, Joseph Popp est lui-même engagé dans la lutte contre le sida en tant que chercheur et consultant pour l'OMS au Kenya.

Après son arrestation, le « savant fou » présenté par la presse prétend d'ailleurs qu'il voulait lever des fonds pour aider la recherche indépendante et les associations. Complotiste achevé, il explique que « les gouvernements du tiers monde » dissimulent sciemment à leur population les techniques de protection contre la maladie pour contrôler la croissance démographique. Quant à l'OMS, elle les protégerait de crainte d'avoir inoculé la maladie en Afrique par des vaccinations. Des délires qui valent au scientifique, considéré comme dément, d'être relâché par la justice.

Six ans après la disquette de Popp, les expériences des informaticiens américains Adam L. Young et Moti M. Yung théorisent le rôle que peut exercer la cryptographie dans une attaque par « cryptovirus d'extorsion ». Mais, plutôt que la rançon, les hackers préfèrent souvent se servir à la source. En 1994, le russe Vladimir Levin s'était introduit dans le réseau informatique de la Citybank pour transférer dix millions de dollars sur son compte en banque. Un an plus tard, l'Américain Kevin Mitcnick est arrêté après avoir volé 20 000 numéros de cartes de crédit. Afin d'étudier et contrer la vague de cybercrimes, le FBI crée la National Cyber-Forensics & Training Alliance (NCFTA) en 1997.

Procureur spécialisé dans les crimes sexuels à Los Angeles, Hemanshu Nigam s'intéresse alors à ceux commis contre des enfants et diffusés sur Internet. Cette activité sur le volet pédopornographique de son travail l'amène à intégrer la section des crimes informatique en 1998. C'est aussi l'année où l'ingénieur américain Wei Dai décrit un système électronique de trésorerie anonyme qu'il appelle « b-money » et où l'informaticien Nick Szabo lance le « Bit gold ». Couvrant d'un voile opaque les transferts d'argent sur la Toile, les crypto-monnaies donnent aux hackers la possibilité de toucher des rançons sans être traqués.

Il faut attendre 2006 et la démocratisation des e-mails pour que les ransomwares

fassent parler d'eux. « Nous ne connaissons que ceux qui sont évoqués dans la presse, les plus gros », relativise Hemanshu Nigam. À cette période, le juriste vient de quitter Microsoft où il a travaillé pendant quatre ans au développement des standards de sécurité de plateformes comme Xbox, MSN et Windows. En parallèle, il conseillait les services secrets américains, Interpol et le FBI. Tous s'inquiètent que, cette même année 2006, des internautes retrouvent leurs données prises en otage par les ransomwares.

« C'est un très bon moyen de gagner de l'argent parce que vous réclamez des petites sommes que les gens sont disposés à payer car ils n'ont pas le choix », note Hemanshu Nigam. « Ils ne peuvent pas appeler le FBI ou le gouvernement. S'ils apportent leur ordinateur à un expert, il répondra : "Je ne peux pas régler ça parce que les données sont cryptées, donc payez". Pour finir, ils n'ont pas de système de sauvegarde. Donc ils s'exécutent. » Le procédé est devenu d'autant plus efficace qu'il s'est paré des atours de la vertu. Certains rançongiciels affichent le logo de la police ou d'agences américaines pour demander de payer une amende en règlement d'un délit. En 2012, Reveton utilise par exemple l'image du FBI pour menacer ses cibles.

Au deuxième trimestre 2012, l'éditeur d'anti-virus McAfee indique avoir enregistré 120 000 nouvelles attaques, soit quatre fois plus qu'à la même période l'année d'avant. Parmi les nombreuses crypto-monnaies qui voient le jour, certaines, comme Dash, sont conçues pour garantir un anonymat complet à ses utilisateurs. De plus en plus fréquentes, les tentatives d'attaques par ransomware passent de 3,8 millions en 2015, selon les chiffres de la société de cybersécurité SonicWall, à 698 millions en 2016, une inflation spectaculaire.

La faille

En septembre 2013, les 60 000 habitants d'Alnapa, sur les bords de la mer Noire, profitent de l'été indien. Avec le retour des vacanciers moscovites dans la capitale, la petite station balnéaire russe a retrouvé sa tranquillité. Evgeniy Bogachev goûte l'instant plus qui quiconque. Son ransomware Cryptolocker va bientôt lui rapporter plus de trois millions de dollars. Malgré la rançon d'un montant équivalent promise par le FBI, ce trentenaire aux airs de Dr Evil, le méchant chauve d'Austin Power, peut tranquillement dépenser celles qu'il a récoltées.

Un an plus tard, juste après la découverte d'une clé permettant à ses victimes de

récupérer leur disque dur, une version dérivée de son programme baptisé CryptolockerF fait son apparition. « Ce n'est pas inhabituel », indique Hemanshu Nigam. « Des hackers récupèrent le travail d'un groupe et l'améliorent. » Ce nouveau ransomware atteint surtout l'Australie, à l'instar de son successeur, Torrentlocker. Cryptowall connait aussi plusieurs moutures, dont la troisième, découverte en janvier 2015, aurait extorqué 325 millions de dollars, d'après le groupe de cybersécurité Cyber Threat Alliance. Fusob s'attaque la même année aux smartphones. « Certains ransomwares récents n'utilisent même pas les pièces jointes des e-mails mais profitent de logiciels qui ne sont pas mis à jour », alerte le FBI.

La mise en garde n'a pas empêché une autre agence américaine, la NSA, d'être prise en défaut. Le 13 août 2016, le groupe de hacker Shadow Brokers a placé en vente des programmes d'espionnage qu'il prétend avoir subtilisé à l'Equation Group, une unité de hackers liée à l'organisme de sécurité informatique national. Après que la société de sécurité informatique russe Kaspersky Lab a jugé la falsification des fichiers « hautement improbable », le site The Intercept a confirmé leur authenticité sur la foi des informations détenues par Edward Snowden. Plus grave, en avril 2017, les Shadow Brokers révèlent être en possession d'un malware créé par la NSA, EternalBlue. Pour « protester » contre la présidence Trump, ils éventent son mot de passe. « Nous payons les conséquences du manque de protection de la NSA pour son matériel de hacking », se lamente Hemanshu Nigam.

Parce qu'il exploite une faille de sécurité de Windows, EternalBlue est ce qu'on appelle en jargon informatique un « exploit ». Il ne peut rien contre les internautes qui ont installé les mises à jour de Microsoft mais se propage sur les machines de ceux – nombreux – dont le système d'exploitation est obsolète. Dès le 12 mai 2017, un groupe de hackers s'en sert pour lancer « WannaCrypt », le ransomware le plus dévastateur jamais inventé. Plus de 300 000 ordinateurs dans 150 pays sont touchés dont ceux des services sociaux britanniques, des chemins de fer allemands, du transporteur américain FedEx ou de la compagnie de téléphone espagnole Telefonica. Élaboré en 28 langues différentes, WannaCrypt est capable de chiffrer 179 types de fichiers différents.

Mais les dégâts auraient pu être bien plus importants si ses concepteurs n'avaient pas aussi créé un « kill-switch », c'est-à-dire un nom de domaine contacté par le ransomware avant de s'attaquer aux fichiers de sa cible. Lorsqu'il le découvre, le hacker MalwareTech décide donc d'enregistrer ledit nom de domaine pour

entraver le fonctionnement de WannaCrypt. Par ailleurs, le fait que seules quatre adresses de bitcoin aient été adressées aux victimes pour leur permettre de payer la rançon rend toute identification impossible, remarque Matthew Hickey, chercheur de la société de sécurité londonienne Hacker house. Dès lors, comment les hackers peuvent-ils déchiffrer les fichiers d'une personne ayant versé les 300 dollars de rançon exigés s'ils sont incapables de faire le lien entre le paiement et le payeur ?

Si un déchiffrage est bien réalisé, en conclut le spécialiste de la cybersécurité américain Craig Williams, qui travaille pour Cisco, cela doit passer par un contact direct avec la victime à moins qu'il soit effectué de manière aléatoire pour donner l'illusion à certains que le paiement est suivi d'effet. Sans quoi « le modèle qui fait fonctionner le ransomware ne fonctionne pas », observe-t-il. Cela explique que les 55 000 dollars de gains estimés constituent « un échec pour un ransomware », ajoute Williams. Les hackers ont seulement gagné « de gros dégâts, une très grande publicité, un grand affichage en tant que délinquants et une marge de bénéfices parmi les plus basses qu'on ait jamais vu même pour un ransomware de taille modérée ou petite ».

À en juger par les similitudes qu'il présente avec un programme de 2015, WannaCrypt serait l'œuvre de Lazarus, indique Matt Suiche. Ce groupe de hackers qui aurait des liens avec la Corée du Nord est parvenu à dérober 81 millions de dollars à la Banque nationale du Bangladesh en 2016. « Wannacrypt nous montre qu'une infection de masse d'un ransomware utilisant des cryptomonnaies n'est pas rentable », tranche Matt Suiche, ajoutant qu' « au moins, les hackers nord-coréens vont directement à la banque, ils ne provoquent pas des dommages chez des entreprises innocentes ».

Bien que les opérations WannaCrypt et NotPetya soient loin d'être des succès financiers en comparaison avec les précédents ransomwares, Hemanshu Nigam estime que « les hackers vont améliorer leur système dans les années à venir et mieux le faire fonctionner ». Déjà, « NotPetya n'avait pas de kill-switch à la différence de WannaCrypt », rappelle-t-il. Des progrès sont indispensables afin d'assurer le fonctionnement même de la méthode. « Ça marche comme un business », compare le patron de SSP Blue. « Si vous ne fournissez pas au consommateur ce pour quoi il a payé, il ne vous écoutera pas. Donc je pense que les hackers ont une bonne raison d'améliorer les ransomwares. C'est ce qui va se produire. » Ceux qui utilisent de vieilles versions de Windows sont prévenus.

d. Comment se protéger face aux ransomwares ?

Pour prévenir les menaces liées aux logiciels malveillants qui tentent d'extorquer de l'argent ou tenter de réparer s'il est déjà trop tard, je vous propose ici quelques actions.

Lorsque le ransomware a pris place sur l'ordinateur (ou le smartphone, dans 20% des cas selon Kaspersky) de sa victime il applique un blocage du système ou un chiffrement (cryptage) sur les fichiers et dossiers personnels de l'ordinateur de telle sorte qu'ils deviennent illisibles. Une fois son travail terminé il indique à l'utilisateur piégé un moyen de débloquer l'ordinateur de récupérer ses fichiers, généralement en payant une rançon contre la clé de cryptage qui permettra d'ôter le chiffrement. Le logiciel tente de se faire passer pour une autorité : police, gendarmerie, FBI, lutte contre le téléchargement illégal etc. D'autre exemples dans le sujet du forum sur les ransomware.

L'utilisateur n'a donc d'autres choix que de perdre ses fichiers ou de payer la rançon. Le paiement ne garantit toutefois pas que les moyens permettant la récupération seront effectivement fournis par le pirate. Il est donc conseillé de ne pas payer et de tenter de récupérer quelques fichiers par d'autres moyens.

Comment le malware agit-il ?

Le fonctionnement d'un ransomware est un peu particulier car il doit mener à bien de multiples tâches pour être efficace. La première est probablement la plus importante mais la moins technique : elle consiste à s'introduire sur l'ordinateur d'une victime. Dans certains cas particuliers comme lors de l'attaque Petya/NotPetya/Petrwap les pirates ont utilisé le système de mise à jour d'un logiciel, MEDoc, pour s'introduire ne laissant aucune possibilité aux victimes pour prévenir l'infection.

Plus habituellement les pirates utilisent la ruse pour s'introduire sur l'ordinateur en se servant d'emails piégés (technique du phishing). Ils redirigent l'utilisateur vers un site infecté ou font télécharger une pièce jointe piégée. Une fois sur l'ordinateur, s'ils arrivent à passer le cap de l'antivirus, c'est là que le malware commence à faire son œuvre, parfois en établissant la communication avec un serveur pour récupérer les éléments nécessaires à l'infection.

La suite est toujours la même avec seulement une petite variante. Soit les pirates affichent un message de menace et bloque quelques fonctionnalités, soit le malware chiffre les données personnelles pour les rendre inaccessibles. Un message s'affiche ensuite pour indiquer à l'utilisateur les conditions pour récupérer ses données, généralement via le paiement d'une rançon.

Comment se protéger ?

Il existe plusieurs variantes de ransomware baptisés avec des noms tels que : Wannacrypt, Cryptowall, Cryptolocker, Petya ou Locky etc. Ce dernier est particulièrement virulent selon l'éditeur de solutions de sécurité Kaspersky qui fournit quelques conseils pour éviter de tomber dans le piège des ransomwares.

1. Sauvegarder ses fichiers

Le conseil est valable pour les ransomwares mais aussi pour l'informatique en général. Les disques durs ou autre systèmes de mémoire tout comme les systèmes ne sont pas infaillibles, il convient donc d'avoir ses données importantes (photos, documents etc...) dupliqués à deux endroits différents en tout temps. Dans l'idéal la sauvegarde doit être faite de façon régulière sur un support qui n'est liée à l'appareil à sauvegarder uniquement lors de la copie des fichiers (clé USB, disque dur externe, sauvegarde en ligne...). En effet les ransomwares peuvent également se propager aux supports de stockage connectés à l'appareil infecté.

2. Mettre à jour son système et ses logiciels

Le ransomware, ou plus généralement les malwares, se diffusent en utilisant des failles de logiciels ou des systèmes comme porte d'entrée. C'est ce qui a permis aux pirates de mener la cyberattaque WannaCrypt. Tenez à jour vos systèmes Windows, Mac, Android, iOS ou autres et vérifiez régulièrement que vous utilisez la dernière version de vos logiciels favoris, notamment les navigateurs. Enfin, certains systèmes d'exploitation ou logiciels ne sont plus supportés et ne reçoivent plus de mises à jour de sécurité. C'est le cas notamment de Windows XP qui ne devrait plus être utilisé.

3. Redoubler de prudence avec les pièces jointes

Le système de pièces jointes des courriers électroniques est devenu au fil du

temps un moyen indispensable pour échanger des fichiers mais c'est aussi un des moyens que les pirates utilisent pour diffuser leur logiciel malveillant. Comme on l'a vu avec le cas Locky une pièce jointe annoncée comme étant une facture peut contenir un malware, il convient donc d'éviter d'ouvrir ou d'exécuter des pièces jointes reçues si on a un doute sur le but du message. Demandez confirmation à l'expéditeur si vous n'êtes pas certains que l'envoi est légitime.

4. Utiliser un antivirus à jour

Les logiciels malveillants, virus et autres malwares, évoluent en permanence. Pour cette raison on pourra trouver différentes variantes d'un ransomware. Utiliser un antivirus à jour permet de s'assurer que les dernières signatures de logiciels malveillants sont bien enregistrées et que votre antivirus pourra le reconnaître. Attention toutefois, un fichier téléchargé mais non signalé comme dangereux par l'antivirus ne signifie pas pour autant qu'il est sain.

En cas infection, que faire ?

5. Ne pas payer

Il est tentant de payer si l'on possède les moyens de céder au chantage mais c'est une fausse bonne idée. Tout d'abord rien ne garantit que les pirates vous fourniront la clé qui permettra de déchiffrer vos fichiers ou débloquer votre ordinateur. Ensuite cela encourage ce type d'attaques et la mésaventure pourrait bien se répéter pour vous ou vos proches.

6. Arrêter la propagation

Dès que vous connaissance de l'infection, débranchez les disques externes encore sains pour éviter le chiffrement de vos fichiers encore intacts et isolez l'ordinateur dans votre réseau pour éviter que le logiciel malveillant se propage à d'autres ordinateurs. Éteignez tout simplement l'ordinateur et débranchez-le d'internet.

7. Désinfecter l'ordinateur

Si vous avez éteint l'ordinateur alors que tous les fichiers n'étaient pas encore chiffrés utilisez un CD bootable (un CD Ubuntu par exemple) qui va vous permettre de mettre en sécurité sur un disque externe ou une clé USB ce qui a été

préservé. Utilisez ensuite un autre CD bootable de sécurité comme ceux proposés par les antivirus (exemple avec Comodo ou BitDefender) pour tenter de désinfecter l'ordinateur. Si l'infection ne bloque pas l'ordinateur et que celui-ci est toujours en route et internet accessible, cherchez un outil de désinfection en vous faisant aider éventuellement en demandant de l'aide dans le forum désinfection.

8. Retrouver ses fichiers

Les éditeurs de logiciels et chercheurs spécialisés en sécurité ont mis au point des outils et mis la main sur des clés de cryptage de certains ransomware. Vérifiez avant tout en cherchant sur internet et en demandant conseil dans les forums. Si aucune solution n'existe vous pouvez tenter de récupérer quelques fichiers en cherchant dans les fichiers temporaires ou en utilisant des logiciels de récupération spécialisés : Solutions Locky et autres Ransomware (récupération de quelques fichiers)

Signaler l'attaque aux autorités

Il est peu probable que la gendarmerie ou le commissariat de votre quartier mettre en œuvre des moyens techniques dignes des experts pour analyser votre ordinateur ou tenter d'arrêter les attaquants qui se trouvent généralement à l'étranger. Le signalement ou dépôt de plainte aura toutefois le mérite d'attirer l'attention sur ce fléau très en vogue.

Chapitre 14 : Comment améliorer son hygiène de vie numérique ?

a. Comment protéger sa vie privée sur Internet ?

Rien de plus facile, pour une personne malveillante ou une entreprise intéressée par nos données personnelles, que de nous pister via nos machines numériques. Même si on n'a rien à cacher, mieux vaut ne pas laisser ouvertes les portes et les fenêtres digitales. Petit guide d'hygiène numérique.

Dans le documentaire très remarqué Nothing to Hide (2016) de Marc Meillassoux et Mihaela Gladovic, le jeune artiste Max Thommes, persuadé de n'avoir rien à cacher de sa vie, accepte de laisser « hacker » - espionner - son MacBook, son iPhone et ses applications pendant un mois. Le contenu ne sera même pas analysé, seulement les « métadonnées », les données sur les données : heures de connexion, géolocalisation, objet des mails, fréquences de communication... L'expérience est édifiante, sinon terrifiante quant à la « perspicacité » du logiciel espion. Pour nous, pas besoin de faire l'expérience de Thommes. Tous, de plein gré, par paresse ou à notre insu, nous laissons en permanence derrière nous de multiples traces numériques, pièces d'un puzzle aisé à reconstituer pour dresser de nous un profil digital d'une criante vérité. De quoi satisfaire un espion mal intentionné ou une entreprise décidée à faire son miel de nos données. Car, dans le modèle dominant de publicité sur Internet, celle dite « ciblée », ces informations individuelles ou collectives sont une vraie mine d'or.

Comme on dit dans le marketing, si c'est gratuit, c'est que le produit c'est vous ! Où vous êtes-vous rendu, avec qui avez-vous communiqué et par quel moyen, quels sites Internet avez-vous visités, qu'y avez-vous consulté, acheté ? Il faut bien moins d'un mois pour connaître par le menu notre emploi du temps, nos goûts, nos habitudes, notre cercle social, notre situation financière, nos opinions politiques, nos convictions religieuses, nos orientations sexuelles, nos rencontres... Une journaliste de The Guardian, assidue sur Tinder a réussi - non sans difficultés - à se procurer les données collectées à son sujet depuis quatre ans par l'appli de contact : au total 800 pages d'informations précises, très personnelles et très intimes ! Tinder prévient d'ailleurs, pour qui prend la peine de lire les petits caractères, que ces données peuvent être utilisées pour de la publicité ciblée. Et qu'il ne faut pas penser qu'elles sont en parfaite sécurité ! Alors, n'ai-je vraiment rien à cacher ? « Ce n'est pas un argument recevable, assure Rayna Stamboliyska, auteur du livre "La Face cachée d'Internet" (Larousse, 2017). Nous avons tous et toutes quelque chose à cacher. Cependant,

avoir une vie personnelle et une intimité ne veut pas dire qu'on est un criminel ou qu'on agit comme tel. »

Le problème réside surtout dans le profilage que permet cette accumulation de données et dans ses applications potentielles : évaluer un risque de crédit, calculer une prime d'assurance, etc. Sans compter le danger de voir nos données éparpillées dans la nature à la faveur d'une cyberattaque, comme ce fut le cas récemment pour 143 millions d'Américains suite au piratage de la société Equifax. À l'échelle individuelle, c'est aussi le risque d'être victime d'un virus ou d'autres mésaventures dommageables comme une usurpation d'identité, très souvent synonyme de longues années de galère.

Protéger sa vie privée et ses données personnelles dans le monde digital implique donc d'adopter un certain nombre de précautions. « S'il est quasiment impossible de ne pas laisser fuiter des données, à moins de vivre six pieds sous terre, prévient Zenzla, membre du collectif Café Vie Privée, il est toutefois possible d'en limiter la quantité. » « Pour éviter d'attraper des virus, on se lave les mains. Eh bien, pour éviter une gastro informatique, il y a l'hygiène numérique », image Zenzla, qui prodigue quelques conseils de base. D'abord, choisir des mots de passe solides et uniques en se rappelant que 123456 reste le plus couramment utilisé dans le monde ! Ensuite, mettre à jour régulièrement son système d'exploitation et ses logiciels. Qui n'a jamais cliqué sur « plus tard » alors que son ordinateur lui signalait qu'il était temps de réaliser des mises à jour ? Elles sont pourtant essentielles pour se protéger des virus qui exploitent bien souvent les failles de sécurité non corrigées. Enfin, réaliser régulièrement des sauvegardes de ses fichiers sur des supports déconnectés des réseaux permet de prévenir quelques désagréments.

JE CHOISIS DES MOTS DE PASSE SOLIDES

La Commission nationale de l'informatique et des libertés (CNIL), recommande d'adopter un mot de passe « robuste », capable notamment de résister à un robot qui va mouliner à très haute vitesse toutes les solutions possibles. Pour elle, il doit être formé d'au moins 12 caractères de 4 types différents (minuscules, majuscules, chiffres, caractères spéciaux), ne pas être lié à votre identité et être unique pour chaque service. Cette approche, prônée aux États-Unis par l'Institut national des normes et de la technologie (NIST), a été longtemps le dogme dominant. L'inventeur de ces bonnes pratiques, Bill Burr, les a cependant récemment reniées. Il recommande dorénavant, comme le NIST, d'adopter des

codes longs associant plusieurs mots (longtempsjemesuiscouchedebonneheure) et considère qu'il n'est plus nécessaire de les changer régulièrement - sauf, bien sûr, s'il apparaît qu'ils ont été découverts. Avec la multiplication du nombre de comptes, le problème central est celui de la mémorisation, qui pousse souvent à reprendre la même combinaison, par exemple le bon vieux « prénom + date de naissance »... La solution est d'adopter un gestionnaire de mots de passe. « Nous recommandons KeePass, indique Zenzla. Son algorithme de chiffrement n'a jamais été violé. » Ce logiciel libre est d'ailleurs certifié par l'Agence nationale de la sécurité des systèmes d'information (ANSSI). Enfin, quand la double identification est proposée (mot de passe puis confirmation via votre smartphone, un code envoyé par SMS ou un e-mail), adoptez-la !

JE RÉDUIS MES TRACES NUMÉRIQUES

Première étape, bien choisir son navigateur. La Quadrature du Net, une association de défense des droits et libertés des citoyens sur Internet, préconise d'utiliser Firefox. Développé par la fondation à but non lucratif Mozilla, ce navigateur est libre, c'est-à-dire que son code source peut être librement lu, modifié et partagé. De ce fait, il « offre une garantie de sécurité qu'aucun de ses concurrents les plus populaires ne pourrait offrir », estime la Quadrature du Net sur le site controle-tes-donnees.net. Mais ensuite, quel que soit le navigateur choisi, il est important de le paramétrer correctement. « La plupart des sites Internet embarquent des contenus en provenance d'autres sites : publicités, boutons de partage de réseaux sociaux, etc. Par ce biais, les sites tiers récupèrent des informations sur votre navigation », explique Jérémie Patonnier, chef de projet relations développeurs chez Mozilla. Il est donc conseillé de bloquer les cookies (des petits fichiers enregistrés sur votre disque dur) tiers et de faire en sorte que tous les cookies téléchargés soient effacés automatiquement à chaque fois que vous fermez votre navigateur.

Vous pouvez aller plus loin. « Aujourd'hui, tous les navigateurs ont un système d'extensions qui permet d'augmenter le niveau de raffinement du blocage et la protection contre la fuite de données », souligne Jérémie Patonnier. Parmi les logiciels anti-traceurs les plus connus, on trouve uBlock Origin, Privacy Badger, HTTPS Everywhere, Ghostery ou Disconnect.me. « Utiliser des extensions est le niveau 0 de la paranoïa. Si vous voulez passer au niveau supérieur et être anonyme, utilisez le navigateur Tor », indique Zenzla. Tor Browser est le navigateur, basé sur Firefox, du réseau mondial décentralisé Tor qui anonymise l'origine des connexions.

Deuxième étape : le choix du moteur de recherche. « Beaucoup de nos recherches sont de l'ordre de l'intime et Google est finalement le premier à qui l'on fait part de nos questionnements », fait remarquer Tristan Nitot, directeur produit chez Cozy Cloud et auteur du livre *Surveillance* (C & F Éditions, 2016). Face à l'américain, quasi hégémonique en France, il invite à utiliser de préférence Qwant, un moteur de recherche européen explicitement développé pour protéger la vie privée des utilisateurs et dont le modèle économique repose sur l'affiliation. « Nous ne vous traçons pas, nous ne gardons pas votre adresse IP, nous n'avons aucune information sur qui vous êtes ni sur où vous allez », assure ainsi Éric Léandri, directeur général de Qwant. Il existe aussi des méta-moteurs de recherche, comme DuckDuckGo ou StartPage, qui transmettent votre requête à d'autres moteurs, servant ainsi d'intermédiaire.

JE CHIFFRE LES DOCUMENTS SENSIBLES

« À titre personnel, le chiffrement peut être utile si vous souhaitez conserver des documents confidentiels sur un support qui pourrait être volé », estime la CNIL, rappelant que la confidentialité des documents hébergés dans le cloud n'est pas garantie. Ces données y sont généralement stockées en clair, potentiellement lisibles par tout utilisateur disposant de droits privilégiés sur les serveurs. Plusieurs logiciels gratuits tels que AxCrypt et 7-Zip permettent de chiffrer ses documents de façon assez simple (mais attention, c'est irréversible). Par contre, chiffrer ses mails est relativement complexe. « Sécurité ne rime pas souvent avec facilité. Si vous voulez chiffrer vos mails, vous devrez le faire manuellement. Le meilleur moyen est d'utiliser GPG (GNU Privacy Guard), mais ce n'est pas facile à mettre en œuvre », reconnaît Zenzla. Il existe des services de messagerie chiffrée, comme ProtonMail ou Mailpile, mais le chiffrement automatique ne se fait qu'entre deux boîtes du même fournisseur. En tout cas, gardez à l'esprit qu'expédier un mail, « c'est un peu comme envoyer une carte postale sans enveloppe : les postiers peuvent la lire, même si on se doute bien qu'ils ne le font que très rarement », prévient Tristan Nitot. Ce dernier conseille d'éviter Gmail et, si possible, d'obtenir son propre nom de domaine et sa propre adresse e-mail auprès de sociétés comme Gandi ou OVH.

JE SUIS PRUDENT SUR LES RÉSEAUX SOCIAUX

Nous partageons beaucoup d'informations personnelles de notre plein gré sur les réseaux sociaux. La première chose à faire est donc de bien paramétrer la

confidentialité de son compte. Il faut ensuite prendre certaines précautions. « Évitez de mettre des photos de vos enfants et de dire tout le temps où vous êtes », préconise Zenzla. De son côté, la CNIL recommande de ne pas communiquer sur nos opinions politiques et notre religion. « Quant aux modalités de traitement des données collectées et aux marges de manœuvre d'opt-out. Il est préférable de se référer aux conditions générales du réseau », rappelle Rayna Stamboliyska. La grande majorité des internautes ne prend pas le temps de les lire alors qu'elles sont pourtant très instructives. Si vous ne voulez absolument pas que vos données personnelles soient exploitées à des fins publicitaires, vous pouvez rejoindre Framasphère (framasoft.org), un réseau social affilié au réseau international Diaspora. Il a été développé par l'association Framasoft, qui propose des services en ligne équivalents à ceux des géants américains du numérique mais basés sur des logiciels libres et respectant la vie privée des utilisateurs.

JE ME MÉFIE DE MON SMARTPHONE

Tentez cette petite expérience : téléchargez l'application DataRespect (pour l'instant disponible seulement pour Android) puis cliquez sur le bouton « Faites-moi peur ! » Vous découvrirez alors combien d'applications installées sur votre téléphone peuvent savoir à votre insu où vous êtes, accéder à liste de vos contacts, vos fichiers, votre enregistreur, votre caméra, savoir qui vous appelle, connaître votre activité physique... Le smartphone, de fait, est un véritable mouchard ! Soyez donc vigilant quant aux accès que requiert une application lors de l'installation. « La donnée la plus sensible est la géolocalisation, considère Philippe Michel, directeur général de Magush et créateur de DataRespect. Si j'ai votre géolocalisation, je sais tout de vous. » Il suggère de la désactiver le plus souvent possible.

Sachant que le wifi et le bluetooth peuvent également permettre de géolocaliser, Philippe Michel applique une solution radicale : « Si je vais faire un quelconque examen médical, même si ce n'est pas grave, je laisse mon téléphone à la maison parce que je n'ai pas envie que ma géolocalisation soit récupérée par n'importe qui. Imaginez que cette information tombe entre les mains d'une assurance ou d'une banque... » Pour limiter la collecte de ses données personnelles, Tristan Nitot a de son côté abandonné les smartphones utilisant Android, qu'il qualifie d'« aspirateur à données », au profit de l'iPhone. « Apple a un business model très lucratif - vendre des gadgets très cher en faisant une très grosse marge - qui ne l'oblige pas à avoir recours à la collecte de données personnelles pour faire du

ciblage », explique-t-il. Son seul regret : impossible d'installer des applications libres sur l'iPhone.

JE SUIS VIGILANT AVEC LES OBJETS CONNECTÉS

Trackers d'activité, jouets, assistants vocaux, frigos, interrupteurs... les objets connectés envahissent notre quotidien. « Il ne s'agit pas d'une simple passade, les objets connectés vont devenir un véritable mode de vie, assure Zenzla. Mais leur mot de passe installé par défaut n'est presque jamais changé, c'est souvent admin ou 12345. » Il est donc très facile pour une personne malveillante de s'y connecter. « Il faut absolument choisir tout de suite son propre mot de passe », insiste Zenzla. Soyez par ailleurs conscients que ces objets connectés engrangent énormément d'informations sur vos habitudes et votre mode de vie. Informez-vous donc sur les données personnelles recueillies et l'usage qui en est fait. Pour cela, rien ne vaut l'effort de se plonger dans les interminables conditions générales d'utilisation - les fameuses CGU - et la politique de confidentialité ! Et partir ainsi à la recherche de notre identité perdue.

QUE VA CHANGER LE « RGPD » ?

Le règlement général sur la protection des données personnelles (RGPD) entrera en vigueur le 25 mai 2018 dans toute l'Union européenne. « Les consommateurs verront leur droit à la vie privée renforcé. Leur consentement devra être explicitement recueilli et le profilage sera mieux encadré », salue Rayna Stamboliyska. Le RGPD s'applique à toutes les entreprises qui traitent des données personnelles de citoyens européens, et donc aussi aux géants américains. En prévoyant des sanctions allant jusqu'à 4% du chiffre d'affaires annuel mondial du contrevenant, « ce texte met véritablement la question des données des citoyens à la hauteur des enjeux », juge Olivier Iteanu, auteur du livre Quand le digital défie l'État de droit (Eyrolles, 2016). Reste une inconnue, souligne cet avocat : « Dans les faits, comment les autorités européennes vont-elles pouvoir contrôler la bonne application du RGPD par des entreprises américaines qui détiennent ces données dans leurs infrastructures aux États-Unis ? »

Témoignage de Rayna Stamboliyska

Publié en juin 2017, La Face cachée d’Internet propose de démystifier les mythes qui gravitent autour du cyberespace. Son auteure, Rayna Stamboliyska,

est experte en gestion des risques. Elle a accepté de lever le voile sur quelques outils de défense numérique, pour une meilleure appréhension de la cybersécurité.

Ces dernières semaines, les attaques informatiques ont fait la Une, avec WannaCry et NotPetya. Sont-elles plus fréquentes qu'avant ou simplement plus médiatisées ?

Rayna Stamboliyska : Nous sommes cyber-morts deux fois en deux mois. Attention, il ne s'agit pas de minimiser l'impact de ces crises mais de remettre les choses en contexte : les rançongiciels existaient déjà il y a quelques années mais on en parlait moins. Certaines attaques sont spectaculaires. Quand, le même matin, vous avez Twitter, YouTube, Airbnb qui ne répondent plus, cela sort du périmètre réservé aux spécialistes et cela touche à peu près tout le monde. Donc, beaucoup de gens hors milieux spécialisés voient qu'il y a un problème.

L'Agence de santé britannique a été touchée par le rançongiciel WannaCry parce qu'elle utilisait un système d'exploitation obsolète et faillible (Windows XP).

Ce que montre ce cas est les dysfonctionnements de gouvernance. Le plus souvent, les gens qui s'occupent des aspects techniques ne prennent pas les décisions. Donc vous avez beau répéter à l'envi que la vétusté des systèmes pose des problèmes (par exemple, que depuis cinq ans l'infrastructure de l'hôpital est ouverte à tous les vents sur Internet), on vous répond : « Ce n'est pas grave, jusque-là, il ne s'est rien passé.» Jusqu'au jour où il se passe un problème... Il y a un manque de sensibilisation aux enjeux. Par ailleurs, il faut comprendre la spécificité d'un incident : ce qu'il se passe exactement au moment de l'attaque et l'anticipation des réactions en face, changent constamment. Il faut des compétences particulières pour gérer ce genre de situations correctement, ce n'est pas le cas de toutes les entreprises.

Ce qui est important pour se prémunir contre cela, ce n'est pas tellement de savoir comment une attaque marche techniquement. Les réponses techniques qu'on peut apporter aujourd'hui seront trop vieilles dans deux mois. Ce que l'on doit faire, entre autres, c'est des mises à jour : il s'agit souvent de correctifs de failles découvertes par l'éditeur du logiciel. On est ainsi prémuni contre des choses déjà corrigées (pour rappel, un correctif qui aurait pu éviter la catastrophe WannaCry était disponible 2 mois avant la propagation du rançongiciel).

Plus largement, lorsqu’on souhaite prévenir les problèmes, on fait des modèles de menaces. Ce n’est pas une solution miracle, mais on dort mieux quand on a écarté la plupart des problèmes stupides qui peuvent faire beaucoup de dégâts. Quand vous êtes une institution publique, vous allez être beaucoup plus souvent confrontée au hameçonnage (« phishing »), très souvent de nature crapuleuse, et beaucoup moins souvent à de hackers russes qui veulent faire exploser les centrales nucléaires françaises. Quand vous êtes une TPE/PME, le harponnage (« spearphishing ») et plus largement, l’attaque au président, vous menace beaucoup plus que les hackers russes.

Que préconisez-vous pour que ce genre de négligence se reproduit moins souvent ?

Il faudrait déjà avoir une culture numérique de base : les antivirus, qu'on vend très cher, ne sont pas vraiment efficaces - et cela fait des années qu'ils ne le sont plus. C'est bien d'en avoir, parce que cela protège contre des fichiers vérolés. Mais ce qui est encore mieux, c'est de savoir ce qui pourrait mal se passer et comment le prévenir. Notamment, garder toujours ses logiciels à jour est une obligation. C'est-à-dire ne jamais désactiver Windows Update si votre système d’exploitation est Windows. Idem pour le reste des logiciels que vous utilisez : quand votre navigateur vous annonce que « Des mises à jour sont disponibles, souhaitez-vous les appliquer ? », ne pas vous dire : « J'ai mes vingt onglets, je vais tout perdre. » Non, vous les mettez en favoris, vous faites les mises à jour et vous redémarrez.

De manière générale, vu qu’Internet fait partie de notre quotidien, il faut essayer d'avoir les mêmes réflexes envers sa vie d'internaute qu'envers son comportement dans la rue : quand je traverse, je vais quand même regarder de tous les côtés s'il y a une voiture. Si la voiture est à cinq mètres, je ne vais pas me mettre à traverser parce que les risques que je me fasse renverser ne sont pas négligeables. C'est la même chose sur Internet : de nombreux services que nous utilisons peuvent cacher des menaces ; par exemple, certaines pubs sont vraiment intrusives et récupèrent beaucoup d'informations sur votre navigation web. Donc vous privilégierez un bloqueur de pubs, comme uBlock, plus propre qu'AdBlock Plus qui vend de la pub lui-même.

Quant à la manière de se tenir au courant des différentes astuces, on doit, chacun et chacune, chercher à en savoir davantage sur les différents aspects de notre vie

connectée. On nous parle beaucoup des perturbateurs endocriniens, beaucoup de gens autour de moi sont adhérents de l'UFC-Que choisir et de 60 millions de consommateurs. Cette démarche-là d'éducation personnelle, appliquons-la aussi à notre propre hygiène numérique. Il faut casser cette idée que l'Internet est un espace à part. Non, c'est un espace ou pratiquement tous les humains sont présents, avec leurs interactions, leurs problèmes, leurs activités plus ou moins criminelles ou criminogènes.

La différence est que sur Internet, on peut se voiler la face : si on désactive Windows Update, on ne voit plus les mises à jour, alors que si la voiture est à cinq mètres, on est obligé de la voir.

Oui, sauf qu'à force de ne rien voir et de rater le train numérique, dans cinq ans, quand nos voitures reposeront sur ce genre de systèmes, on aura vraiment l'air malin. Pourquoi ma voiture ne veut pas démarrer ? Parce que tu n'as pas fait les mises à jour et elle ne sait plus comment le faire. Aujourd'hui, les babyphones, les webcams, les grille-pains et autres montres connectées peuvent être touchés par une attaque informatique, et c'est un problème. Cela veut dire que ces objets sont connectés à Internet. Leur commercialisation répond à un besoin client, certes, mais cela ne signifie pas pour autant que la mise sur le marché doit être d’objets non sécurisés. Le jeu ici est bidirectionnel : vous en tant qu’entreprise vous en fichez… tant que vous en tant que client en pâtissez, de cette négligence. La sécurité n’est pas une lubie, mais une question de confiance : dans le langage business, plus vos clients vous font confiance, plus vous gagnez des sous.

Un autre type d'intrusion dans notre vie privée numérique vient aujourd'hui des États eux-mêmes, via leurs agences de renseignement.

Ce genre de risque est plus inquiétant encore que des attaques au rançongiciel, parce que sur ces attaques, on a une prise. Nous n'en avons aucune sur la surveillance généralisée et décidée administrativement. Autrement dit, il faut se rappeler que c’est la dose qui fait le poison : les services font leur boulot… jusqu’à ce que ça dépasse les limites acceptées dans une démocratie. Ce qu’on peut se dire est qu'il y a une radicalisation des gens qui prennent ce type de décisions. Quand on est paranoïaque, si l'on ne procède pas à un reality check de temps à autre, rien ne nous empêche de sombrer dans cette paranoïa. Vous voyez des menaces partout et votre réaction logique va être d'augmenter ce que vous percevez être le niveau de protection. Heureusement, il y a des associations et des défenseurs des droits numériques pour faire faire ce reality check.

Comment fait-on pour ne pas sombrer dans une paranoïa ou dans les effets d'annonces ?

Il faut distinguer le sentiment d'(in)sécurité des conditions matérielles de sécurité. Quand on dit que l'on va contourner les chiffrements pour intercepter les terroristes en devenir et anticiper leurs attaques, le discours visé est : « Ne vous inquiétez pas, nous avons les moyens d'assurer votre sécurité ». Techniquement, ce que j'entends, moi, est que l'ennemi visé ici, c'est les maths et pas le terrorisme - outre le fait que plein de terroristes ne discutent pas en conversations chiffrées. En effet, malgré une médiatisation abusive de ce point, lorsqu'on échange avec des gens et souhaite parvenir à un effet de masse, on ne se cache pas : on utilise des applications avec un élément social facile à mobiliser.

Or, cette hypermédiatisation agit comme un épouvantail. Le souci dans les appels politiques en faveur d'un affaiblissement du chiffrement est qu'en affaiblissant le chiffrement sous prétexte d'intercepter un certain type de communications, on compromet le medium pour justifier l'éventuelle anticipation d'un de ces usages très minoritaires. Cela signifie qu'à terme, si l'on va dans cette voie, tout le monde pourra prétendre être votre banque, donc avoir accès plus ou moins facilement à vos identifiants donc à votre compte.

Dans votre livre, vous préconisez le logiciel libre dans une bonne hygiène numérique, tout en précisant que c'est largement insuffisant.

Le logiciel libre et open source, c'est tout logiciel dont le code est ouvert à tout le monde, donc tout le monde, peut s'en servir, le distribuer, l'étudier, le modifier (certes, cette dernière activité sera plus simple pour ceux qui en ont les capacités techniques). Il y a quelques années, on se transmettait des CD crackés, des contrefaçons. Avec le logiciel libre, cette notion-là n'existe pas : vous n'avez pas de restriction quant à la transmission, la modification et la diffusion. Prenons comme exemple le navigateur web Mozilla Firefox : vous pouvez le télécharger autant de fois que vous le souhaitez, vous n'avez pas à acheter un système d'exploitation dans lequel il sera compris (comme Safari d'Appel ou Internet Explorer/Edge de Microsoft) pour vous en servir.

Il y a un avantage certain à utiliser un système d'exploitation libre et dont le code est ouvert tel qu'Ubuntu plutôt que Windows car, comme le code est ouvert, il est

constamment audité, examiné, modifié, amélioré par de nombreux utilisateurs. Cela ne veut pas dire qu'il n'y a aucune vulnérabilité dans un logiciel libre, mais la correction est rapide et vous avez tout de suite des alertes de sécurité.

Il y a d’autres aspects intéressants notamment dans votre interaction avec la machine. Sur Windows par exemple, si on ne vous restreint pas les permissions, vous êtes automatiquement administrateur de votre machine. Ce qui est un problème, parce que si j'arrive à prendre la main, je suis directement administrateur. Aussi, vous pouvez installer n'importe quoi sans vous poser aucune question. Dans le cas d'un système d'exploitation libre, la machine vous demande : « Êtes-vous sûr de vouloir faire cette opération ? Pour le faire, indiquez votre mot de passe administrateur. » Il y a une étape en plus, qui vous fait réfléchir : ai-je vraiment besoin de ce truc-là ? Par ailleurs, les sources des mises à jour peuvent être éditées par vous-mêmes si vous le voulez (on apprend vite, pas d’inquiétude). L'internaute est davantage responsabilisé, moins infantilisé à aveuglément suivre les décisions de quelqu’un d’autre.

Comment voyez-vous l'avenir concernant la réglementation européenne et française en matière de vie privée sur Internet ?

En novembre, cela fera deux ans que l'on sera sous état d'urgence - un état d'exception - et pourtant cela n'a rien empêché, malheureusement.

On pourrait répondre : cela n'a pas marché parce que l'on n'en a pas fait assez.

A-t-on une étude d'impact ? Qu'est-ce qui n'a pas marché ? Pour moi, il n'y a pas assez de personnes disponibles pour analyser les palanquées de données que les services collectent. De plus, quand les soldats de l'opération Sentinelle sont fatigués, ils loupent des choses, c'est normal. Il y a une dilapidation de moyens dans un mauvais sens.

Rançongiciel (« ransomware » en anglais)

« C'est un logiciel qui va prendre le contrôle de vos données et qui va vous dire : "Si vous voulez les revoir, il faut me payer." Après, il y a différents types : certains chiffrent vos données et vous donnent les clés de déchiffrement après. Vous vous êtes acquitté de la somme demandée - le plus souvent en bitcoin, la monnaie virtuelle - donc tout va bien. D'autres vont effacer des données ou vous

mettre la pression en disant : "Si vous ne me payez pas dans l'heure qui vient, je vais effacer tel répertoire ou tant de gigaoctets de vos photos de vacances..." L'idée est de jouer sur la notion d'urgence. On a aussi vu sur le marché des rançongiciels qui ne chiffraient rien du tout, qui faisaient juste apparaître un écran moche, kitschissime, avec des têtes de mort pixelisées. Pourtant, les gens se faisaient avoir, parce qu'ils étaient tellement stressés qu'ils se débrouillaient pour payer. »

Hameçonnage (« phishing » en anglais)

« Je vais prétendre être un acteur reconnu ou de confiance (EDF, les impôts, etc.) et je vous demande de cliquer ici pour vous connecter sur votre espace personnel ou pour payer vos impôts. L'e-mail a l'air d'émaner vraiment d'EDF ou des impôts. Ce clic va vous amener sur un site où vous allez rentrer vos coordonnées bancaires par exemple et payer un montant, vos impôts ou un excédent quelconque. Sauf que les impôts n'envoient jamais de demandes de paiement par e-mail. Il s'agit d'un fichier qu'on va envoyer en masse, à n'importe qui, de manière pas du tout ciblée. Il y a des palanquées de sites qui existent avec des adresses e-mails, ou alors vous pouvez en récupérer à partir d'une adresse plus ou moins publique - parce que quelqu'un a mal sécurisé son MailChimp [un site d'envoi automatisé de newletters] - ou encore vous achetez juste un fichier auprès de n'importe quelle conférence ou événement pour quelques euros. Vous pouvez aussi faire toutes les variantes d'un nom grâce à un petit script facile à fabriquer. Si cela n'aboutit pas, ce n'est pas grave, cela ne vous a rien coûté, et dans le tas, il y aura des gens qui vont cliquer.

Beaucoup d'institutions, lorsqu'elles veulent faire de la prévention, pèchent dans leur manière de formuler les choses en disant : "N'ouvrez pas des e-mails suspects." Comment puis-je savoir s'il est suspect sans l'ouvrir ? Copier l'habillement d'un site web, c'est trivial. Vous allez avoir un nom de domaine émetteur qui ressemble. L'exemple classique, c'est google.co, gooogle.com, gogle.com pour google.com. Parfois aussi, dans le texte, il y a des caractères particuliers. Mais en fait, on ne va jamais le voir parce que le logiciel de messagerie que la plupart des gens utilisent, qui est Outlook, interprète ces caractères-là. Ce que vous voyez à l’œil, c'est un "e" normal, alors que quand vous le copiez en texte brut, avec un éditeur de texte tel que Notepad, vous voyez qu'il y a des caractères bizarres dedans. Si vous n'êtes pas sûr, il vaut mieux appeler le fournisseur de service en question. Plutôt que de cliquer sur le lien, vous pouvez faire un clic droit, puis le copier dans un éditeur de texte pour

se rendre compte de la tête qu'il a. Par exemple, il n'y a aucune raison qu'EDF vous envoie un lien en format bit.ly [format pour rétrécir une URL]. »

Harponnage (« spearphishing »)

« Là, nous sommes dans une situation très différente du hameçonnage : plutôt que d'avoir une attaque en masse, on va cibler quelques personnes-clés et on va essayer de tout savoir sur elles : avec qui elles discutent et donc à qui sont-elles susceptibles de répondre facilement et sans se poser trop de questions ? Comment ces gens-là discutent entre eux, quels sont les types de blagues qu'ils se font ? Les réseaux sociaux sont parfaits pour cela : en analysant les 2000 derniers tweets de quelqu'un, vous avez un graph social très précis. Le harponnage se prépare vraiment : il faut que vous connaissiez le nom du chien de la secrétaire de la personne visée. Si j'arrive à lui faire croire que je suis légitime pour lui poser les questions que je vais lui poser et qu'elle me donne les réponses, elle peut m'ouvrir des portes dont j'ai besoin. La motivation n'est pas du tout la même que pour le simple hameçonnage : le harponnage prend du temps, et donc de l'argent. Il va plutôt concerner l'espionnage industriel. »

The Onion Router (Tor)

« C'est un logiciel qui rend votre navigation anonyme. Attention : cela signifie que votre fournisseur d'accès ne sait pas sur quels sites vous allez. Toute la communication entre votre ordinateur et le site cible est masquée. Mais si vous utilisez Tor et que vous vous connectez à Facebook, certes votre fournisseur d'accès ne le saura pas mais Facebook saura que c'est vous grâce à vos identifiants de connexion. Quand on parle d'anonymat, il faut toujours se demander par rapport à quoi et à qui.

Le navigateur Tor, qui est un navigateur Firefox modifié, bloque la plupart des trackers [petits programmes qui enregistrent vos données de navigation] initialement présent dans Firefox, Chrome et autres. Il va en plus vous proposer différents "modes parano". Si vous mettez votre fenêtre de navigation en plein écran, par exemple, le "mode très parano" vous enverra un avertissement : "Attention, mettre en plein écran peut renseigner les sites sur lesquels vous allez sur votre résolution d'écran." Il propose aussi des outils qui forcent votre navigation à être la moins faible possible. Pour aller vraiment dans les détails techniques, il faut avoir une connaissance plus avancée, mais si l'on veut seulement utiliser le navigateur Tor, il n'y a besoin d'aucune compétence. »

The Amnesic Incognito Live System (Tails)

« C'est un système d'exploitation au même titre que Windows, Mac ou Ubuntu, sauf que vous ne l'installez pas sur votre ordinateur mais sur une clé USB. Vous l'insérez ensuite dans votre ordinateur et, au lieu de démarrer l'ordinateur sur le disque dur normal (par défaut sur Windows ou Mac), vous lui indiquez que vous voulez qu'il se lance sur Tails, sur la clé USB.

C'est la distribution la plus anonyme possible : toutes les fonctionnalités comme la sauvegarde des mots de passe dans le navigateur sont désactivées, vous ne pouvez rien installer si vous ne définissez pas d'identifiants administrateur au départ, toute la navigation passe par Tor et les VPN [Virtual Private Networks, ou réseau privés virtuels en français]. Si je veux me connecter à mon webmail dans un lieu public, je pars du principe que je ne connais absolument pas la qualité du réseau wifi. Il ne m'appartient pas donc je ne sais pas qui est dessus, donc je ne mettrai jamais mon ordinateur ouvert à ce type de réseau et laisser transiter mes mots de passe sur un wifi inconnu. Je vais démarrer mon ordinateur sur Tails et ma connexion est donc encapsulée dans de nombreuses sécurités. Je peux donc faire transiter mes mots de passe sans que personne ne sache que je suis dans ce café-là et que je me connecte à cet e-mail. »

b. Introduction à Tor et visite du dark web

Tor fait parler de lui dans les médias mais qu'est-ce que c'est et comment ça marche ? Voici un dossier complet pour tout comprendre sur l'outil de navigation anonyme que déteste la NSA.

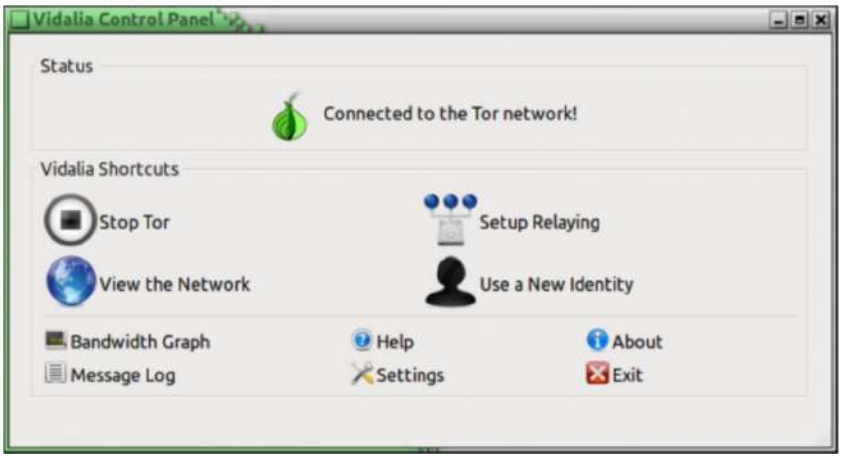
Un clic et votre identité disparaît. Votre connexion devient américaine, française ou indonésienne. Ça y est: vous êtes anonyme. C'est comme cela que fonctionne, en résumé, Tor, un logiciel qui rend votre connexion anonyme. Des gens du monde entier l'utilisent au quotidien pour éviter d'être identifiés par des gouvernements trop intrusifs ou par leurs forces de sécurité.

Mais pas besoin d'être pisté par la CIA ou la NSA pour utiliser Tor. C'est un outil dont tout un chacun peut se servir au quotidien pour naviguer sur le web de façon anonyme et à l'épreuve de tout pistage.

Qu'est-ce que Tor?

Tor est un logiciel qui prend les données qui entrent et sortent via votre connexion Internet et les fait passer à travers un circuit de serveurs répartis dans le monde. Cela permet à votre navigation d'être totalement anonyme.

Le réseau de Tor, auquel n'importe qui peut participer en tant que nœud de connexion ou hub de façon volontaire, compte plus de 4000 machines réparties dans des dizaines de pays du monde. Ce nombre important de hubs garantit l'anonymat et la connectivité pour les utilisateurs de Tor.



Pour faciliter son utilisation, Tor se sert de Vidalia, un utilitaire qui permet d'activer, d'arrêter et de contrôler le fonctionnement de Tor. Il existe une appli similaire pour les téléphones Android baptisée Orbot, ainsi qu'une distribution Linux qui utilise exclusivement Tor.

Linux TailsLa distribution Linux Tails, qui impose l'utilisation de Tor à toutes ses applications

Que signifie Tor?

Le nom Tor n'a pas été choisi en référence au Dieu nordique du tonnerre, mais plutôt en tant qu'acronyme de The Onion Router, "le routeur oignon". L'appellation fait référence à la structure du réseau Tor, qui consiste en plusieurs couches successives de chiffrage, destinées à protéger les données.

À l'origine, le projet Onion Router, financé par le gouvernement des États-Unis, a été développé dans les laboratoires d'investigation de l'armée américaine. Aujourd'hui, Tor reçoit des financements venant de sources diverses, comme des entreprises ou des ONG.

À quelles fins utilise-t-on Tor?

Tor est utilisé pour empêcher qu'une activité sur Internet soit liée à qui en est l'auteur. Tor génère donc de l'anonymat sur le net. Cet anonymat peut être utilisé à des fins très diverses. Des groupes décentralisés comme Anonymous utilisent régulièrement Tor

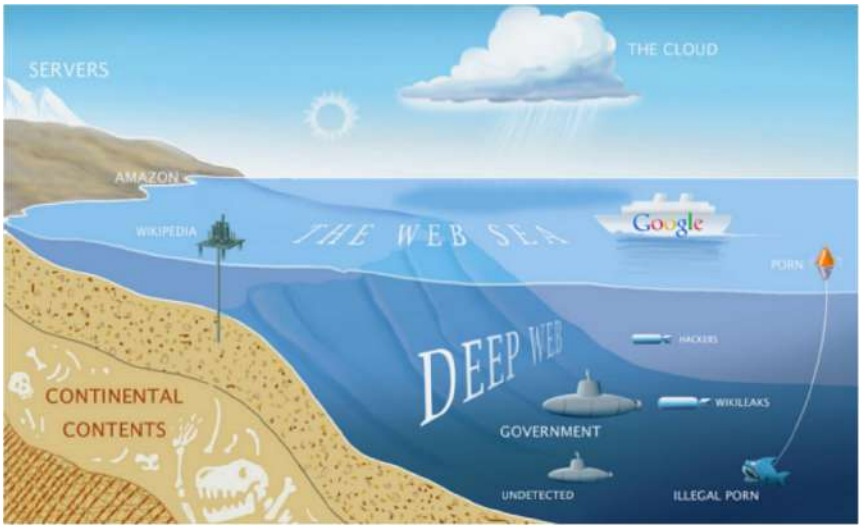
Une utilisation éthique de Tor est défendue par des institutions comme l'EFF (Electronic Frontier Foundation) qui y voit un outil aux services d'individus luttant pour les libertés civiles dans des régimes totalitaires, qu'ils soient journalistes, informateurs ou dissidents politiques.

Mais le côté obscur de Tor réside dans son utilisation à des fins moins avouables, comme l'achat et la vente de monnaie virtuelle (Bitcoins), la distribution de contenu illicite, le commerce illégal, l'espionnage et la communication entre groupes criminels.

Qu'est-ce que le "Deep Web"?

Parmi les utilisations peu connues de Tor, on peut citer l'accès anonyme à l'Internet profond (Deep Web ou Darknet), une partie du réseau enfouie, obscure, inaccessible depuis les moteurs de recherche comme Google et qui héberge des contenus à la légalité parfois douteuse.

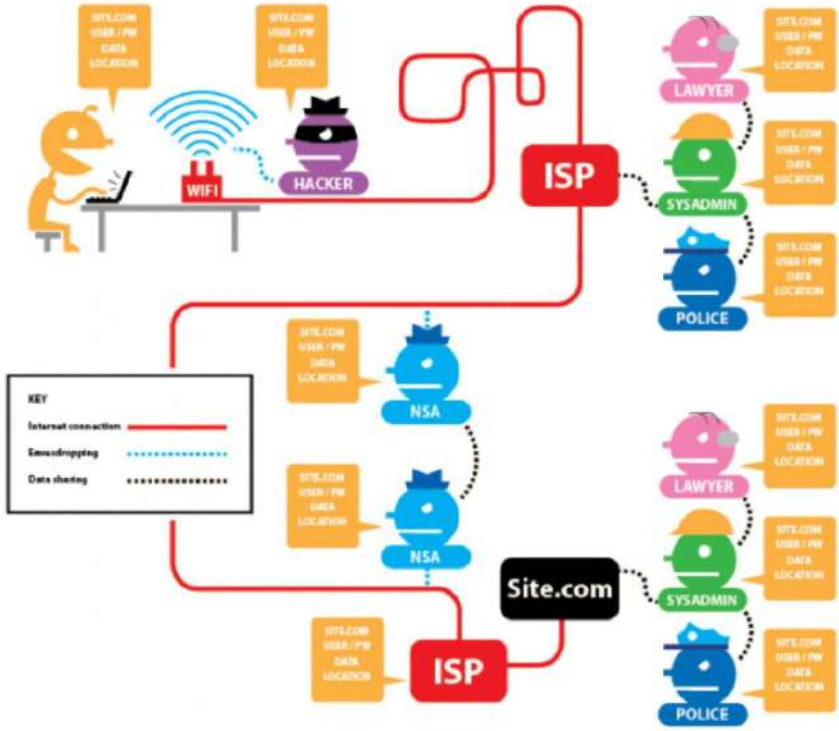
En tant que tel, le "Deep Web" n'est pas forcément illégal. On appelle "profonde" ou "obscure" toute partie de l'Internet qui, pour sa "profondeur" dans l'architecture des sites web, ou du fait de son inaccessibilité, est inconnue des moteurs de recherche.



La relation entre Tor est l'Internet profond est la même qu'avec le reste de l'Internet, mais étant donné que le Deep Web est aussi le repaire favori de groupes qui agissent en marge des lois, Tor leur est indispensable pour naviguer dans ces parages.

Comment fonctionne Tor?

Lorsque vous vous connectez à un site web, votre ordinateur ou votre smartphone essaie de se connecter directement à son serveur par la route la plus directe. C'est l'efficacité et la rapidité qui priment.



Dans ce cas, votre réseau, identifié par une adresse IP, est recensé comme le point de départ des communications. En cas de comportement illégal ou frauduleux de votre part, cette adresse sera utilisée contre vous.

Quand vous utilisez Tor, cette ligne entre le PC et le serveur distant est cassée. La connexion passe alors par une série de nœuds (hubs) secrets qui cryptent les données que vous envoyez et recevez. En arrivant au nœud ou hub de sortie, l'information est déchiffrée afin que le destinataire puisse l'utiliser. Dès cet instant-là, les données perdent toute leur protection.

Pourquoi Tor est-il aussi lent?

Comme s'en défendent les auteurs de Tor sur leur page officielle, il y a beaucoup de raisons qui expliquent que Tor est plus lent qu'une connexion normale. La première est liée à la conception de Tor: le trafic passe d'un nœud à l'autre, et les retards s'ajoutent les uns aux autres.

À mesure que le réseau Tor sera soutenu par plus de volontaires et par le financement de donateurs, la quantité et la rapidité des nœuds amélioreront la qualité générale du service. Mais n'attendez pas un trafic rapide comme l'éclair:

c’est le prix à payer pour être anonyme sur le net.

Tor est-il sûr ?

Utilisé correctement, Tor garantit l’anonymat, mais pas la confidentialité. Si quelqu’un espionne le trafic au point de sortie, il peut récupérer l’information. Un autre point faible de Tor réside au niveau des plugins. Flash, par exemple, annule l’anonymat de Tor, en modifiant la configuration de la connexion et en stockant ses propres cookies.

En général, l’utilisation de Tor avec des applications peu sûres l’empêche de garantir l’anonymat. Ceci inclut des services externes, comme les DNS. Heureusement, Tor travaille à résoudre ce problème.

Comment rendre Tor plus sur?

Pour augmenter la sécurité de Tor, il est recommandé de:

- Naviguer sans plugins et en désactivant le Javascript
- Toujours utiliser le protocole HTTPS
- Si vous envoyez une info confidentielle, chiffrez-la au préalable

On peut aussi combiner Tor avec un tunnel VPN comme HotSpot Shield, ce qui ajoute une couche supplémentaire de chiffrage. Mais il faut le faire correctement.

Quelles sont les alternatives à Tor ?

Si on souhaite naviguer dans l’anonymat, il existe plusieurs alternatives à Tor. Les plus connues sont les suivantes:

- JAP (Java Anon Proxy ou JonDon), un système de proxy sécurisé
- I2P, un logiciel qui crée un réseau totalement chiffré et privé
- Freenet, un des nombreux réseaux anonymes en circulation
- des proxys comme TunnelBear, Freegate ou PaperBus
- des tunnels VPN comme HotSpot Shield ou UltraSurf
- Un conseil: attention à ce que vous faites

Aucun outil n’est infaillible. Un hacker bien armé sera parfaitement capable de contourner l’anonymat de Tor et d’identifier qui se cache derrière la chaîne de

nœuds de la connexion anonyme. Tor contribue à votre anonymat, c'est certain, mais il ne vous garantit ni l'invisibilité ni, encore moins, l'impunité.

Quel avenir pour Tor ?

Si Tor attire de plus en plus d'utilisateurs, c'est que depuis l'affaire Snowden, la protection de ses données personnelles est devenu un sujet qui intéresse le grand public. Selon Linus Nordberg, un des développeurs de Tor, entre juin 2012 et juin 2013, le navigateur Tor a été téléchargé 60 millions de fois; depuis juin 2013, 150 millions de téléchargements ont été enregistrés.

Mais Tor n'est pas aimé par tout le monde. Le réseau intéresse la NSA. Selon les dernières révélations diffusées par la télévision publique allemande, la NSA trace tous les utilisateurs de Tor. Autre manière de se débarrasser de Tor est l'arsenal juridique et le droit américain. En effet, Tor est une organisation américaine et donc soumis au droit américain et notamment au National Security Letters, des requêtes contraignantes émises par des agences fédérales américaines (FBI, département de la Défense) qui leur permettent d'obtenir toute information nominative à des fins de surveillance, et ce, sans aucune supervision judiciaire.

En attendant, Tor continue de s'organiser et fait appel aux bonnes volontés pour se développer. Son plus grand défi reste de se faire connaître davantage, d'être encore plus facile à utiliser et plus rapide.

Observer ce qui se dit sur la partie « cachée » d'Internet permet aux entreprises d'anticiper une attaque informatique. Mais infiltrer les réseaux cybercriminels nécessite de prendre des précautions.

Internet tient son oiseau de malheur. Dailymotion n'a pas pu faire autrement que de reconnaître ses faiblesses quand le site Leaked Source a annoncé que des mots de passe et des identifiants de ses membres inscrits étaient tombés entre les mains de cybercriminels. Heureusement, la plate-forme française de vidéos en ligne avait chiffré une partie de ces informations , les rendant difficilement exploitables pour un informaticien mal intentionné. Ces derniers mois, LinkedIn, Foursquare, MySpace et d'autres ont vécu l'amère expérience d'être brocardés par le site hébergé en Russie.

À chaque fois, ses administrateurs invitaient gratuitement les internautes à vérifier s'ils étaient concernés. Contre paiement, ils proposent aussi de consulter

les bases de données volées. Leaked Source affirme les repérer en scannant le Web officiel et le dark web. Mais les entreprises pourraient très bien s'infiltrer elles aussi sur la partie « cachée » d'Internet, celle où les moteurs de recherche traditionnels ne fonctionnent plus. « Je ne conseille pas aux entreprises de le faire seules mais repérer ce qui se passe sur le dark web leur permettra de limiter les dégâts », pointe Alexeï Chachourine, analyste pour Orange Cyberdéfense. Ainsi, Dropbox a anticipé le pire l'été dernier .

Auprès des marchands d'armes informatiques

Attention, surfer sur le dark web n'est pas une promenade en bord de mer par temps calme. Certes, tout n'y est pas noir, malgré ce que laisse penser l'appellation de ce coin du cyber-espace. De simples citoyens soucieux de leur vie privée y communiquent entre eux. Mais, c'est aussi là que l'on trouve des espions peu recommandables, des trafiquants de drogue et des marchands d'armes informatiques.

Daniel Smith, responsable de la recherche en sécurité chez Radware, guide ses interlocuteurs sur les réseaux Tor et Invisible Internet Project (I2P). Sur le moteur de recherche spécialisé Torch, il lance en anglais la requête « louer un botnet ». Pour 25 dollars, il peut souscrire au détournement de la puissance informatique d'un ordinateur vers la cible de son choix. À très grande échelle, cette technique a paralysé une partie du Web mondial en octobre dernier . Sur le darknet, des places de marché - façon eBay de la cybercriminalité - proposent des logiciels rançonneurs pour moins de 400 dollars. Pas étonnant que ce fléau fasse de plus en plus de victimes . Pour davantage de discrétion, la facture peut être réglée en bitcoins, la monnaie électronique anonyme. Sur les forums de hackers, Daniel Smith fait lire les discussions entre vendeurs et acheteurs de logiciels malveillants. Certaines communautés lui sont fermées : « pour s'inscrire, il faut commettre un crime », explique-t-il. Lui-même se dit ancien hacker mais assure n'avoir jamais franchi la limite de la loi. Certains de ses anciens camarades comptent, eux, sur leur réputation d'experts techniques prêts à tout pour décrocher les meilleures missions sur des sites de petites annonces spécialisées.

Infiltration sous pseudonyme

L'environnement est effrayant mais entrer en contact avec ce monde-là permet aux responsables de la sécurité informatique de mieux comprendre leurs

adversaires. « Sur le dark web, les entreprises peuvent apprendre comment sont monétisées les données volées, notamment les données bancaires, ou entendre parler d'une faille concernant leurs propres système de paiement en ligne ou leurs objets connectés », explique Alexeï Chachourine. C'est aussi là que les sites Internet peuvent savoir s'ils ont été ou sont encore dans le viseur de cybercriminels. Par exemple, des listes de sites où le vol d'identifiants de cartes bancaires paraît facile sont mises à jour quotidiennement.

Pour s'y infiltrer, les spécialistes préconisent d'utiliser un ordinateur entièrement déconnecté du réseau de l'entreprise et qui ne servira qu'à ça. « Naviguer dans le dark web est dangereux, prévient Daniel Smith, on peut cliquer sur un lien qui lance une attaque informatique sans s'en rendre compte et devenir complice d'un crime ». Lorsqu'il discute en ligne avec des hackers, il utilise une liste de pseudonymes à rallonge pour ne pas se faire repérer. Alexeï Chachourine utilise le même stratagème. « Les cybercriminels réputés se protègent des curieux. Si votre profil n'est pas sérieux, ils ne vous répondront pas », remarque-t-il. Pis, ils attaqueront. Malheureusement, c'est aussi auprès d'eux que les analystes peuvent obtenir les informations les plus intéressantes. Pour contourner le problème, des start-up comme Cybelangel scanne le dark web pour ses clients . Mais la tâche est plus ardue que la recherche de fichiers de données menée par Leaked Source. « Lancer une surveillance automatique du dark web est impossible car les sites changent souvent de noms, réfute Alexeï Chachourine, de plus, les cybercriminels utilisent des jargons et des expressions codées inspirés par plusieurs langues ». Pour ne rien arranger, il s'agit souvent des langues rares : russe, chinois ou roumain. Sur le dark web plus qu'ailleurs, le crime n'a pas de nationalité.

c. Les 6 conseils d'Edward Snowden pour protéger ses données personnelles en ligne

Quoi de mieux qu'une petite "Master class" d'Edward Snowden pour s'assurer (un peu) d'anonymat sur internet. Interrogé par le site The Intercept, celui qui est adulé par certains, accusé par d'autres (dont la justice américaine), est forcément devenu un spécialiste de la protection de données. Réfugié à Moscou, il prodigue 6 conseils à appliquer pour que le commun des mortels puisse se défendre.

Conseil numéro 1 : chiffrer son disque dur

Qu'est-ce c'est ? Il s'agit tout simplement de faire en sorte que les données ne puissent pas être utilisées par une personne tierce ou sur un autre ordinateur sans le mot de passe adéquat.

Pourquoi ?

"Vous devriez chiffrer votre disque dur, de sorte que si votre ordinateur est volé, les informations ne peuvent être obtenues par un adversaire – vos photos, le lieu où vous vivez, là où vous travaillez, où vont vos enfants, où vous allez à l'école..." explique Edward Snowden.

Comment on s'y prend ? Chiffrer ses données n'est pas très compliqué. Ainsi, Windows intègre un outil de cryptage très simple et permet de sécuriser ses dossiers un par un. Il suffit de cliquer-droit, puis Propriétés et dans Onglet général, sélectionner Avancée. Il suffit alors de cocher Chiffrer le contenu pour sécuriser les données. Pour crypter la totalité du disque dur, il vaut mieux utiliser des programmes dédiés comme le programme DiskCryptor, très simple d'utilisation, qui fixera un mot de passe pour accéder aux données. ATTENTION

L'avis du spécialiste

"Le chiffrement des données est absolument nécessaire, même pour le commun des mortels" affirme Frédéric Mouffle, directeur du pôle investigations et sûreté informatique chez Ker-Meur. "Les affaires de type "snapshat" (opération "snappening") ou le piratage des données "icloud" en sont la preuve. Si les données (concernant icloud) avaient été cryptées, les images n’auraient pu être diffusées."

Conseil numéro 2 : utiliser un générateur de mot de passe

Qu'est-ce que c'est ? Un gestionnaire de mot de passe permet de définir de compiler automatiquement des mots de passe uniques et très complexes.

Pourquoi ? "Une des principales sources pour obtenir des informations sont les anciennes données" souligne Edward Snowden. "Vos informations d'identification peuvent refaire surface car un service que vous n'utilisez plus depuis 2007 a été piraté et le mot de passe que vous utilisiez est le même que celui de votre compte Gmail."

Comment on s'y prend ? De nombreux programmes de gestionnaires de mots de passe existent : on peut citer Dashlane ou KeePassX qui génèrent et conservent tous vos mots de passe, même sur smartphone. Et ces données ? Eh bien, elles n'existent que sur l'ordinateur (ou le smartphone), sont totalement cryptées et ne sont donc pas conservées sur le cloud.

Avis du spécialiste

"C’est une bonne chose à condition d’avoir un mot de passe "fort". Il est à noter que dernièrement les gestionnaires de mots de passe tel que "KeePass" ou encore "lastpass" se sont montrés vulnérables dans des conditions très particulières, ce qui rend l’attaque plus compliquée qu’exploiter une page de phishing. C’est une sécurité supplémentaire."

Conseil numéro 3 : utiliser une authentification forte

Qu'est-ce que c'est ? Une authentification à double facteur consiste à utiliser deux modes d'identification complémentaire : un mot de passe puis un certificat. Par exemple, une carte à puce fonctionne de cette façon. L'ordinateur ne la valide seulement si les informations qu'elle contient correspondent au code secret.

Pourquoi ? "L'intérêt de cette technique est que si vous vous faites voler votre mot de passe, elle permet d'avoir un second moyen d'authentification (un SMS ou quelque chose comme ça)" explique Edward Snowden.

Comment on s'y prend ? Désormais de nombreux logiciels intègrent

l'authentification à double facteurs comme Gmail, Dropbox, Twitter… Ainsi, vous êtes rapidement prévenu si votre compte est utilisé par un autre outil que votre ordinateur ou votre smartphone.

L'avis du spécialiste

"Utiliser la double authentification est devenu une évidence, lorsque par exemple, on cherche à modifier le numéro de téléphone enregistré dans votre compte, une validation par SMS sera alors nécessaire et mettra fin à l'attaque..."

Conseil numéro 4 : utiliser Tor

Rappel

Tor est un réseau informatique qui fonctionne comme un oignon. Des couches (de routeurs) se superposent pour rendre la navigation internet anonyme. Tor est à la fois utilisé par les opposants politiques dans de nombreux pays mais aussi par les criminels pour s'échanger des photos pédopornographiques ou vendre de la drogue.

Pourquoi ? "Je pense que Tor est le projet le plus important pour renforcer la vie privée aujourd'hui" affirme Edward Snowden. "Personnellement, je l'utilise tout le temps."

Comment on s'y prend ? Utilise Tor est devenu un jeu d'enfant. Il suffit de télécharger le programme sur le site officiel et de le lancer au moment d'aller sur internet. Evidemment, utiliser Tor n'a plus d'intérêt si vous vous connectez à Facebook ou Twitter puisque vous vous identifiez sur un site tiers.

L'avis du spécialiste

"Tor est un réseau structuré avec un ensemble de relais qui ne garantissent pas finalement l'anonymat. Il vous garantit juste que ce sera "long et compliqué", pour remonter jusqu'à vous... Une attaque type "man in the middle" (L'homme du milieu en français) a déjà été réalisé avec succès. Tor a d'ailleurs communiqué le 30 juillet, via un billet sur son blog, que le réseau était compromis par une faille permettant a un tiers de surveiller certains utilisateurs ! Le réseau Tor ne s'appuie que sur une dizaine de serveurs maîtres appelés aussi « Directory Authority » qui assurent un échange heuristique des relais

authentifiés aux logiciels client utilisateurs.

Conseil numéro 5 : crypter ses appels

Qu'est-ce c'est ? Il s'agit simplement d'empêcher que les appels puissent être écoutés.

Pourquoi ? "Dès que vous parlez, vos communications, si elles sont interceptées, ne peuvent pas être lues par des adversaires" affirme Edward Snowden.

Comment on s'y prend ? Il existe une application, appelée Signal, qui s'occupe de crypter vos appels. Elle peut être trouvée dans l'app store d'Apple et dans celui d'Android. En revanche, si vous être un véritable activiste, Signal n'est pas forcément une barrière infranchissable.

L'avis du spécialiste

"Le cryptage de la téléphonie n’est pas nécessaire en Europe, à moins que vous ayez quelque chose à vous reprocher" affirme Frédéric Mouffle. "L’interception de communication GSM n’est pas à la portée de tous le monde, ce n’est plus un "canal prioritaire" face à la multiplication des moyens de communication (vocaux). De nombreuses applications sont en effet disponibles (Whatsapp, Facebook, etc …) utilisant d’autres protocoles que le GSM".

Conseil numéro 6 : télécharger un bloqueur de publicités

Qu'est-ce que c'est ? Un petit programme qui se charge de fermer les publicités intempestives sur internet.

Pourquoi ? "Tout le monde devrait disposer d'un bloqueur de pub" affirme Edward Snowden. "Au moins pour des raisons de sécurité. Certains fournisseurs internet introduisent leurs propres publicités dans leur logiciel."

Comment on s'y prend ? Le plus connu est évidemment l'allemand Adblock qui peut se télécharger facilement et se montre particulièrement efficace. Problème, les éditeurs sont vent debout car les recettes publicitaires fondent comme la neige au soleil.

L'avis du spécialiste

"Certains sites internet ne se financent que par la publicité. Les bloquer a pour conséquence de mettre en difficulté ce type de médias qui proposent des contenus gratuits. Mais comme il faut de tout pour faire un monde, d’autres sites internet utilisent quant à eux abusivement les "pop-up" qui peuvent vite devenir très envahissantes. Vecteur d’infection, les "pop-up" et autres "applet" sont utilisés pour infecter les machines. Il faut donc se doter d’un "bloqueur de pub" et l’activer en fonction de ce que l’on fait sur internet."

BONUS : le conseil de Julian Assange

Parce qu'il n'y a pas qu'Edward Snowden qui se planque pour échapper à la justice. Enfermé dans l'ambassade équatorienne à Londres, le père de Wikileaks propose une alternative incongrue aux méthodes de cryptage : la poste. "Ma recommandation, pour les gens qui n'ont pas dix années d'expérience en cryptographie, est qu'ils reviennent à des méthodes anciennes: utiliser la Poste traditionnelle" a-t-il récemment expliqué au site belge, Le Soir.

Chapitre 15 : Les perspectives de recherche

L'informatique a atteint une dimension planétaire et touche un large public amené à véhiculer et traiter un très grand nombre d'informations vulnérables. Il est donc indispensable de concevoir de nos jours la sécurité comme un état de vigilance à mettre en œuvre de manière proportionnée, une anticipation permanente à diffuser dans les infrastructures numériques, plutôt que de subir des attaques comme une fatalité moderne et de cicatriser en bout de chaîne les dommages déclenchés par les violences et les incivilités immatérielles. C'est le défi à relever pour gagner la confiance auprès des citoyens et des entreprises afin qu'ils utilisent fructueusement ces technologies.

À brève échéance, les thèmes de recherche portent essentiellement sur :

- la cryptographie : proposer des mécanismes cryptographiques moins gourmands en ressources notamment en environnement contraint, proposer des mécanismes cryptographiques pour la gestion des droits (DRM) garantissant leur traçabilité et proposer des méthodes de chiffrement par flot aussi sûres que les méthodes actuelles de chiffrement par blocs mais plus rapides ;

- les modélisations et mises en œuvre de politiques de sécurité : introduire l'espace, le temps, le contexte, la mobilité, gérer les conflits de politiques de sécurité, modéliser les grandes infrastructures et modéliser les politiques de sécurité pour le dossier médical ;

- la gestion des crises amplifiées par effet domino : protéger les infrastructures critiques et les rendre résilientes ;

- l'identification et authentification des acteurs, des contenus et la gestion des droits ;

- la biométrie : banque de données pour étalonner des algorithmes de reconnaissance, signature avec biométrie, reconnaissance du comportement par suivi de silhouette et analyse des gestes ;

- le tatouage d'images, de sons, de flux vidéos et de logiciels :

protection des ayant-droits, contrôle des copies, authentification, intégrité ;

- la stéganalyse : détection d'informations cachées par procédés de stéganographie ;

- la sécurité des SI : techniques de détection d'intrusion, de protection de la vie privée, sécurité des grilles, architectures de système de leurres ;

- la sécurité des réseaux fixes et sans fil, mobiles, actifs, auto-configurables, ad hoc ;

- l'évaluation réaliste des vulnérabilités sur le plan opérationnel, arrêt des virus, filtrage du spam en amont du terminal de l'utilisateur final ;

- la sécurité de l'urbanisation digitale et la sécurité du virtuel : nouveaux paradigmes de sécurité répondant aux besoins des applications ubiquitaires, établissement de confiance sans se baser sur une infrastructure existante ou une organisation a priori, structures avec faible connectivité ou connectivité intermittente, niveau de garanties intermédiaires par rapport à la recherche habituelle d'une assurance absolue ;

- la certification, l'assurance de sécurité : introduction de méthodologies d'évaluation de la sécurité, incrémentales, plus rapides et moins coûteuses.

À plus long terme, la sécurité numérique devrait affronter le mur de la loi de Moore et s'immiscer dans les fissures entre le matériel invisible des transistors binaires en prolifération presque cancériforme et le logiciel éparpillé, grouillant du marché massif des ordinateurs en poussière intelligente (smart dust) et franchir le Rubicon du numérique, c'est-à-dire parvenir à l'âge quantique, aborder la sécurité des nanotechnologies et de la bio-informatique, et se saisir des questions suivantes :

- la cryptographie quantique : recherche en amont pour la distribution des attributs de sécurité, en utilisant une confiance

inédite fondée sur l'incertitude d'Heisenberg, et bâtir des réseaux quantiques hautement sécurisés à partir de transmissions en clair de photons uniques et/ou de gerbes de photons, résistants à une lecture indiscrète grâce à des protocoles sécurisés fondés sur le constat révélé par la mécanique quantique, à savoir l'impossibilité physique d'observer subrepticement un grain de lumière sans le perturber et finalement prévenir les deux instigateurs de la communication quantique ;

- la sécurité des nanotechnologies : recherche en amont sur le marquage à une échelle invisible du monde physique et sur des infrastructures de confiance pour la traçabilité des nanotechnologies ;

- la sécurité numérique du monde vivant : recherche en amont, avec des principes éthiques, sur le marquage et la traçabilité du règne animal et végétal, avec des prothèses numériques ou une intrication du numérique dans le cœur des cellules vivantes ;

- la sécurité de la poussière intelligente, c'est-à-dire des nano-ordinateurs massifs et passifs, la future génération des ordinateurs en essaim, presque invisibles qui vont jalonner bientôt notre espace ambiant, étiqueter nos vêtements et escorter nos objets familiers ;

- la sécurité de la prochaine convergence à l'horizon, celle du numérique, du quantique avec les bio-nanotechnologies, c'est-à-dire amorcer une synthèse humaniste du traitement de la connaissance du monde artificiel créé ex nihilo, afin de contrôler l'écosystème artificiel que l'Homme vient d'engendrer depuis plus d'un demi-siècle, d'apprivoiser les créatures ultérieures, d'explorer sereinement les nouveaux territoires et d'appréhender les ruptures technologiques à venir.

Quel rôle l'intelligence artificielle jouera-t-elle en cybersécurité ?

L'Intelligence Artificielle promet de révolutionner la perception de la cybersécurité au cœur des entreprises, mais pas uniquement. Ce changement de paradigme engage en effet, une redéfinition complète des règles du jeu pour les DSI et les RSSI, ainsi que l'ensemble des acteurs de la sécurité.

Longtemps, les technologies de détection et de suppression de virus informatiques se sont appuyées sur des « signatures » afin d'identifier le code malveillant présent sur une machine. Malgré le fait que les outils en sécurité informatique ont cherché à améliorer leur efficacité en tirant parti de diverses innovations, ces logiciels n'ont jamais réussi à s'éloigner de l'approche classique. « Je parle ici du principe d'une base de données globale qui regroupe les différents types de malwares identifiés jusqu'au présent. À la recherche de motifs spécifiques, les outils traditionnels scannent le code des systèmes de fichiers et la mémoire de l'ordinateur, permettant ainsi la détection des signatures préexistantes dans la base de données. En d'autres termes, votre antivirus est capable de détecter seulement les cyber-menaces connues. » explique Joseph Steinberg, expert cybersécurité qui a participé à la rédaction du livre blanc « L'Intelligence Artificielle : vraie rupture en cybersécurité » publié par ITrust à l'été.

Les systèmes de détection ou de protection en temps réel basés sur des signatures (comme les IDS/IPS ou les firewalls applicatifs) sont donc de plus en plus impactés par la lourdeur de leurs bases de données qui ne fait que croître. De plus en plus de signatures différentes sont nécessaires ce qui a pour conséquence de ralentir les systèmes de détection. Enfin, outre la volumétrie des données en constante augmentation, la typologie des attaques se diversifie toujours davantage.

Dès lors, les entreprises spécialisées dans la cybersécurité de pointe ont compris que la recherche d'une activité inhabituelle, plutôt que la recherche d'une activité malveillante typique, est le meilleur moyen de faire face à l'insuffisance des signatures. Cette nouvelle approche est ce que l'on appelle la détection d'anomalies. En suivant ce principe, les experts en sécurité créent des règles afin d'apprendre à leur machine la « normalité ». Une normalité qui est bien entendu amenée à évoluer. Ce qui est « normal » aujourd'hui peut devenir une exception demain.

C'est pourquoi la détection d'anomalies peut parfois générer un grand nombre de faux positifs. En raison d'un nombre limité de ressources, cette abondance peut accabler le personnel en charge de la DSI. Ces derniers ne sont pas capables d'examiner toutes les remontées en temps réel et, par conséquent, laissent passer des alertes. Et si parmi ces signaux faibles il y avait des vraies intentions hostiles ?

« C’est pourquoi nous avons besoin de l’intelligence artificielle. » souligne Jean-Nicolas Piotrowski, PDG Itrust. « Les capacités d’une IA peuvent offrir des avantages considérables d’un point de vue sécurité et efficacité », en faisant la différence entre une simple irrégularité, et un véritable signal hostile. L’intégration des informations contextuelles à partir des flux « Threat Intelligence » peut également affiner la précision de l’analyse des activités inhabituelles susceptibles de porter, plus tard, sur une cyberattaque. Bien évidemment, le feedback sert toujours à améliorer la capacité de détection d’une menace inconnue.

« Gardez à l’esprit que la détection d’anomalies et la compréhension d’un comportement malveillant, ainsi que la détection de menaces, sont des activités ayant pour but des objectifs très différents. Pour assurer l’avenir de la cybersécurité, nous aurons besoin des deux. » souligne à son tour Joseph Steinberg.

La sécurité cognitive, proactive par nature

Sur la base de ses connaissances et expériences, le système d’Intelligence Artificielle doit donc produire une analyse proche de celle d’un humain, être capable de faire les liens entre différents événements pour déduire s’il a affaire – ou non – à une attaque potentielle. Il est donc nécessaire d’enseigner au système d’IA ce qu’est un incident de sécurité. C’est-à-dire lui transmettre des exemples d’incidents, des modèles ou modes opératoires utilisés pour perpétrer une attaque. À force d’apprendre, l’IA sera en capacité de conseiller les analystes sur les incidents potentiels, de trouver la cause d’une attaque et de mettre en place un plan de remédiation. Ainsi, alors que la génération actuelle de systèmes est réactive, avec la capacité à détecter et à réagir à des anomalies ou à des attaques, la sécurité cognitive est par nature proactive.

Le champ des possibles est assez vaste et certaines applications exploitent déjà le machine learning à des fins de cybersécurité. « Parmi elles on peut bien sûr citer les systèmes de détection des évènements sécurité (SIEM) dont certains utilisent l’intelligence artificielle pour détecter les écarts de comportement utilisateur par rapport au comportement habituel d’utilisateur qu’ont connu les systèmes. Cette capacité est souvent appelée UEBA ou User and Entity Behavior Analytics. » explique Yannick Delmont est Head of Security chez Claranet.

Il existe aussi une nouvelle génération d'anti-virus dont le fonctionnement repose à la fois sur la détection d'anomalies et sur un vaste réseau d'échange et d'apprentissage.

Gigamon vient quant à lui d'annoncer le lancement de son nouveau modèle de sécurité « Defender Lifecycle » capable de faire face à la vitesse, au volume et à la nature polymorphique des cybermenaces réseau actuelles. Basé sur une couche primaire de visibilité totale des données en mouvement, il s'appuie sur les quatre piliers que sont la prévention, la détection, la prédiction et le confinement des menaces tout au long du cycle de vie d'une attaque. Ce nouveau modèle intégrera le machine learning, l'intelligence artificielle et l'automatisation des flux de sécurité afin de déposséder l'assaillant, et de redonner le contrôle et l'avantage au gestionnaire du réseau. Gigamon s'est associé à plusieurs partenaires de longue date incluant Cisco, Imperva, RSA et Vectra Networks. « Pour chasser et classer efficacement les menaces, les organisations ont besoin d'une visibilité permanente de l'ensemble de la surface d'attaque, tant au niveau des charges de travail dans le cloud et le datacenter que pour les appareils des utilisateurs et de l'Internet des Objets, déclare Mike Banic, Vice-président de Vectra. Grâce à la visibilité parfaite du réseau fournie par la plateforme de visibilité Gigamon, l'intelligence artificielle mise au point par Vectra permet aux entreprises de bénéficier d'une détection en temps réel et de réagir plus rapidement en cas de cyberattaque. »

Alors, fini les innombrables heures dédiées à la surveillance des signaux faibles ou à la classification des alertes de type faux-positif ? « Nous assistons à un moment historique, un moment où l'Intelligence Artificielle assume enfin son rôle de Deux Ex Machina dans de nombreux cas » souligne Jean-Nicolas Piotrowski, PDG ITrust, PME spécialisée en cybersécurité qui a, dès 2009, lancé des recherches sur des systèmes intelligents capables de détecter les signaux faibles au sein des systèmes d'information pour prévenir attaques et virus inconnus. « La grande expérience de nos ingénieurs lors de missions forensiques, d'audits, ou d'expertises, nous a permis de modéliser un moteur comportemental permettant de lutter notamment contre les APT. Notre équipe s'est spécialisée dans le traitement décisionnel des informations de sécurité de différentes applications, serveurs ou équipements de sécurité. Reveelium a été développé pour fournir un système expert de détection d'anomalies basé sur des algorithmes intelligent qu' ITrust développe depuis 5 ans avec l'appui de 3 laboratoires internationaux. Au sein d'ITrust nous utilisons donc les technologies Big data et Machine Learning au service des problématiques de Cybersécurité. »

ajoute le PDG.

Reveelium analyse automatiquement les comportements des systèmes d'information et recherche les signaux faibles dans la très grande quantité de données générées par les serveurs, applications, bases de données, équipements de réseaux et de sécurité. Il identifie de manière très précise les anomalies de sécurité de la plupart de problèmes de sécurité régulièrement rencontrés. Reveelium tire sa force dans l'utilisation de 3 moteurs complémentaires.

Le moteur de détection de signal faible est issu de recherches poussées en algorithmes mathématiques. Il est complété par un moteur de corrélation métier issu de l'expérience des ingénieurs et consultant sécurité. « Les deux moteurs s'adossent enfin à une base de connaissance globale, la mémoire de Reveelium, qui identifie et collecte les comportements de tous les Reveelium des clients. L'ensemble de ces éléments regroupés permet ainsi de faire bénéficier à l'ensemble de nos clients les expériences des uns et des autres. » souligne l'équipe ITrust.

1 La détection des malwares inconnus

Avec sa capacité à apprendre des modèles comportementaux normaux, l'IA peut identifier en amont les formes inconnues et polymorphes d'un logiciel malveillant sans faire appel à des bases de signatures.

2 La détection des menaces internes (délibérées)

Dans le cadre d'une investigation post-attaque, il est parfois difficile de tracer les signaux faibles déclenchés par un attaquant. L'intelligence artificielle permet, toujours de par sa capacité à apprendre de modèles comportementaux – cette fois-ci anormaux, d'apporter des solutions.

C'est un facteur extrêmement important à prendre en compte pendant une analyse forensic. Cela permet non seulement de valider la source de la menace (interne ou externe), mais de faire également la distinction, si la menace vient de l'intérieur, entre un employé réellement malveillant et un employé ayant simplement cliqué sur le mauvais lien.

3 La détection des comportements imitant l'activité humaine

Prenons, par exemple, l’ordinateur d’un directeur financier qui utilise un mécanisme parfaitement légitime afin de soumettre les informations des salariés à son processeur de paie. Pendant l’opération, si l’IA observe une tentative de retransmission de ces informations vers un autre ordinateur inconnu, elle va automatiquement bloquer ce comportement anormal et suspect.

En d’autres mots, l’intelligence artificielle peut également dépister les activités malveillantes qui simulent au départ le comportement humain.

4 L’authentification des utilisateurs

En analysant et en stockant les propriétés biométriques des humains, l’IA pourra apprendre et, finalement, reconnaître les comportements spécifiques de ces individus. C’est pourquoi l’intelligence artificielle pourra jouer un rôle central dans l’autorisation d’accès à des ressources informatiques sensibles.

5 La gestion des alertes de sécurité informatique

Grâce à ses moteurs Big Data, l’IA peut analyser une énorme quantité d’alertes. Toutefois, elle peut apprendre à ignorer les faux positifs, ce qui rend la gestion de la sécurité plus efficace et soulage les équipes d’experts surchargées.

Certains experts pensent que, dans quelques années, l’IA supplantera totalement l’humain dans le domaine de la cybersécurité. « C’est clairement l’objectif des programmes de recherche financés par les gouvernements américain, chinois et russe », prévient Roman Yampolskiy, directeur du laboratoire de cybersécurité à l’université de Louisville (Kentucky), aux États-Unis.

« Ces technologies autoapprenantes ouvrent des perspectives intéressantes, mais il faudra mener de nombreuses expérimentations terrain avant de les appliquer à des systèmes complexes industriels ou de transport », relativise Gilles Desoblin, directeur du programme Internet de Confiance, chez SystemX.

D'autres applications de l'IA pour la cybersécurité

- L'assistance à la programmation : Adetunji Adebiyi, Johnnes Arreymbi et Chris Imafidon, de l’université de Londres-Est, ont montré qu’un système autoapprenant pouvait repérer des erreurs dès la conception d’un logiciel.

- La détection des failles : Isao Takaesu, du japonais Mitsui Bussan Secure Directions, travaille sur un logiciel auto-apprenant capable de détecter les failles d'applications déjà commercialisées.
- La réparation automatique des bugs : Le projet « Prophet » de deux étudiants du MIT, Fan Long et Martin Rinard, vise à mettre au point un système capable de proposer des patchs.
- L'attribution des cyberattaques : Actuellement, il faut des jours pour trouver l'origine d'une attaque. Les États-Unis ont alloué 17,3 millions de dollars au Georgia Institute of Technology pour créer des algorithmes capables de reproduire automatiquement l'expertise humaine dans le domaine de l'attribution des cyberattaques.

Le volume et la vélocité du flux des données en matière de sécurité est l'un de nos plus grands défis dans le traitement de la cybercriminalité.

La sécurité cognitive en est peut-être à ses débuts, mais le futur proche semble plus que prometteur. Un enrichissement permanent nourrira ce système ambitieux qui devra prochainement relever, lui aussi, le challenge des objets connectés…

Un outil dont on ne mesure pas toutes les qualités tant elles sont nombreuses, mais dont on peut imaginer les atouts dans un domaine qui agite particulièrement le monde et en particulier la France. En effet, analyser, comprendre, décrypter et anticiper… sont autant de points essentiels à la lutte contre le terrorisme qui pourrait trouver aussi un allié de taille dans l'intelligence artificielle.

CONCLUSION

Avec l’explosion des contenus, l'architecture des cybersphères (données et programmes associés) est rhizomorphe. Ce sont des bulbes de données et de programmes qui (grâce à la convergence informatique et télécoms) sont en train de s'installer durablement et parfois d'échapper à leur propriétaire.

Il existe une réelle inquiétude face à l’urbanisation numérique en cours : perplexité des utilisateurs, mais aussi difficulté des développeurs et des exploitants. L’utilisateur va disposer bientôt d’un nouvel écosystème, d'une immense machine de communication où l'on pourra relier les êtres humains nomades et leurs appareils électroniques usuels interconnectés. On assiste à la naissance d’un règne numérique composé d’entités autonomes qui vivent leur propre cycle. La perspective de cette communication généralisée, en réseau, sans hiérarchie, en utilisant ce nouveau règne, soulève des questions de sécurité, listées ci-dessous, qui n’ont pas trouvé de réponses à ce jour :

a) la disparition des cloisons étanches séparant les vies privée, professionnelle et publique. Tout individu construit, sur cette unique infrastructure commune, en prolongement de son corps, un réseau virtuel privé avec ses propres données. Ce réseau commence dans les prochaines prothèses numériques du corps biologique et finit par se dissoudre aux confins de la planète dans la masse chaotique de la pâte numérique indifférenciée de l’information fongible de la Toile. Ce réseau propre à chaque individu est perméable, vulnérable et finalement lui échappe. L’individu laisse aussi des empreintes, des traces numériques indélébiles que d’autres humains peuvent retrouver après enquête, pour reconstituer une biographie à son insu ;

b) la construction complexe au-dessus du monde physique, de plusieurs étages de mondes logiques virtuels, toujours plus symboliques et abstraits. La sécurité numérique consiste justement à amarrer, coûte que coûte dans ces entrelacs virtuels, ces divers étages à des instances physiques réelles, afin de se raccrocher au monde réel.
Les concepteurs de ces édifices sont prisonniers de ces paradigmes qui s’accumulent au fil du temps de l’évolution technologique et qui finissent par paralyser l’essor des techniques numériques ;

c) l’édification d’une masse de données (pépites d’information enfouies dans

un chaos de déchets informationnels) qui gonfle à vue d'œil et que les moteurs de recherche généralistes ont du mal à vaincre : information fongible, tout venant, qu'il est nécessaire de rechercher, de saisir, de trier, de sélectionner, de vérifier, créant ainsi une entropie envahissante ;

d) l'effacement des frontières des espèces :

- espèces géographiques comme les États (Internet ignore les contours des pays et transgresse les barrières nationales), les systèmes d'information des entreprises (l'informatique est de plus en plus externalisée), les huis clos (les ondes hertziennes débordent les murs de nos constructions physiques) ;

- espèces temporelles comme les réunions en chair et en os, les discussions en direct ; la messagerie, les forums permettent le foisonnement de rencontres et de conversations en dehors du temps ;

- espèces informatiques qui se fondent dans un syncrétisme indescriptible avec des ontologies distinctes mais entremêlées, comme les constructions d'entités protocolaires encapsulées, interopérables qui s'enchevêtrent et deviennent interdépendantes ;

e) la relative disgrâce de la notion d'identité, avec la prévalence de l'anonymat, si essentiel dans la philosophie de l'Internet, et le recul concomitant de la notion d'auteur dans la masse de documents disponibles sur le Web. Cette vision suscite des interrogations sur les effets regrettables de l'univers numérique, auxquels on n'a pas encore découvert de parades. Le système globalement n'est pas maîtrisé en temps réel. La généralisation des virus n'avait pas été prévue avec l'arrivée du haut débit, la congestion des réseaux par les spams n'a pas été non plus annoncée.

La sécurité du XXIème siècle devra élaborer une confiance renouvelée, dans une clarté numérique assumée par tous les acteurs, guidée par une éthique persévérante, dans un esprit civique, entre les deux mondes biologique et numérique, à l'échelle d'une gouvernance numérique planétaire.